从首破接口到纵深防御

Contents

摘要 . . . 3
1. 引言：问题、缺口、范围与研究问题 . . . 3
1.1 生成式视觉系统的端到端安全问题 . . . 3
1.2 既有组织范式、失败机制与精确缺口 . . . 4
1.3 图像—视频对象、范围与排除边界 . . . 4
1.4 中央问题、四个 RQ 与主张上限 . . . 4
1.5 贡献、状态边界与阅读路线 . . . 4
01.E1 证据展开：引言：生成式视觉安全为何需要端到端攻防视角 . . . 4
2. 综述方法与证据治理 . . . 6
2.1 文章类型、时间窗与状态语义 . . . 6
2.2 数据源、查询与检索通道 . . . 6
2.3 纳入、排除、版本与去重 . . . 6
2.4 筛选、数据提取与编码 . . . 7
2.5 证据等级、主张语言与归因 . . . 7
2.6 可比性门、统计拒绝与缺失处理 . . . 7
2.7 复现枚举、审计材料与更新规则 . . . 7
02.E1 证据展开：检索、筛选、编码与证据地图 . . . 7
3. 技术系统边界与威胁模型 . . . 10
3.1 从生成架构到安全状态 . . . 10
3.2 系统边界、资产与责任主体 . . . 10
3.3 攻击者能力、访问和预算 . . . 10
3.4 后果证据维度与因果链 . . . 10
3.5 视频新增的时间、运动、音画与流式状态 . . . 11
03.E1 证据展开：技术与安全脉络：从 GAN 到视频基础模型 . . . 11
03.E2 证据展开：系统边界、资产、主体与威胁模型 . . . 12
4. 首破接口分类、证据地图与比较合同 . . . 14
4.1 为什么选择首破接口作为主轴 . . . 14
4.2 判定树、并发、歧义与未知 . . . 14
4.3 I1-I7 安全合同与控制入口 . . . 15
4.4 当前证据地图与覆盖审计 . . . 15
4.5 指标单位、三联报告与统计拒绝 . . . 15
04.E1 证据展开：首破接口 taxonomy 的设计、判定与覆盖审计 . . . 16
5. I1-I7 镜像证据综合：攻击机制与最早中断控制 . . . 17
5.1 I1 数据、授权与语料：投毒/记忆根因 □ 来源、去重、隔离与撤回 . . . 17
5.2 I2 权重、代码与组合供应链：恶意制品 □ 签名、SBOM、沙箱与组合差分 . . . 17
5.3 I3 文本与多模态条件：越狱/控制劫持 □ 规范化、授权差分与能力门 . . . 18
5.4 I4 训练、微调与个性化：后门/再学习 □ 可信更新、回滚、擦除双集与同意 . . . 18
5.5 I5 采样、隐私、缓存与资源：提取/侧信道/成本放大 □ 隔离、预算、近重复与熔断 . . . 18
5.6 I6 检测、水印与来源：规避/移除/伪造 □ 多信号真实性证据栈 . . . 19
5.7 I7 身份、版权、诈骗与平台滥用 □ 身份核验、传播限制、事件响应与救济 . . . 19
5.8 跨接口传播、反例和未闭合证据 . . . 19
05.E1 证据展开：I1：训练数据、授权、标注与上游记忆攻击 . . . 20

05.E2 证据展开：I2：权重、代码、LoRA、适配器与供应链攻击 . . . 21
05.E3 证据展开：I3：提示、概念、多模态条件与生成控制劫持 . . . 21
05.E4 证据展开：I4：训练、微调、个性化与安全对齐攻击 . . . 22
05.E5 证据展开：I5：采样、潜空间、隐私提取、缓存与服务可用性 . . . 24
05.E6 证据展开：I6：检测、水印、来源证明与归属规避 . . . 25
05.E7 证据展开：I7：身份、版权、诈骗、政治传播与平台滥用 . . . 26
6. 跨接口纵深防御：组合、信任根与失效传播 . . . 27
6.1 七接口与五防御域的交叉映射 . . . 27
6.2 数据、制品、参数与运行时信任根 . . . 27
6.3 真实性信号与平台行动的非替代关系 . . . 28
6.4 撤回、版本、申诉与跨平台失效 . . . 28
6.5 正常效用、成本、适应性绕过和拒绝门 . . . 28
06.E1 证据展开：数据治理与组合供应链防御 . . . 28
06.E2 证据展开：训练、安全对齐、概念擦除与个性化防御 . . . 30
06.E3 证据展开：推理时条件审核、能力门与资源防御 . . . 31
06.E4 证据展开：检测、水印、指纹、签名与真实性基础设施 . . . 33
06.E5 证据展开：平台治理、事件响应与受害者救济 . . . 36
7. 视频生成专项综合：时间、运动、音画与流式状态 . . . 39
7.1 最小评测单位与有效分母 . . . 39
7.2 边界帧、时空后门、运动与轨迹 . . . 39
7.3 音画联合身份、语义与审核 . . . 39
7.4 内容/运动记忆、缓存与长时资源 . . . 40
7.5 视频水印、来源、转码与首次告警 . . . 40
7.6 可继承结论、不可继承结论与开放缺口 . . . 40
07.E1 证据展开：视频生成专项：时间、运动、音画与实时传播 . . . 40
8. 多源证据的现实与工程检验 . . . 44
8.1 学术论文与官方代码：机制、实现与未运行边界 . . . 44
8.2 系统卡、标准、产品与法规：声明和义务 . . . 45
8.3 32 项事件的因果链与未知字段 . . . 45
8.4 本地 PARTIAL_RUN 与七仓库 STATIC_AUDIT_ONLY . . . 45
8.5 多源证据的一致、冲突与停止规则 . . . 45
9. 讨论：跨家族解释与条件化部署决策 . . . 46
9.1 中央问题与四个 RQ 的受限回答 . . . 46
9.2 跨接口共同机制、反例与替代解释 . . . 46
9.3 闭源 API 与开放权重 . . . 46
9.4 创作者工具与企业媒体供应链 . . . 46
9.5 分发平台、受害者救济与高风险业务 . . . 47
9.6 最小组合、上线门、SLO 与明确拒绝条件 . . . 47
09.E1 证据展开：跨家族综合与部署决策 . . . 47
10. 局限、伦理、双用途与作者责任 . . . 50
10.1 检索、筛选、语言、地域与版本局限 . . . 50
10.2 证据、归因、统计和低基率局限 . . . 50
10.3 复现、工程与生产外推局限 . . . 50
10.4 双用途、伦理、公平与利益相关者 . . . 50
10.5 作者责任、可更新性与结论降级 . . . 51
10.E1 证据展开：局限、伦理、双用途与作者责任 . . . 51
11. 可证伪研究议程 . . . 52
11.1 视频、音画与实时状态（F01-F04） . . . 52
11.2 组合供应链、隐私、可用性与撤回（F05-F08） . . . 53
11.3 来源证明、低基率检测与跨平台处置（F09-F13） . . . 53
11.4 代理化生成与多阶段责任（F14） . . . 54
11.5 三阶段观察窗和停止规则 . . . 54
11.E1 证据展开：未来三至五年的可证伪研究议程 . . . 54
12. 结论 . . . 57
12.1 中央问题与四个 RQ 的边界回答 . . . 57

12.2 实践含义、非主张与后续最小验证 57
12.E1 证据展开：结论与开放材料 58
附录 A. 27 项统一论文深析与页级证据卡 58
APP-A.E1 证据展开：代表性研究谱系与二十七项统一深析 58
附录 B. 数据集、指标、完整比较矩阵与统计拒绝记录 66
APP-B.E1 证据展开：数据集、指标、基准与可比性 66
附录 C. 32 张事件卡、新闻与政策时间线 68
APP-C.E1 证据展开：新闻、真实事件、产品安全与政策时间线 68
附录 D. 局部实验、七仓库静态审计与构建回执 72
APP-D.E1 证据展开：有边界的局部实验与七仓库静态审计 72
数据、代码与状态声明 74
AI 辅助仅用于检索编排、结构化、初稿重构与一致性校验，不替代人类作者对每个技术、定量、法律和伦理主张的责任。
本稿的方法状态仍为非 PRISMA 严格系统综述，统计状态仍为 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE，端到端复现仍为 end_to_end_runs=0；任何后续更新必须保留原版本、变更映射、证据定位与失败记录，不得因文档已完成而默认科学状态升级。 74

附录：截止后更新（2026-08-09 至 2026-09-26） **74**
A.1 事件卡 E010 的后续：OpenAI—Hugging Face 事件已进入制度阶段 75
A.2 截止后新增的深度伪造与真实性事件 75
A.3 截止后新增的来源凭证与标准动向 75
A.4 如何使用本附录 75

摘要

图像与视频生成安全贯穿训练语料、模型制品、条件输入、训练更新、推理服务、输出真实性与平台分发，单看最终输出无法区分最先失效的合同、后续传播与现实后果。在当前语料中，若仅按攻击名称、内容类别或证据来源分列材料，同一结果会混合不同权限、控制入口和责任主体，而图像帧级证据也容易被误作视频级结论；本文将这种组织失配界定为需要解决的综述设计问题。本文由此考察图像与视频生成的端到端生命周期，追问攻击者首先破坏哪一安全合同，以及现有多源证据在何种权限、模态和评测协议下支持哪些镜像防御与部署判断。研究在 2014 年 1 月 1 日至 2026 年 8 月 9 日窗口内执行可审计多源检索、版本去重和分层编码，属于非 PRISMA 的 taxonomy survey，不声称穷尽文献或完成严格系统综述。截至该时间点，证据包包含 201 条中央来源记录及 174 个去重组、41 张论文卡、32 条攻防链、27 项统一论文深析和 32 张事件卡。面向当前语料的综合形成 I1—I7 首破接口、攻击—最早中断控制的镜像关系及多源证据边界，并将时间、运动、音画身份和流式状态识别为不能由静态图像结果逐帧替代的视频合同。由于研究单位、终点、分母、预算、模型和方差不兼容，元分析状态为 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE；本地实验仅为 PARTIAL_RUN，七个仓库仅为 STATIC_AUDIT_ONLY，且 end_to_end_runs=0。因此，本文只提出与部署场景、信任根和拒绝条件绑定的纵深控制组合，并把尚未闭合的问题转写为具有最低实验、核心指标和否证标准的研究议程。

关键词：图像生成；视频生成；生成式视觉安全；首破接口；纵深防御；后门与越狱；水印与来源证明；平台治理

\newpage

1. 引言：问题、缺口、范围与研究问题

1.1 生成式视觉系统的端到端安全问题

生成式视觉安全不是“提示进入—媒体输出—审核器判定”的单点问题，而是一组跨生命周期的安全合同：训练数据应有可追溯来源与授权，模型及依赖制品应与声明的身份和版本一致，文本与多模态条件应表达获准意图，训练更新应维持约定的安全属性，推理服务应保护租户、缓存和资源，真实性信号应可验证且不过度承诺，下游平台还要把身份、同意、标识、举报、申诉和救济转化为可执行流程。任一合同先行失效，都可能经后续接口传播；因而最终出现相似媒体，并不意味着攻击权限、证据责任或修复位置相同。

当前语料给出了这种区分的具体支点：Nightshade 把首个可定位失效放在污染样本进入训练语料，Rickrolling the Artist 把违约制品放在文本编码器，MMA-Diffusion 考察文本与图像条件的联合操作，训练数据提取依赖生成查询与近重复确认，而 WAVES 把水印攻击放入质量约束下的适应性评测 [@P005] [@P003] [@P009] [@P024] [@P030]。这些工作可以产生相似的有害、未授权或难归因输出，却分别要求数据治理、制品验证、条件控制、查询保护和真实性防线介入；本文因此把“第一个失效安全合同”与传播路径、输出状态和现实后果分开编码。

1.2 既有组织范式、失败机制与精确缺口

本文不以缺少一份外部综述对照表为前提宣称既有研究整体失效，而是对当前证据包作一项可检查的组织判断：若以“后门、越狱、版权、深度伪造”等攻击或后果名称作为唯一主轴，触发词既可能来自数据投毒，也可能激活恶意适配器或直接构成条件载荷；若以“论文、新闻、标准、代码”分章，读者又必须自行恢复同一攻击链中的机制、控制和现实边界。这样的材料排列不能稳定回答“攻击者最早获得什么权限、哪个状态先改变、谁最早能够中断”三个部署问题。

第二个失配来自模态与评测单位：把图像证据逐帧复制到视频，会漏掉事件顺序、运动轨迹、连续身份、音画对应、首次可靠告警与平台转码后的信号保留。BadVideo 的时空目标、VideoSeal 的时序传播与流式路径以及 T2VSafetyBench 的视频级风险任务，分别改变了攻击目标、真实性信号和评价对象 [@P007] [@P033] [@P034]。据此，本文把精确缺口界定为：当前语料需要一个同时区分首破接口、证据层与视频评测单位，并把攻击证据连接到最早可执行控制及其残余风险的综合框架；这一缺口是本文的设计任务，不是对所有既有综述的经验性排名。

1.3 图像—视频对象、范围与排除边界

主体范围包括文本到图像、图像到图像、受控编辑、主体或风格个性化、文本到视频、图像到视频、视频编辑及其服务化系统。工作只有在明确处理生成流水线中的资产、攻击者、访问接口、可观察后果或镜像防御时才进入核心；检测、取证、水印和来源证明则须直接面向生成媒体、生成器归属、适应性规避或真实分发链。与生成系统没有接口关系的普通分类器对抗样本、仅改善质量而没有安全资产与威胁模型的工作，以及无法核验身份的摘要或转载不进入主体。

图像的常用分析单元是一幅媒体及其提示、种子、模型和安全器；视频还需记录帧、片段、镜头、轨迹、角色身份、时序状态、容器处理，以及在联合系统中的声音、说话人和音画同步。“深度伪造”也不是自动纳入标签：DeepfakeBench 可支持统一实现与检测评测问题，却不能单独证明未知生成器和低基率生产流量中的部署效果；对抗检测与音画联合检测只作为 I6 输出/检测接口的桥接证据，不被改写成生成模型内部攻击 [@P035] [@P036] [@P037] [@P038]。该边界既防止把通用视觉安全无限扩张为生成安全，也防止因只看模型内部而漏掉身份、来源和平台处置。

1.4 中央问题、四个 RQ 与主张上限

全文的中央问题是：在图像与视频生成系统的端到端生命周期中，攻击者首先破坏哪些安全合同，现有多源证据在何种权限、模态与评测协议下支持哪些镜像防御与部署决策？围绕这一问题，RQ1 询问资产、主体、攻击者能力、首破接口与后果证据如何一致编码；RQ2 询问七个接口上的攻击机制、权限、传播、成本、正常效用与失败条件呈现哪些跨研究模式。二者先建立可复核的对象和比较合同，再进入攻击证据综合。

RQ3 询问镜像控制能够在哪个接口最早中断传播，以及其信任根、正常效用、适应性绕过和部署成本；RQ4 询问论文、代码、系统卡、标准、法规、事件与局部实验分别能支持何种现实或工程判断，哪些位置必须停止转译。答案只对截至 2026 年 8 月 9 日的当前证据包成立：本文不声称分类唯一或完备，不估计现实发生率，不把异构百分比合成总体效应，不宣称统一最佳防御，也不把供应商声明、代码存在、局部运行或静态审计升级为生产效果和论文复现。

1.5 贡献、状态边界与阅读路线

本文的第一项贡献是把七个首破接口与攻击者能力、模态、目标和后果证据分层，使并发、歧义和未知可以显式保留；第二项是以“攻击合同—机制证据—最早中断控制—正常效用与成本—适应性绕过—残余传播”为综合单元，而非把攻击清单和防御清单并列；第三项是建立图像—视频证据合同，使片段、时序、运动、音画、资源和转码不再被帧级结果代替；第四项是区分论文、代码、系统卡、标准、法规、事件和工程材料的可转译上限；第五项是把部署建议写成带拒绝门的条件化组合，并把开放问题写成可证伪议程。

交付物的当前科学状态为 `compiled-draft`：综述设计非 PRISMA，27 项论文主协议均未运行，定量合并被正式拒绝，本地与仓库证据分别保持 `PARTIAL_RUN` 和 `STATIC_AUDIT_ONLY`，`end_to_end_runs=0`。第 2 章先给出证据治理与拒绝规则，第 3—4 章定义系统边界和首破分类，第 5—7 章综合接口攻防与视频不可约状态，第 8 章检验多源证据的现实和工程转译，第 9—10 章给出受限回答及其局限，第 11 章提出可证伪议程，第 12 章收束结论；论文卡、完整指标矩阵、事件卡和工程回执分别进入附录，避免证据卡替代正文论证。

01.E1 证据展开：引言：生成式视觉安全为何需要端到端攻防视角

01.E1.1 从“不良内容”转向安全合同　图像和视频生成系统的安全问题经常被简化为一个内容审核问题：用户输入提示，模型输出媒体，审核器判断内容是否违规。这个描述只覆盖了生成流水线中的一个局部接口。真实系统还包含训练数据与授权、预训

练权重和第三方组件、个性化与微调、条件编码和控制模块、采样与缓存、输出水印和来源凭证、平台上传与推荐、身份核验、投诉下架和现实业务授权。任何一层都可能先发生安全合同失效，并把风险传播到后续层。

例如，污染样本进入训练集时，首个失效是数据来源与完整性；恶意 LoRA 被加载时，首个失效是制品与供应链；对抗提示绕过安全器时，首个失效是条件和控制；训练数据从模型输出中被提取时，首个失效位于推理与隐私边界；水印被移除后再次上传时，首个失效则位于输出来源或平台分发。它们都可能最终出现“有害图像”，却要求完全不同的权限、证据和防御主体。若只按最终内容类型分类，数据所有者、模型开发者、API 服务商、编辑工具、分发平台和受害者之间的责任界面会被抹平。

本文因此把安全问题写成一条合同链：来源是否被授权并保持完整，制品是否来自可信构建，条件是否表达获准意图，训练更新是否保持安全属性，推理是否隔离租户与资源，输出是否具有可验证而不过度承诺的真实性信号，平台是否把信号转化为及时、可申诉的处置。为维持一个可比较主轴，每条记录必须给出一个 `primary_first_break`；若多个合同同时失效、先后不可辨或材料不足，则另记 `co_primary`、`ambiguous` 或 `unknown`，不得制造虚假的唯一时间顺序。后续传播和现实后果另行编码。这一选择使攻击与防御可以镜像对齐，也避免把“媒体看起来可疑”“检测器给出高分”“平台已经下架”和“现实伤害得到证实”写成同一个结论。

01.E1.2 图像与视频不是样本数量上的简单差别　图像生成的最小分析单元通常是一幅图及其提示、种子、模型和安全器。视频生成至少还包含帧、片段、镜头、运动轨迹、角色身份、时序状态和容器处理；联合音画或带音轨系统还包含声音、说话人和音画同步。危险语义可能不存在于任何单帧，而只在动作顺序、镜头组合或音画对应中成立；水印可能在多数帧可检出，却在关键片段持续缺失；身份可能逐帧相似，但在长序列中漂移；平台转码、抽帧、变速和拼接会改变检测分母与信号保留。

因此，逐帧攻击成功率不能自动成为视频级攻击成功率，逐帧水印命中也不能自动成为片段级来源证明。视频评测必须回答：分母是源帧、解码帧、片段还是完整视频；允许多少连续漏检；何时首次告警；运动、口型、声音和身份是否联合成立；不同转码与容器处理是否改变结果；实时流是否需要状态恢复与延迟预算。本文把这些要求作为横切合同，而不是在每个图像方法后附一句“也可扩展到视频”。BadVideo 把后门目标扩展到时空组合，VideoSeal 引入时序传播与流式处理，T2VSafetyBench 则表明视频安全本身需要多维任务划分；三者分别代表攻击、来源信号和评价对象的不同变化 [@P007] [@P033] [@P034]。

01.E1.3 研究对象与排除边界　本文纳入文本到图像、图像到图像、主体/风格个性化、受控编辑、文本到视频、图像到视频、视频编辑及其服务化系统。只要工作明确处理生成系统的资产、攻击者、接口、可观察后果或镜像防御，即可作为核心或桥接证据。检测、取证、水印和来源证明只有在明确面向生成媒体、生成器归属、适应性规避或真实分发链时才进入主体；普通图像分类器对抗样本、与生成流水线无接口关系的通用鲁棒性工作以及只有宏观观点而无直接技术或制度证据的材料被排除。

“深度伪造”也不是自动纳入标签。经典深度伪造检测、音画异常和法律分析可以为输出真实性与现实传播提供桥接证据，但它们不必然研究生成模型内部。DeepfakeBench 的统一实现对检测评测很重要，却不证明未知生成器和低基率生产流量中的部署有效性 [@P035]；对抗深度伪造研究表明检测器本身也可成为适应性攻击目标 [@P036]；音画联合检测工作则揭示视频比静态图像多出的身份一致性证据 [@P037] [@P038]。这些工作在本文中被定位到 I6 输出/检测接口，而不是被重写成模型训练攻击。

01.E1.4 五层后果：从策略违规到可核验现实伤害　本文把后果证据分为五个阶段/维度。L1 是内容策略违规，例如生成了安全规范禁止的主题；L2 是生成控制被劫持，即攻击者让系统偏离预期条件或安全策略；L3 是危险、侵权或未授权能力被实际调用；L4 是媒体成功生成并进入传播链；L5 是有可核验的现实伤害。它们不是通用严重度排序，也不要求每项风险依次经过 L1–L5：隐私提取和资源拒绝服务可直接落在其他安全属性，事件可使用 `NA`、多标签或未知项。层级只表示某条证据链实际观察到的位置，不表示每个事件必然沿同一路径升级。

这一划分对事件分析尤其重要。官方澄清某段媒体为伪造，最多证明有媒体和官方响应，未必公开生成器、行为者或损失；检测器判定为 AI 生成，也不是对身份、意图或法律责任的最终认定。相反，香港政府关于预录深伪视频会议诈骗的书面答复记录了冒充、组织授权失效与约二亿港元转账损失，可达到 L5，但仍未披露具体生成模型 [@O048] [@O049]。Deep Fakes 的早期法律分析强调隐私、民主、安全和“说谎者红利”等多类危害，也说明危害并不只来自伪造被相信，还可能来自真实证据被轻易否认 [@P041]。因此，本文不把模型能力、媒体真实性、平台传播和现实伤害压成一个二元标签。

01.E1.5 八个研究问题　本文依次回答八个问题。第一，图像与视频生成系统的资产、信任边界、攻击者权限和后果如何统一表达。第二，攻击链中哪个接口首先失效，边界案例如何判定。第三，各攻击家族的知识、访问、预算、持久性、迁移和失败条件有何差别。第四，镜像防御在何处执行，依赖哪些信任根，并产生怎样的安全—效用—成本权衡。第五，数据集、指标、基线、视频分母和攻击预算是否允许跨论文比较。第六，论文、代码、系统卡、标准和真实事件如何组成不混层的证据链。第七，本地条件允许验证什么，静态审计和未运行状态分别意味着什么。第八，实时视频、组合供应链、个性化身份、来源证明和监管执行可形成哪些可证伪问题。

八个问题按照“定义对象—建立主轴—展开攻击—镜像防御—审计证据—解释现实—验证边界—提出议程”的顺序闭合。本文不追求一个无条件最安全模型，而是给出在明确资产、权限、模态、资源和处置责任下的组合控制。

01.E1.6 贡献与阅读路线 第一项贡献是首破接口 taxonomy。它用七个连续接口覆盖数据、供应链、条件、训练、推理、输出和分发，并把攻击目标、媒体模态、白盒程度、安全属性和现实后果降为次级标签。第二项贡献是攻防镜像：防御必须说明在攻击链哪个位置执行，正常效用、适应性攻击和失败处置必须与攻击效果同报。第三项贡献是图像—视频证据合同：视频需要片段、时序、运动、音画、资源和平台转码指标，不能用帧复制替代。

第四项贡献是多源证据分层。学术论文回答机制和实验，官方代码回答工程入口和版本，系统卡回答发布方风险主张，标准回答互操作和信任合同，法规回答责任义务，事件材料回答现实链条。本地实验与静态审计作为独立层，不冒充论文复现。第五项贡献是条件化部署与未来议程：每项建议都连接前文失败证据，并给出最低验证设计与否证条件。

全文分为五部分。第一部分给出技术脉络、方法、威胁模型与分类设计；第二部分逐接口分析攻击并单设视频专项；第三部分逐接口展开防御；第四部分审计代表论文、指标、事件和局部实验；第五部分把证据转成部署决策、未来议程、局限和结论。

\newpage

2. 综述方法与证据治理

2.1 文章类型、时间窗与状态语义

本研究是带可审计范围检索的 taxonomy survey / evidence review，检索窗口为 2014 年 1 月 1 日至 2026 年 8 月 9 日；更早材料仅在当前生成媒体方法明确依赖时作为桥接证据。研究保留查询、版本、全文、论文卡、事件卡和证据等级，但没有执行数据库原生完整导出、双人独立全文筛选、逐条全文排除或正式偏倚工具，因而明确属于非 PRISMA 设计，不能声称穷尽全部文献或完成严格系统综述。

状态词在本文中描述完成到哪一步，而不是给材料贴质量高低标签：`NOT_ATTEMPTED` 表示主协议未运行，`STATIC_AUDIT_ONLY` 表示只读代码、配置与制品合同，`PARTIAL_RUN` 表示仅运行无害局部子问题，`compiled-draft` 只表示稿件和构建链可形成当前草稿。相应地，“代码可访问”“配置可定位”“局部程序返回结果”和“论文主协议完成”是四个不同命题；任何较低状态都不得因语言润色而升级。

2.2 数据源、查询与检索通道

检索沿四条证据流并行展开。学术流覆盖图像与视频生成中的投毒、后门、越狱、隐私、提取、可用性、检测、水印、来源和深度伪造；代码与产品流覆盖官方仓库、模型卡、系统卡、权重与安全发布；标准与政策流覆盖来源规范、标识制度、透明度义务、平台责任与受害者救济；事件流覆盖诈骗、身份冒用、政治传播、非自愿私密影像、未成年人风险、版权争议、产品变更和平台响应。四条流服务于不同问题，不能把论文、公告和报道直接相加为同一“研究数”。

学术发现层保存 16 组 OpenAlex 查询：原始返回 2,921 条，以 DOI 或 OpenAlex ID 去重后为 2,289 条，题名相关门得到 356 条优先候选；另一条经出版方、作者页、官方机构和官方仓库核验的宽候选表含 161 条来源。上述数字分别表示查询召回、身份去重、题名优先级和核验入口，均不等于最终纳入量；长篇扩写阶段的来源表只绑定正文引用、定位、等级和核验日期，与中央 201 条来源记录存在版本和证据角色重叠，因此不再相加。

2.3 纳入、排除、版本与去重

核心纳入要求是材料明确规定生成系统的攻击者、资产、入口、目标、可观察后果或防御，或直接提供相关数据、指标、代码、标准和事件证据；桥接研究还必须说明其如何迁移到生成媒体接口。排除项包括与生成流水线无联系的通用分类器鲁棒性、没有安全资产与威胁模型的一般质量改进、只报检测分数却不处理生成器或来源合同的常规取证、无法核验身份的搜索摘要与转载，以及缺少配置、数据或判定方式却给出强效果主张的材料。

去重以研究身份而非文件数量为单位：正式发表版通常优先于预印本，同时保留版本漂移；论文、项目页和仓库是同一研究的不同证据角色，不重复计成多项研究。标准按版本号独立记录，法规正文、后续指南和新闻公告即使主题相近也不合并为一个对象；事件的官方答复、平台公告和媒体交叉则组成同一事件的来源关系，而不是新增事件。无法确定身份或版本时保留冲突与未知字段，不以相似题名静默裁决。

2.4 筛选、数据提取与编码

论文卡提取题名、作者、年份、发表身份、模态、首破接口、次级标签、威胁模型、攻击或防御机制、作者报告结果、模型与数据、指标、代码、全文定位、失败条件、复现状态和证据等级；事件卡分开事件日期与文件发布日期，并提取辖区、主体、媒体模态、已确认或指称状态、攻击链、首破接口、后果、官方响应、争议和未知项。空值被区分为未报告、不可访问、不适用和尚未核验，避免把缺失误写成不存在。

首破编码从攻击者已有权限、最早改变的系统状态和首先违反的安全属性出发，再记录攻击输入、操作位置、高层目标、直接输出、传播接口、后果证据、正常效用和失败条件。只有机制、时间与权限证据足以排序时才填写 `primary_first_break`；不可分的同时失效写 `co_primary`，竞争解释无法裁定写 `ambiguous`，关键信息不足写 `unknown`。视频记录另增加帧数、片长、镜头、轨迹、音画状态、流式延迟与编码链。

2.5 证据等级、主张语言与归因

证据等级控制的是来源角色和可用语言。A 级包括出版方全文、正式规范、法条、原始数据与官方司法或执法记录；B 级包括作者完整稿、官方代码、模型或系统卡以及存在发布方利益限制的技术材料；C 级用于缺少一手卷宗但有多家高信誉媒体交叉的事件材料。等级不自动等于研究方法质量，后者仍需单独审计威胁模型、预算、基线、版本、随机性、适应性攻击、正常效用、失败案例以及代码和数据可得性。

正文让行动者与证据强度保持一致：论文“在指定协议下报告”，系统卡“由供应商声明”，法规“规定”，事件文件“记录”，本地实验“在本项目配置下观察到”，跨来源关系则明确写成“本文综合、推断或建议”。具体数值没有全文定位不进入结果句，百分比没有共同研究单位、分母与方差不平均；供应商自评不写成第三方现场验证，官方代码的入口和配置也不写成主协议已运行。

2.6 可比性门、统计拒绝与缺失处理

进入比较前先锁定估计对象：请求、服务响应、有效响应、可判定响应、图像、帧、片段、整段视频、身份和事件不能共享一个分母；ASR、FID/KID、FVD、CLIP 相似度、ROC-AUC、水印比特准确率、资源成本和现实伤害也不是可折算的同一终点。FID/KID 与 FVD 本质上是集合级质量指标，ROC-AUC 亦不直接给出低基率部署中的精确率 [@R-M001] [@R-M002] [@R-M003] [@R-M004] [@R-M005]。若 `valid_responses=0`，生成质量与 ASR 记为 `NA`，不能把零有效响应写成 0% 成功，也不能把拒绝样本静默移出分母。

本文的可比性门要求模型与服务版本、数据、攻击权限和预算、生成与裁判协议、有效分母、正常效用、适应性设置和不确定性同时可对齐；现有跨论文材料缺少共同研究单位、有效分母、独立性与方差，故定量综合正式状态为 `NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE`。这是一项方法结果而非遗漏：正文只允许单论文原协议内比较和受限的跨论文机制综合，不制作森林图、I^2、统一 ASR 排名或综合安全分，缺失关键字段的工作只作为带限制案例。

2.7 复现枚举、审计材料与更新规则

复现采用六状态枚举：`NOT_ATTEMPTED` 为未运行，`STATIC_AUDIT_ONLY` 为只读代码与配置，`ENVIRONMENT_PROBE` 为验证环境或入口，`PARTIAL_RUN` 为运行局部无害子问题，`CONTROLLED_END_TO_END` 为在授权数据和隔离模型上完成主协议，`EXTERNAL_SERVICE_VALIDATION` 还要求服务授权、精确版本与请求回执；另以 `paper_main_protocol_run` 标记是否执行论文主配置。当前 41 张论文卡均为 `NOT_ATTEMPTED`，七个仓库为 `STATIC_AUDIT_ONLY`，本地合成媒体实验为 `PARTIAL_RUN`，`paper_main_protocol_run=false` 且 `end_to_end_runs=0`。

审计路径保留查询原始返回、优先级结果、来源注册表、下载清单、全文与页级索引、论文卡、事件卡、攻防矩阵、仓库提交、实验配置与日志、图表脚本、构建回执和 SHA-256 散列；这些工件只能证明其各自合同，文件存在不等于已运行。时效性事实冻结于 2026 年 8 月 9 日，产品系统卡、平台政策、标准、法规适用和诉讼状态在正式投稿前须重新检索；更新时追加版本与访问日期并重跑引用、数字和状态验证，不用新页面无痕覆盖旧证据。

02.E1 证据展开：检索、筛选、编码与证据地图

02.E1.1 论文类型与声称上限 本研究是带可审计范围检索的 taxonomy survey。它使用明确查询、版本去重、核心全文、论文卡、事件卡和证据等级，但尚未满足严格系统综述要求的数据库原生完整导出、双人全文筛选、逐条全文排除和正式偏倚工具。因此，检索结果用于说明在已执行来源和规则下的覆盖，不能声称穷尽全部研究。分析单元是一项“论文—方法—模型/数据—威胁配置”；标准、系统卡、事件和本地实验属于独立证据层，不与论文实验合并计数。

主张上限按证据类型分别规定。出版方全文和作者完整稿可支持其明确报告的机制、设置、结果和局限；官方代码可支持当前提交的接口、配置、依赖和许可证；系统卡可支持发布方自报的风险与缓解；正式标准和法规可支持文本中的规范合同与义务；官

方事件文件可支持其中明确记录的行为和结果；媒体材料只能支持报道事实及其未知项。跨来源的新判断被标为本文综合，不能伪装成任一来源的原话。

02.E1.2 四条证据流 检索分为四条并行证据流。学术流覆盖图像/视频生成、投毒、后门、越狱、隐私、提取、可用性、检测、水印、来源和深度伪造；代码与产品流覆盖官方仓库、模型卡、系统卡、权重和安全发布；标准与政策流覆盖 C2PA、内容凭证、标识办法、AI Act、平台责任和受害者救济；事件流覆盖诈骗、身份冒用、选举传播、非自愿私密影像、未成年人风险、版权争议、产品安全发布和平台响应。

四条流不能简单相加。一个论文可能同时有正式版、预印本、项目页和仓库；一个事件可能有官方答复、平台公告与多篇报道。中央表保留访问入口，但通过 DOI、规范题名、URL 和人工裁决给出规范来源组。版本关系和事件来源关系被显式保存，以便读者既可按研究身份计数，也能回到具体访问入口。

02.E1.3 查询、时间窗与可复算数量 时间窗为 2014 年 1 月 1 日至 2026 年 8 月 9 日；更早的水印、取证和隐私工作只有在当前生成媒体方法明确依赖时作为桥接证据。OpenAlex 学术召回使用 16 组可重复查询，原始命中 2,921 条，按 DOI/OpenAlex ID 去重后为 2,289 条，规范题名相关门保留 356 条优先候选。另一条由出版方、作者页、官方机构和官方仓库核验的宽候选表含 161 条来源。这些是不同收窄层：2,921 是查询返回，2,289 是身份去重，356 是题名优先级，161 是多源核验入口，均不等于最终系统综述纳入数；可复算计数分别位于 `data/openalex/manifest.json`、`data/openalex/prioritized_candidates.csv` 和 `research/agent_search_news/candidate_sources.csv`。

中央来源注册表含 201 条记录和 174 个去重组，其中 40 条为核心锚点，57 条为事件证据入口，104 条保持宽候选。核心锚点中有 30 篇论文保存本地全文并建立页级文本索引；官方目标共 11 个，9 个保存本地快照，Sora 2024 系统卡因 HTTP 403、香港 LCQ9 页面因远端断连保留网页核验和失败记录。下载失败没有被改写成来源不存在，也没有用二手材料静默替换。

长篇扩写阶段又按攻击、防御和论文/事件三条线建立独立的 `sources.csv`，用于绑定新增正文引用键、精确定位、证据等级和核验日期。它们与中央注册表存在论文版本、官方页面和证据角色重叠，因此只作为“长篇引用入口表”使用，不与 201 条中央记录相加为所谓总纳入量。最终正文实际使用多少引文，以 `paper/references.bib` 和引用闭合验证为准；研究身份去重仍以中央规范组和各补强表的稳定 URL/版本信息判断。

02.E1.4 纳入、排除与版本规则 核心纳入要求是工作明确规定生成系统的攻击者、资产、入口、目标、后果或防御，或提供直接相关的数据、指标、代码、标准与事件证据。桥接研究必须说明它如何迁移到生成媒体接口。排除项包括：只研究普通分类器且与生成流水线无联系的对抗样本；没有安全资产与威胁模型的一般质量改进；只报检测分数而不讨论生成器、适应性攻击或来源合同的常规取证；无法核验身份的搜索摘要和转载；没有配置、数据或判定方式却给出强效果宣称的工作。

正式发表版优先于预印本，但保留版本漂移。论文、仓库和项目页是同一研究的不同证据角色，不重复形成三个“研究”。标准按版本号独立记录，法规正文与后续指南、解释或新闻公告不能因主题相关而去重为同一对象。中央 QA 曾发现 EU AI Act 正文与 2026 年 Article 50 指南发布公告被错误合并；最终拆分为两个规范组并分别绑定匹配快照。这一修正说明主题相同不等于文献身份相同。

02.E1.5 论文卡、事件卡与首破接口编码 论文卡包含题名、作者、年份、venue、模态、首破接口、次级标签、威胁模型、攻击/防御机制、作者报告证据、模型与数据、指标、代码、全文定位、失败条件、复现状态和证据等级。空白值使用未报告、不可访问、不适用或尚未核验，不用空单元格暗示“没有”。当前 41 张核心论文卡覆盖全部七接口，且复现状态均为 NOT_ATTEMPTED；这表示本文没有运行这些论文主实验，不表示方法无代码或不可运行。

事件卡把事件发生日期和文件发布日期分开，记录司法辖区、组织、系统或模型、媒体模态、受影响群体、已确认/指称状态、攻击链、首破接口、可观察结果、现实伤害、官方回应、法律标准、争议、证据等级和未知项。32 张事件卡全部具有来源关系，但它们不是随机样本，不能用于推断发生率、年度趋势或司法辖区风险差。

首破接口由“攻击链中第一个安全合同失效的位置”判定。若恶意开发者直接控制训练过程，首破点是训练接口；若同一权重通过第三方托管伪装成良性制品进入系统，受害部署的首破点是供应链。若合法模型被调用生成冒充视频，而服务没有违规运行，首破点可能在身份同意、发布或付款授权，而不是模型内部。每条记录还保留传播接口和五层后果，避免单一标签丢失攻击链。

02.E1.6 证据等级、质量与主张语言 证据等级 A 包括出版方全文、正式规范、法条、原始数据和官方司法/执法记录；B 包括作者完整稿、官方代码、模型/系统卡和具有发布方利益限制的技术材料；C 用于缺一手卷宗但有多家高信誉媒体交叉的材料。等级描述来源角色，不自动等同于论文方法质量。论文质量另外审计威胁模型、攻击预算、基线、数据和模型版本、随机性、适应性攻击、正常效用、失败案例、代码和数据可得性。

正文使用四类语言。来源明确报告的结果写“作者在某协议下报告”；跨研究组织写“本文综合表明/提示”；本地实验写“在本项目玩具配置下观察到”；建议和机制解释写“本文推断/建议”，并给出替代解释或否证条件。没有全文定位的具体数字不进入正文；没有独立研究和方差的百分比不被平均。

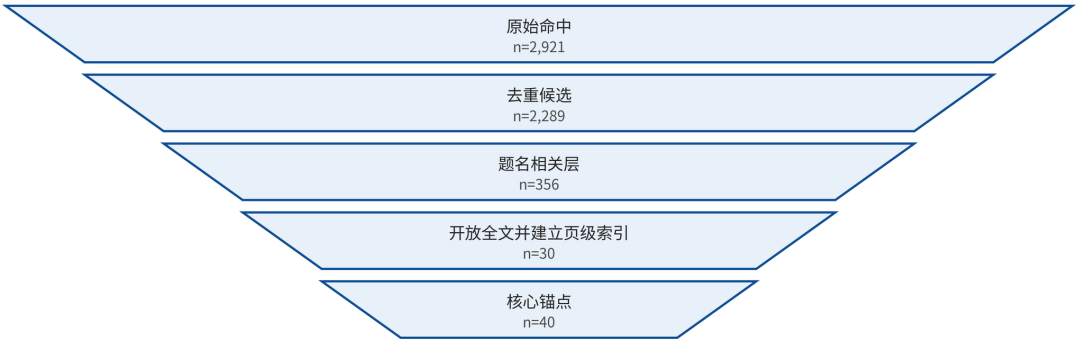
02.E1.7 定量可比性与正式统计拒绝 攻击成功率、FID、FVD、CLIP 相似度、AUC、EER、水印比特准确率、人评偏好、资源成本和现实伤害是不同终点。即使都表示百分比，分母也可能是提示、生成样本、帧、片段、视频、身份、用户、请求或事件。模型版本、安全器、预算、判定器、视频长度、分辨率和失败处理进一步造成异质性。多数工作没有为同一可比终点提供独立研究簇、有效分母和方差，因此正式状态为 `NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE`。

统计拒绝不是缺少分析，而是分析结果：现有证据只允许单论文原协议结果和跨论文定性机制综合。本文不会把各论文最佳 ASR 排成攻击强度榜，也不会把检测 AUC 与水印准确率转成综合安全分。若未来形成共同生成器、数据、攻击预算、样本单位、正常效用和不确定性合同，可在预注册子集内重新评估统计合并。

02.E1.8 可复核材料与时效边界 完整查询、OpenAlex 原始返回、优先级结果、下载清单、PDF、提取文本、页级关键词索引、论文卡、事件卡、攻防矩阵、仓库快照、实验配置、日志、图表脚本、LaTeX 和散列均保存在 Ditse 目录。中央 CSV 与 JSON 经过字段级同步检查，来源本地文件按 SHA-256 复核。

时效性事实截至 2026 年 8 月 9 日。产品系统卡、平台政策、标准版本、法规适用和诉讼状态可能变化，正式投稿前必须执行更新检索。本文把访问日期和对象版本作为证据合同的一部分；“当前页面说明”不能被写成永久产品能力。

证据收窄：候选数不等于纳入数



候选池只用于召回与优先级；正文机制主张回到全文或一手官方材料。本图不是 PRISMA 流程。

表：检索与证据层级

证据层	对象	本地数量	核验单位	解释上限
发现层	OpenAlex 原始命中	2921	自动查询日志	只用于召回，不能视为纳入
候选层	OpenAlex 去重候选	2289	DOI、OpenAlex ID	题名相关仍需全文筛查
中央证据层	多源规范记录	201	174 个去重组	来源版本与证据等级保留
论文解析层	结构化论文卡	41	全文定位与局限	复现状态全部独立记录
事件层	新闻、政策事件卡	32	一手公告优先	样本数不是发生率
工程层	公开仓库静态审计	7	入口、依赖、权重合同	end to end runs=0

注：数据源为 `paper/tables/evidence_counts.csv`；正文显示 6/6 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

3. 技术系统边界与威胁模型

3.1 从生成架构到安全状态

从 GAN 式一次映射到扩散模型的迭代去噪，安全对象由最终像素扩展为条件嵌入、噪声调度、逐步去噪轨迹、引导强度和解码过程。BadDiffusion 与 TrojDiff 分别说明触发行为可以进入训练或反向扩散过程，而清洁效用、触发特异性与攻击目标仍须分开评价 [@P001] [@P002]。这一变化只支持“中间状态进入威胁模型”，不支持据架构名称推断风险规模，也不把按设计生成敏感内容自动写成模型被攻破。

潜空间与组件化把文本编码器、去噪主干、VAE、ControlNet 和 LoRA 变成可独立分发或替换的制品。Rickrolling the Artist 表明仅检查主去噪网络不足以发现被替换的文本编码器，Stable Signature 则说明解码器也可成为来源信号的根植位置 [@P003] [@P028]；Anti-DreamBooth 和 MasqLoRA 进一步把权限分别落到个体训练图像与独立适配器 [@P020] [@P006]。同一模块化机制既可能提供控制点，也可能扩大供应链和个性化边界，因而组件身份验证不能替代组合后的行为差分。

服务化生成还把请求队列、近似缓存、中间潜变量、超分或插帧、安全复审、转码、存储与 CDN 纳入系统状态。近似缓存研究给出了延迟侧信道、提示恢复与缓存污染的条件性证据，但不能外推为所有服务均脆弱 [@P039]；分辨率、帧数、采样步、候选数和重试会改变 GPU 时间与账单，却缺少足以建立广泛机制结论的生成专用 DoS 一手实证。本文因此把缓存视为已获机制支点的 I5 风险，把资源耗尽保持为经检索但尚未闭合的证据缺口。

3.2 系统边界、资产与责任主体

系统边界从训练数据进入开始，经过清洗与标注、基座训练与安全对齐、权重和代码分发、适配器组合、多模态条件输入、采样与输出复核、水印或来源凭证、导出与转码，延伸到账户、推荐、举报、变现与司法处置。由此形成七类受保护资产：数据来源与授权；权重、代码和依赖制品；文本、图像、视频、音频、掩码、深度与轨迹条件；训练目标、更新、擦除和个性化过程；随机性、缓存、租户、队列与资源；检测、水印、签名与归因；身份、同意、发布、申诉与救济。边界既不截断在模型 API，也不泛化为不可审计的“整个互联网”。

责任主体至少包括数据主体与权利人、收集和标注团队、基座模型及安全对齐团队、模型仓库与插件作者、个性化服务、云推理运营者、编辑工具、分发平台、凭证签发者和验证者、审核团队、受害者、媒体以及监管与司法主体。控制必须同时说明执行者、观察信号和失效后的处置权；例如 C2PA 可机器检查声明、签名、内容绑定与验证状态，却仍以签名者身份和声明为信任根，密码学有效只支持“谁签了什么且是否被篡改”，不自动证明现实陈述为真 [@O001]。同理，生成概率分数不能替代身份、同意、语境与传播证据。

3.3 攻击者能力、访问和预算

本文以五元组 (A=(K,X,B,T,C)) 记录攻击者能力：(K) 为从黑盒产品行为到灰盒中间状态、再到权重和梯度的知识；(X) 为发布样本或制品、提交条件、启动个性化、调用检测器以及使用平台分发与变现的访问；(B) 同时记录查询数、训练算力、存储带宽与货币成本；(T) 区分一次输入、多轮查询、等待训练周期、供应链潜伏与持续再上传；(C) 区分单账户、多账户、多组件发布者和跨平台协同。五个字段共同决定攻击能否与另一研究比较，不能被“白盒/黑盒”一个标签替代。

能力合同还能防止同名方法被误作同一威胁：MMA-Diffusion 的白盒联合条件操作与其黑盒迁移评测需要分列，训练数据提取的查询预算和候选语料知识改变可行性，而数据投毒可以不接触权重、经下一轮抓取和训练延迟显现 [@P009] [@P024] [@P005]。因此每个效果句须同时绑定模型与数据、攻击者已有权限、预算、持续时间、协同方式和失败处理；缺少这些字段时，本文保留机制案例，但拒绝攻击强度排名。

3.4 后果证据维度与因果链

后果采用五个可独立填写的证据维度：L1 为内容策略违规，L2 为生成控制被劫持，L3 为危险、侵权或未授权能力被调用，L4 为媒体生成并进入传播链，L5 为可核验的个人、机构或公共现实伤害。它们不是严重度阶梯，也不要求顺序升级；参数、潜变量、缓存或密钥异常另记为系统状态，隐私提取和资源拒绝服务可对不适用维度写 `NA`。每一维分别记录有证据、无证据、不适用或未知，不能用“最高层级”压缩整条因果链。

该分离使模型内效果、传播与现实伤害不会互相冒充：训练后门实验可以支持其协议观察到的控制劫持，却不能自动推出平台传播；官方澄清可以确认媒体和响应，却未必披露生成器、行为者或损失。香港政府对预录深伪视频会议诈骗的书面答复记录了冒充、组织授权失效与约二亿港元转账损失，可支持该事件的 L5，但具体模型仍未知 [@O048] [@O049]；早期法律分析提出的隐私、民主与“说谎者红利”是危害机制框架，不是发生率估计 [@P041]。同样，TAKE IT DOWN Act 规定通知和移除义务，但法条本身不证明任一事件已发生或治理已有效 [@O014]。

3.5 视频新增的时间、运动、音画与流式状态

视频不是图像样本数量的扩张，而是引入了至少五组不可约状态：时间上的事件顺序与持续身份，空间—时间耦合的运动和轨迹，声音、说话人、口型与语义的联合身份，跨帧记忆与缓存，以及直播或交互生成中的窗口、首次告警、吞吐和状态恢复。平台抽帧、变速、拼接、转码和容器处理还会改变可观察分母与真实性信号。故视频威胁合同必须绑定模型版本、片长、帧率、镜头、音轨、预算和聚合规则，不能用“一帧通过/失败”概括整段媒体。

现有支点展示了不同新增合同：T2VSafetyBench 要求面向实际帧序列划分视频安全任务，BadVideo 把后门目标扩展到时空组合，Two Frames Matter 显示首尾条件单独通过时中间补全轨迹仍可能形成目标事件，VideoSeal 则把水印传播和流式处理纳入实现 [@P034] [@P007] [@LN05] [@P033]。这些证据支持的是“评测单位必须扩展”，并不证明所有图像攻击已在视频系统成立；没有事件级、轨迹级、音画级或流式协议时，主张最多限定在实际抽取并测量的帧或片段。

03.E1 证据展开：技术与安全脉络：从 GAN 到视频基础模型

03.E1.1 从单次映射到迭代去噪：为什么扩散模型改写了攻击面 GAN 时代的生成链可以粗略理解为从隐变量到像素的一次前向映射：数据分布、生成器权重、判别器与输出筛选是主要状态。扩散模型把该链条展开为数十个乃至更多采样步，每步消费条件嵌入、噪声调度、去噪网络输出和引导强度。这种变化不只是画质提升：它增加了可以被操作、缓存、重用和审核的中间状态。后门可被编入反向扩散过程，检测或水印信号可被植入初始噪声或解码器，服务可用性则受采样步数、分辨率、批大小和并发策略共同决定。BadDiffusion 与 TrojDiff 分别从训练后门和特洛伊扩散过程说明，扩散模型的安全对象不能只写成“最终图像”，而应包括整个反向轨迹、清洁效用和触发特异性 [@P001] [@P002]。

安全脉络的第一个结构性变化是，“生成结果有害”与“生成系统被攻破”开始明显分离。一个按产品设计生成灵敏图像的模型，若没有绕过任何技术控制，其首破点可能在下游同意和平台治理，而不是采样器。反之，一张看似无害的图像，若来自被置换的文本编码器、恶意 LoRA 或被污染数据，已经构成完整性失效。因此本文后续不使用“有害内容”作为唯一分类轴，而追踪安全属性首次失效的接口。

03.E1.2 潜空间、DiT、流匹配与自回归生成：新增状态而不是简单替代 潜空间扩散把高分辨率像素压缩到 VAE 潜表示中，将文本编码器、去噪主干和 VAE 解码器变成可独立分发的组件。这一工程拆分带来了 I2 供应链风险：用户校验了主模型哈希，仍可能装载不同的文本编码器、VAE、ControlNet 或 LoRA。Rickrolling the Artist 将攻击放在文本编码器，说明“主去噪网络未改”不能推出整体行为未改 [@P003]。Stable Signature 则从防守方向说明，解码器本身也能成为来源信号的根植位置 [@P028]。两者放在同一技术脉络中才能看出，组件化同时提供安全控制点和受攻击面。

DiT 与流匹配把生成主干进一步推向大型 Transformer 与连续速度场。对安全而言，关键不是名称更换，而是状态尺度和调度方式改变：更长的 token 序列、联合图文/音画注意力、模型并行、中间缓存与端到端编译会影响租户隔离、侧信道和资源公平。自回归视觉生成则把帧、块或多模态 token 写入显式上下文，引入缓存泄漏、长序列成本放大和状态污染问题。本综述因此不以某一生成架构作为攻击分类：相同架构可在数据、制品、条件、训练、服务、输出或下游任一接口首破。

03.E1.3 个性化、可组合适配器与开放权重：权限边界的下沉 DreamBooth、文本反演、LoRA 和主体驱动生成把原本由模型开发者掌握的训练权限下放给平台用户、插件作者与二次分发者。这使安全合同从“这个基座模型是否通过审计”变为“谁能为谁做个性化、使用哪些数据、输出了哪个参数制品、制品能否转让、同意撤回后哪些版本应当失效”。Anti-DreamBooth 展示了数据主体可以通过训练前图像保护来提高未授权个性化成本，但其跨模型、清洁图像泄漏与预处理边界也说明这不是永久撤回机制 [@P020]。

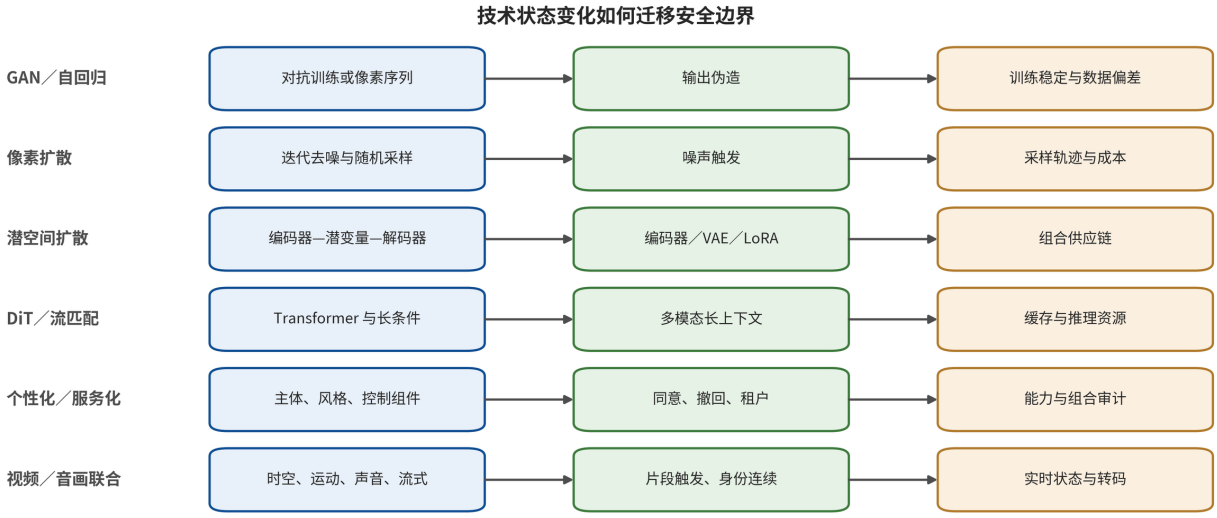
LoRA 进一步把微调参数变成可独立下载的小型制品。MasqLoRA 的威胁模型表明，恶意行为可存在于独立适配器，基座模型自身的签名与哈希仍然完全正常 [@P006]。对视频生成，这一问题被空间 LoRA、运动模块、相机轨迹控制、音频生成模块和推理加速插件成倍放大。当前已有图像 LoRA 后门证据，但截至 2026-08-09，尚不足以声称“恶意运动模块在主流视频生成链上已经被系统实证”。合理的表述是：可组合模块构成高优先级供应链缺口，防守方需建立组合后的行为差分，但不能把图像结论写成视频攻击事实。

03.E1.4 服务化与近似缓存：性能优化如何变成安全状态 商业图像与视频生成往往是一条分布式服务链：请求进入队列，调用条件解析、多阶段采样、超分或插帧、安全审核、转码、存储与 CDN。为减少重复计算，系统可对提示嵌入、中间潜变量或最终输出做近似缓存。Attacks on Approximate Caches 将这种性能优化识别为跨租户延迟侧信道、提示恢复与缓存污染的条件 [@P039]。其证据不能外推为所有生成服务均脆弱，但它足以否定“缓存只是性能实现，不属于威胁模型”这一隐含假设。

服务化还把可用性与成本安全提升为独立资产。生成请求并非等成本：分辨率、帧数、时长、采样步、候选数、重试、安全复审和导出规格都可改变 GPU 时间与账单。然而，本次定向检索没有找到足以建立广泛机制结论的图像/视频生成专用 DoS 一手实证。因此后文将资源耗尽作为 I5 中经过检索的开放缺口，而不拿 LLM 或通用云 DDoS 文献代填。

03.E1.5 视频基础模型：时间、运动、音画与实时性的不可约差异　视频生成不是将同一个图像生成器在每帧独立运行。现代视频模型通过时间注意力、时空卷积、时间 Transformer、帧间流或联合时空 token 让物体、身份和镜头在时间上保持一致。这些机制引入六类图像中不存在或不完整存在的安全状态：（1）帧间持续身份；（2）动作与物理因果顺序；（3）相机轨迹和分镜；（4）跨帧延迟或累积载荷；（5）口型、说话人、语义和环境声的联合一致；（6）直播和交互生成中的告警时延与撤回窗口。

T2VSafetyBench 将时序风险从静态有害类别中分离，并要求安全判定面向实际视频帧序列 [@P034]。BadVideo 进一步说明，训练后门的目标可以通过时空组合和动态元素表达，因此一组单帧看似无害不能推出整个片段安全 [@P007]。Two Frames Matter 把这个逻辑推到边界帧与中间补全：开始与结束条件可能单独通过过滤，但模型生成的中间轨迹才是风险对象 [@LN05]。这些结果构成本文的基本视频原则：如果没有事件级、轨迹级、音画级和流式评测，研究最多只能声称“在抽取的帧上有效”。



此图表达系统状态与攻击面，不以阶段顺序推断风险规模或技术优劣。

表：技术家族、状态变化与新增攻击面

技术家族	状态变化	新增安全面	关键接口	证
GAN 与早期自回归	显式生成器、判别器或像素序列	训练不稳、模式覆盖、伪造检测	训练数据、权重、输出	不
像素空间扩散	迭代去噪与随机采样	噪声触发、采样轨迹、成本放大	训练、条件、采样	约
潜空间扩散	编码器—潜空间—解码器模块化	文本编码器、VAE、适配器成为供应链接口	权重、代码、条件、输出	约
DiT 与流匹配	Transformer 化与更长条件上下文	长提示、多模态控制、算力与缓存状态	条件、训练、推理	架
个性化与可组合适配	LoRA、ControlNet、主体、风格微调	同意、恶意制品、组合触发、撤回困难	数据、供应链、训练、分发	卓
视频与音画联合生成	帧—片段—镜头—音画联合状态	时序触发、身份连续、实时状态、转码保留	七接口均受影响	迁

注：数据源为 `paper/tables/technology_security.csv`；正文显示 6/6 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

03.E2 证据展开：系统边界、资产、主体与威胁模型

03.E2.1 端到端系统边界与七类可保护资产　生成式视觉系统的边界从训练数据进入开始，经历数据清洗与标注、基座训练、安全对齐、参数与代码制品分发、适配器组合、文本/图像/音频条件输入、采样和安全审核、水印与来源凭证、导出与转码，最后进入账户、推荐、举报、变现和司法处置链。把边界只画到模型 API 会同时漏掉上游语料和下游现实伤害；把边界扩大为“整个互联网”又会使攻击者权限无法验证。因此本文用七个连续但可分辨的安全合同界定边界。

七类资产与后续接口一一对应。第一类是数据来源、授权、标注完整性与个体隐私；第二类是权重、代码、编码器、VAE、LoRA、运动模块和依赖的制品完整性；第三类是文本、参考图、视频、音频、掩码、深度和轨迹条件的权限语义；第四类是训练目标、参数更新、擦除/遗忘和个性化的过程完整性；第五类是采样随机性、租户隔离、缓存机密性、查询隐私、队列公平与服务可用性；第六类是输出检测、水印、指纹、签名、来源声明和归因的完整性；第七类是账户、身份、同意、发布、推荐、申诉、受害者救济与现实主体的权益。

03.E2.2 主体与责任：谁承诺什么，谁能观察失效 安全主体至少包括数据主体/权利人、数据收集与标注团队、基座模型开发者、安全对齐团队、模型仓库与插件作者、个性化服务、云推理运营者、编辑工具、分发平台、来源凭证签发者与验证者、内容审核团队、受害人、媒体机构与监管/司法主体。一个控制若没有执行主体，就只是一个建议；一个失效若没有可观察者，就不能进入事件响应。

例如，C2PA 规范把声明、签名、内容绑定、配料关系和验证状态定义为可机器检查的来源信号，但其信任仍以签名者身份与声明为根 [@O001]。这意味着验证者可以确认“某个声明由某个密钥在某个时间签署且未被篡改”，但不能仅凭密码学有效性确认“声明对现实世界为真”。同样，平台检测器可以对“生成概率”给出分数，但冒充、非自愿、版权侵害或政治欺骗需要身份、同意、语境与传播证据。

03.E2.3 攻击者能力五元组：知识、访问、预算、持久性与协同 本文用五元组 (A=(K,X,B,T,C)) 记录攻击者能力。(K) 是知识，从仅知产品行为的黑盒，到知道中间嵌入和安全分类器的灰盒，再到拥有权重、梯度、数据和代码的白盒。(X) 是访问，包括向公开网页放置样本、向模型仓库上传制品、向 API 提交条件、启动个性化任务、调用检测器，以及使用平台发布与变现。(B) 是预算，应同时记录查询数、训练 GPU 时间、存储/带宽与货币成本。(T) 是持久性，区分一次输入、多轮查询、等待下一次训练周期、长期供应链潜伏与持续再上传。(C) 是协同，区分单一账户、多账户、多组件发布者与跨平台网络。

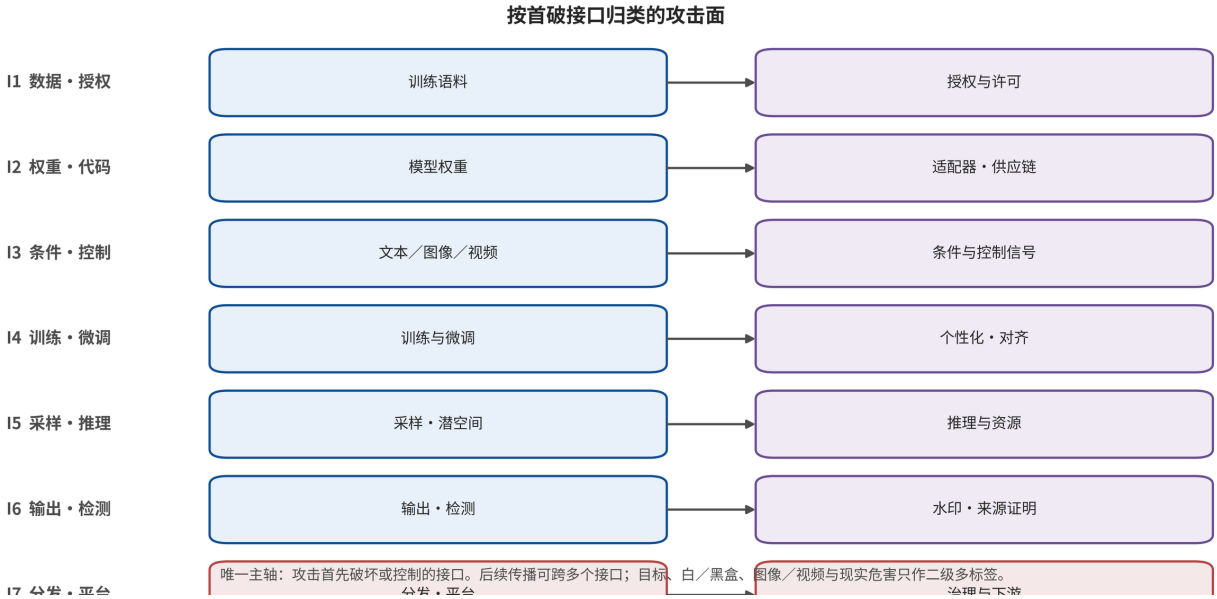
同一方法在不同能力假设下不是同一攻击。MMA-Diffusion 中的白盒联合条件操作与黑盒迁移评测必须分列 [@P009]；训练数据提取中，高查询预算和候选训练语料知识会改变可行性 [@P024]；数据投毒则可以在不访问模型权重的情况下，通过下一轮数据抓取与训练长期传播 [@P005]。评测若不报告这五个字段，“攻击成功”就没有可比较的含义。

03.E2.4 攻击目标与五类证据阶段或后果维度 攻击目标可表示为对机密性、完整性、可用性、授权、真实性或可追责性的违反。但技术目标不是现实后果。本文沿用引言的五个可多标签、可记为不适用或证据未知的后果维度：L1 是内容策略违规；L2 是生成控制被劫持；L3 是危险、侵权或未授权能力被实际调用；L4 是媒体成功生成并进入传播链；L5 是有可核验的个人、机构或公共现实伤害。参数、潜变量、缓存或密钥异常等技术证据另记在“系统状态变化”字段，不强塞进后果维度。

L1—L5 不是严重度阶梯，也不要求后层由前层自动推出。训练后门论文可能支持 L2/L3，却没有真实传播 L4 或现实伤害 L5；平台事件可能确认 L4/L5，但其模型内部状态和生成器仍为 `unknown`；隐私提取、资源拒绝服务等风险也可对不适用维度记 `NA`，并按机密性或可用性合同单独报告。每一维都应独立填写“有证据、无证据、不适用或未知”，不得以最大编号概括整条证据链。一篇论文在自定义判定器上显示有害视频，最多支持其协议实际观察到的 L1—L3；如果没有平台曝光和现实结果，不能改写成“已导致某类社会伤害”。法规规定通知与移除流程，只支持制度义务本身，不能反向证明 L1—L5 中任一事件后果已经发生。TAKE IT DOWN Act 将数字伪造纳入非自愿私密视觉内容的通知与移除框架，但法条不提供发生率或执行效果估计 [@O014]。

03.E2.5 统一威胁合同与声称上限 每项攻击在进入本综述的比较表前，必须填写十二个字段：`primary_first_break` 及其分类状态、受保护资产、攻击者五元能力、攻击输入、操作位置、高层目标函数、系统状态变化、直接输出、跨接口传播、L1—L5 各维证据状态、正常效用与失败条件。若两个接口在现有机制证据下同时首破，记录 `co_primary`；若存在多个可行解释但无法裁定顺序，记录 `ambiguous`；若全文信息不足以识别首破点，记录 `unknown`。对视频还要增加帧数、片段时长、镜头、轨迹、音画状态、流式延迟与编码链。

声称上限由证据类型决定。作者全文实验可以写“该研究在所述模型、数据和预算下报告”；官方系统卡可以写“供应商声明部署或评估”，但不能写“第三方现场已验证”。Sora 2 系统卡报告了提示、视频帧、音频转录、场景描述审核，以及 C2PA、可见动态水印和身份同意控制；本文将其作为产品设计证据，不将其作为所有平台上的保留率证据 [@R-A035]。类似地，本子任务未运行攻击代码，因此不使用“我们复现”这一结果类别。



表：资产、攻击主体、权限与后果

资产/边界	攻击主体	权限范围	主要目标	可能后果
训练语料与许可	数据发布者、采集者、训练运营者	发布少量样本至控制语料管线	投毒、非授权训练、记忆	数据污染、
模型权重与代码	制品发布者、仓库维护者、依赖攻击者	发布组件至获得构建权限	后门、代码执行、组合劫持	完整性、可
文本与多模态条件	普通用户、灰盒集成者	黑盒查询至上传控制信号	越狱、授权绕过、目标操纵	策略违规、
训练与个性化作业	数据贡献者、微调者、内部人员	影响批次、目标函数或适配器	后门、恶意微调、概念恢复	能力边界失
推理资源与租户状态	API 用户、多账户攻击者、邻租户	请求、并发、会话与缓存观测	成本放大、状态泄漏、拒绝服务	可用性、隐
输出与真实性证据	编辑者、水印规避者、凭证持有者	转码编辑至签名密钥失陷	检测逃逸、水印移除、伪造	归因混淆、

注：数据源为 `paper/tables/threat_model.csv`；正文显示 6/8 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

4. 首破接口分类、证据地图与比较合同

4.1 为什么选择首破接口作为主轴

攻击目标、触发形式、知识、模态和后果会在同一攻击链上重复出现：触发词可以是污染数据留下的推理开关、恶意适配器的激活条件，也可以直接充当越狱载荷；“深度伪造”又可能由未授权数据、恶意制品、条件越权、个性化、检测规避或下游滥用产生。以这些名称作唯一主类，会把攻击者先前权限和最早可执行控制混在一起。首破接口法改问安全状态何时第一次从满足合同变为不满足，并把目标、模态、知识和后果作为次级字段。

这一主轴保留因果顺序，却不把实现技术误当接口：Nightshade 在推理时由概念提示显现，但机制证据把污染样本进入训练置于其前，因此候选首破为 I1；Rickrolling 的触发同样出现在提示中，违约制品却是文本编码器，故候选首破为 I2 [@P005] [@P003]。Glaze、Anti-DreamBooth、PhotoGuard、I2VGuard 和 Anti-I2V 都利用扰动，却保护数据、个性化或条件等不同合同 [@P019] [@P020] [@P018] [@R-A025] [@R-A026]。本文只声称该主轴能对当前语料作可追溯编码，不声称它是唯一或完备分类。

4.2 判定树、并发、歧义与未知

判定树依次询问四件事：攻击者最早合法拥有何种权限，第一个被改变且可由机制或观察支持的系统状态是什么，该变化首先违反哪项明确安全属性，以及全文、威胁模型与定位是否足以排序。攻击者本就是训练者时，“访问训练代码”不是攻破；系统按

设计生成媒体而风险始于冒充或付款授权时，也不能虚构模型越狱。判定先产生候选接口，只有机制、权限与时间证据闭合后才升级为 primary_first_break。

编码允许四种状态：证据支持时记录一个 primary_first_break；同一不可分操作同时破坏多个合同记为 co_primary；多个解释均可行但无法排序记为 ambiguous；关键前置缺失记为 unknown。co_primary 表达并发事实，ambiguous 表达证据不能裁定，两者不可互换。覆盖审计检查题名隐藏后的判定、攻防使用同一规则、图像与视频不更换主轴以及控制入口能否回映，但本项目没有双人独立重编码和一致性统计，因此“可复核”不能写成已验证的编码者一致性或总体稳定性。

4.3 I1-I7 安全合同与控制入口

I1 数据、授权与语料合同要求来源、许可、标注和隐私边界可追溯；其最早控制入口是训练前台账、去重、异常簇、隔离与撤回。I2 权重、代码与组合供应链合同要求加载制品与名称、版本、签名、依赖和审计状态一致；其入口包括内容寻址哈希、签名、SBOM、安全序列化、允许列表、沙箱及组合行为差分。I3 文本与多模态条件合同要求输入不越过政策、权限和控制语义；其入口包括规范化、语义级审核、能力门、查询关联、生成中引导与输出复核。三者分别对应上游语料、可执行制品和调用条件，不能因共享“触发”表象而合并。

I4 训练、微调与个性化合同要求训练者、目标函数、参数更新、擦除和个性化过程可审计；可信更新、检查点差分、保留/擦除双集、回滚和同意记录是候选入口。I5 采样、隐私、缓存与资源合同保护查询、随机性、租户、队列和成本；查询与成本预算、缓存分区、近重复告警、公平调度和熔断可最早介入。前者覆盖训练过程被直接操纵或安全属性被再学习，后者覆盖模型制品正常但运行时状态、机密性或可用性先失效；局部控制的存在不等于生产有效性已经验证。

I6 检测、水印与来源合同要求信号可验证、可归因且同时考虑移除与伪造；密钥水印、签名凭证、软硬绑定、平台保留、撤销和人机解释构成多信号入口。I7 身份、版权、诈骗与平台滥用合同要求身份、同意、标识、账户、发布、举报、申诉和救济不被滥用；身份核验、敏感能力限制、再上传阻断、快速下架与证据保全是候选控制。C2PA 的密码学验证不能替代内容事实判断，水印和被动检测也不能替代平台行动与受害者救济 [@O001] [@O005]；故“镜像”表示最早控制位置的映射，而非七接口与五个防御域的一一对应或统一最优组合。

4.4 当前证据地图与覆盖审计

截至 2026 年 8 月 9 日，中央来源表含 201 条记录和 174 个去重组，来源等级 A/B/C 分别为 102/93/6；结构化主体另含 41 张论文卡、32 条中央攻防链、27 项统一论文深析和 32 张事件卡。数字的统计单位彼此不同：来源记录与规范组描述检索身份，论文卡和深析描述研究级证据，攻防链描述机制单元，事件卡描述现实或政策对象；它们不能相加为“总样本”，也不能用事件数推断发生率或趋势。

覆盖审计确认当前语料可在 I1—I7 主轴下保留机制、传播与边界，但各接口的证据类型并不对称：论文卡覆盖七个接口，27 项深析主要承担技术机制与协议定位，I7 的现实链更多依赖事件、标准、法规和平台材料，不能为追求版面整齐强行补造论文深析。类似地，“41 张卡均有首破字段”只证明字段闭合，不证明文献总体分布或分类完备；正文按接口报告支持、反例、未知与停止位置，完整卡片留在附录供复核。

4.5 指标单位、三联报告与统计拒绝

比较从有效分母开始。在线服务至少保留 requests、responses、valid_responses、judgeable_responses、policy_accepted_inputs 与 successful_attacks 六个嵌套计数；重复种子还要按提示聚类。视频至少区分帧、片段、整段视频和身份：一百帧不是一百个独立视频，任一帧命中也不等于事件顺序成立；训练数据提取还需分开生成数、候选数、自动阳性、人工近副本与独立训练样本 [@P034] [@P007] [@P024]。新闻和治理的单位是事件或有效通知，而非报道篇数。

每项攻防比较采用三联报告：Attack=(成功判定，有效分母，权限/预算)，Utility=(干净质量，任务保持，用户可接受度)，Residual=(适应性攻击，未知模型或条件，部署失真)。后门 ASR 若不并报清洁效用，可能只反映模型整体受损；水印移除若不限制媒体质量，也可能只反映破坏性压缩。TrojDiff 不同目标指标、MasqLoRA 不同组合结果与 BadDiffusion 的毒化配置不能直接排序，WAVES 的攻击—质量前沿也只能在共同攻击强度与质量合同下解释 [@P002] [@P006] [@P030]；视频时序一致性还须与运动幅度配对，以排除静止输出造成的虚高 [@R-A025]。

正式拒绝规则覆盖三类错误：不把 ASR、FID/KID、FVD、AUC、水印比特准确率和现实伤害折算为同一终点；不把帧、提示、身份或同一模型的重复样本当作独立研究；不把 AUC 变成未指定基率的平台精确率、把事件数变成发生率、把 C2PA 验证变成事实真实性或把静态代码审计变成复现成功。只有同一论文同一协议内比较、统一基准的同代码重跑，或取得原始计数后定义共同终点并正确处理依赖结构的再分析，才可能进入定量综合；当前材料未满足这些条件，故保持 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE，跨研究结论限于条件化定性综合。

04.E1 证据展开：首破接口 taxonomy 的设计、判定与覆盖审计

04.E1.1 primary_first_break 主标签与非强制唯一性 攻击可按目标（隐私、后门、版权、越狱）、时机（训练期、推理期）、知识（白盒、黑盒）、模态（图像、视频、音频）或后果（诈骗、政治传播、非自愿私密影像）分类，但这些轴会在攻击链上反复出现。一个“触发词”可以是 I1 数据投毒的推理开关，也可以是 I2 恶意 LoRA 的激活条件，还可以直接是 I3 提示越狱载荷。若以“触发”作为主类，会把不同权限和防御入口混在一起。

首破接口法优先保留因果顺序：沿数据 → 制品 → 条件 → 训练/更新 → 采样/服务 → 输出/归因 → 分发/现实使用的链条，寻找最早从满足安全合同变为不满足的状态。通常将证据最充分的接口记录为 primary_first_break，攻击者知识、时机、模态、目标与后果作为次标签，后续经过的接口记为传播链。但分类不强制唯一：若两个合同在同一不可分操作中同时失效，使用 co_primary；若全文支持多个首破解释却不能排序，使用 ambiguous；若材料不足，使用 unknown。这些状态防止为了表格整齐而制造虚假的因果顺序，同时仍帮助定位最早可中断位置。

04.E1.2 操作性判定树和证据门 判定从四个问题开始。第一，攻击者最早合法拥有什么权限？如果攻击者本来就是模型训练者，“接触训练代码”不是攻破，违反的是训练过程完整性或对外制品声明。第二，第一个被改变的系统状态是什么？必须是可观测或可由全文机制支持的状态，不能从方法名称猜测。第三，该状态变化违反哪个明确安全属性？如果系统按设计工作而攻击者在下游实施欺骗，不能虚构模型层越狱。第四，是否有全文、章节/页码和威胁模型足以支持该判定？只有摘要或新闻摘录时，保持未验证。

判定树先生成候选接口，而不是强制单选：若最早证据是未授权、污染或误标数据被纳入，候选 I1；若最早证据是装载与声明不一致的权重、代码或适配器，候选 I2；若制品正常而条件越过政策或控制语义，候选 I3；若最早是训练、微调、个性化或擦除更新违反合同，候选 I4；若最早通过采样、缓存、查询、租户或资源调度实现，候选 I5；若最早规避、伪造或剔除检测、水印或来源信号，候选 I6；若前述系统按设计运行而风险始于下游身份、同意、发布或治理，候选 I7。候选只有在机制、时间和权限证据支持排序时才成为 primary_first_break；真正同时失效记为 co_primary，无法区分竞争解释记为 ambiguous，证据不足记为 unknown。

04.E1.3 七个接口的安全合同与镜像防御入口 接口合同用于定义候选首破点和镜像防御位置，不用于排斥同一事件的 co_primary 或传播标签。I1 承诺数据有来源、授权、完整标注与隐私边界，镜像防御是训练前来源台账、去重、异常簇、隔离与授权撤回。I2 承诺被加载制品与名称、版本、签名、依赖和审计状态一致，镜像防御是内容寻址哈希、签名、SBOM、安全序列化、允许列表、沙箱与组合行为差分。I3 承诺条件输入不越过政策、权限和控制语义，镜像防御是语义级多模态审核、能力门、查询关联、生成中安全引导与输出复核。

I4 承诺训练者、目标函数、参数更新、个性化和擦除过程可审计，镜像防御是训练权限、更新日志、检查点差分、保留/擦除双集和个性化同意。I5 承诺推理服务保护查询、随机性、缓存、租户、队列和资源，镜像防御是查询/成本预算、租户缓存分区、近重复输出告警、公平调度和熔断。I6 承诺输出检测、水印、来源声明和归因可验证、抗移除与抗伪造，镜像防御是密钥水印、签名凭证、软/硬绑定、挑战应答、平台保留、撤销和人机解释。I7 承诺身份、同意、标识、账户、发布、举报、申诉与救济不被滥用，镜像防御是身份/同意核验、敏感能力限制、发布标识、再上传阻断、快速下架、证据保全和申诉。

04.E1.4 边界案例、优先级与多标签规则 边界案例的第一条原则是“实现技术不等于被保护接口”。Glaze、Anti-DreamBooth、PhotoGuard、I2VGuard 和 Anti-I2V 都使用扰动，但它们分别保护未授权风格/个性化数据或图像条件，不应被简单归入“对抗攻击”一类 [@P019] [@P020] [@P018] [@R-A025] [@R-A026]。第二条原则是“仅在证据足以排序时，优先最早违反的明确合同”。Nightshade 在推理时通过普通概念提示显现，但全文机制把污染样本进入训练数据放在提示显现之前，因此其 primary_first_break 为 I1 而非 I3 [@P005]。Rickrolling 的触发也出现在提示中，但违约制品是文本编码器，故其 primary_first_break 为 I2 [@P003]。

第三条原则是将目标和后果作为次标签。深度伪造可由 I1 未授权身份数据、I2 恶意制品、I3 视觉条件越权、I4 个性化越权、I6 检测规避，或 I7 合法能力滥用产生。若只看最终“深度伪造”标签，就无法决定应优先修复数据授权、模型仓库、条件审核、水印还是平台救济。第四条原则是不以“最早”之名强行消除真实并发：若同一次不可分操作同时破坏数据授权与训练更新完整性，可记录 I1/I4 co_primary；若论文没有说明污染发生在集中训练还是后续微调，则记录 I1/I4 ambiguous；如果连关键前置都缺失，则记录 unknown。co_primary 表示并发首破，ambiguous 表示证据不能裁定，两者不能混用。

04.E1.5 覆盖审计、稳定性与 taxonomy 失败条件 覆盖审计不是统计哪一类论文最多，而是检查每个纳入对象是否能在不改变主轴的情况下稳定编码。稳定性检查包括：将一篇论文的题名和方法名隐去，仅根据攻击前置、首个状态变化和安全属性判定；对攻击论文与防御论文使用同一判定规则；对图像与视频只增加模态状态字段，不重新创建一套主类；对模型能力滥用与真实技术绕过做反事实问答。

taxonomy 有四种明确失败情形。第一，为追求单标签覆盖率而把应为 co_primary、ambiguous 或 unknown 的对象强行单选，制造虚假精度。第二，在机制证据充分时仍大量使用 ambiguous 或 unknown，说明接口定义、全文读取或证据字段不足。第三，各章为了容纳新论文而更换主轴，例如 I1 用“时机”，I3 用“目标”，I6 用“方法”，从而失去跨章可比性。第四，primary_first_break 与 co_primary 都无法映射到最早可执行的一个或多个防御位置。稳定性不以“所有编码者必须给出一个相同标签”为目标，而以主标签、并发状态、歧义原因和证据页码均可复核为目标。为防止这些失败，attack_comparison.csv 对全部家族使用同一比较字段，video_risk_matrix.csv 只将时间、运动、音画、资源与流式状态作为视频次轴；其中 interface 是便于排序的 primary_first_break 展示字段，不否认正文记录的并发或不确定状态。

表：七类首破接口的判定与边界

首破接口	纳入判据	不归此类	典型案例	边界处
I1 数据与语料	恶意、未授权记录首先进入训练候选	只上传推理参考图	数据投毒、训练授权	I3（若
I2 权重、代码、供应链	被加载制品、依赖或组件首先失信	开发者自己训练出后门	恶意 LoRA、编码器、序列化	I4（若
I3 条件与控制	文本、图像、视频、掩码先突破输入合同	正常条件触发潜伏后门	越狱、对抗参考图	I4、I2
I4 训练与对齐	更新过程、目标或个性化作业先失信	只调用已有危险能力	训练后门、恶意微调、擦除恢复	I3（若
I5 推理与资源	采样、缓存、租户或成本合同先失效	输出随后被转码规避检测	DoS、成本放大、状态侧信道	I6（若
I6 输出与来源	检测、水印、签名或凭证先失效	生成本身已违规但未规避来源	水印移除、伪造、检测逃逸	I3、I4

注：数据源为 paper/tables/taxonomy_boundaries.csv；正文显示 6/7 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

5. I1-I7 镜像证据综合：攻击机制与最早中断控制

5.1 I1 数据、授权与语料：投毒/记忆根因 □ 来源、去重、隔离与撤回

I1 的安全合同要求训练、微调与评测语料具有可追踪来源、适用授权、正确标注、受控重复和明确的隐私边界。攻击由样本或其权利、标签、版本关系先进入不应进入的训练流程而成立，之后在参数或输出中显现只是传播。Nightshade 的作者实验把整体污染细化为概念定向的语义偏移，并在指定模型、语料和清洗设置下检查攻击与缓解；该结果支持“污染样本被纳入训练是首破点”，不支持据此估计现实语料的普遍污染率，也不提供本文可复用的样本制作步骤 [@P005]。

最早中断位置是数据入口，而不是等到输出审核：来源与许可账本先确认主体、用途和撤回状态，精确哈希、感知表示、语义嵌入及人工复核共同处理重复与异常，高风险批次在不直连生产训练的隔离区等待处置。Glaze 与 Anti-DreamBooth 的作者结果表明，训练前扰动可在各自模型和预处理预算内提高未授权风格或主体学习的成本；LightShed 等反制又说明保护本身会成为适应性净化目标 [@P019] [@P020] [@P023]。因此正常效用必须同时报告长尾样本误删、少数类覆盖、合法个性化成功、处理时延和创作者可接受度，不能把攻击指标下降写成无代价授权治理。

适应性攻击可借重描述、转码、跨账户分散、代理模型差异或混入清洁样本削弱筛查与主动保护；撤回也可能只阻止后续训练，而无法低成本消除已发布检查点和离线副本。若入口控制失败，污染关系传播到 I4 的更新状态，近重复与未授权样本可在 I5 成为记忆或提取根因，身份、版权和救济问题最终进入 I7。视频还需在片段、运动、音频和身份轨迹层去重；现有视频记忆研究区分内容记忆与运动记忆，但不提供商业服务总体记忆率 [@A047]。故 I1 的残余风险必须随数据分片、特征库、检查点、适配器和撤回记录向下游显式传递。

5.2 I2 权重、代码与组合供应链：恶意制品 □ 签名、SBOM、沙箱与组合差分

I2 的安全合同要求实际加载的权重、编码器、VAE、LoRA、运动或音频模块、自定义节点及运行时依赖，与声明的名称、版本、来源、摘要、许可和执行权限一致。攻击者只要能使目标系统加载未经充分审计的制品，便可在提示到来之前建立异常状态。Rickrolling the Artist 的作者实验显示，仅替换文本编码器即可重定向生成语义；MasqLoRA 的作者实验显示，独立 LoRA 可承载条件异常并与其他适配器组合 [@P003] [@P006]。这些图像证据支持检查组件和组合，而不是断言视频运动模块已被同类攻击实证覆盖。

最早中断控制位于制品准入：不可变摘要、发布身份和签名确认字节及发布链，SBOM 记录基座、编码器、适配器、转换与依赖，安全序列化和最小权限沙箱收窄任意执行面，固定输入与种子的组合行为差分再检查加载前后拒绝、语义、身份、运动和资源变化。官方文档把仓库扫描描述为尽力而为，并说明安全加载默认值仍不排除拒绝服务或下游对象风险；签名同样只证明来源

与完整性，不证明行为良性 [@O037] [@PyTorchSerialization2026] [@SigstoreBlob2026]。正常成本包括隔离环境、制品登记、组合测试和误拦自定义组件；允许列表可降低组合规模，却会牺牲开放生态的即插即用效用。

适应性绕过可利用签名主体本身恶意、密钥或仓库账户失陷、静态统计正常但行为异常、转换或量化后才显现，以及多个单件各自通过而组合触发。BlackMirror 的作者结果说明黑盒行为差分可补充静态权重检查，但其探针与模型范围也不是完备证明 [@R-A029]。若制品准入失效，异常可在 I4 被继续训练或写入“最新”别名，在 I3 由普通条件激活，在 I5 消耗共享状态，并随工作流二次分发进入 I7。撤销必须覆盖摘要拒绝列表、运行节点缓存、已部署实例和下游通知；离线副本仍构成不能由中心平台远程消除的残余风险。2026 年 10 月为该接口补上一个生产实例：Hugging Face Datasets CVE-2026-57845 使构造的 pickle 经废弃 pandas 构建器执行 Python，披露时无修复版本——供应链门如今覆盖数据加载库，而不只是模型制品。

5.3 I3 文本与多模态条件：越狱/控制劫持 □ 规范化、授权差分与能力门

I3 的合同不是审核一段提示字符串，而是保证文本、参考图、首尾帧、掩码、姿态、轨迹和音频等联合条件不越过内容策略、主体授权或能力范围。攻击机制利用字面规则、嵌入语义与输出判定之间的不一致，或把意图分散到分别看似正常的模态和时间条件中。SneakyPrompt 的作者结果显示，黑盒接受/拒绝反馈可被用于搜索替代表达；MMA-Diffusion 的作者结果显示，文本与图像条件的联合操作会暴露单模态审核盲区 [@P008] [@P009]。这些结果只在相应模型、查询预算和判定器下成立，不能合并为统一越狱成功率。

最早中断控制是请求入口的多模态规范化与授权差分：把编码、OCR、图像区域、轨迹、音频转录和元数据还原到同一请求对象，分别判断内容语义、主体同意和技术权限，再由能力门限制敏感身份、片长、分辨率、外部制品和导出范围。后续采样期约束与滑动片段复核是纵深层，不应为入口放行提供理由。Sora 2 系统卡所述输入、输出、身份和产品控制属于厂商对特定版本的部署声明，不是独立攻击评测 [@O020]。正常效用代价表现为多模态解析延迟、合法引述或教育内容误拒、少数语言偏差、人工复核负担以及生成完成后才阻断所浪费的算力。

适应性攻击会跨轮改写语义、递进参考素材、利用模型或审核器版本漂移，并把目标延迟到生成中间或完整事件；因此查询关联只能提供风险证据，不能把正常反复创作自动视为恶意。Two Frames Matter 与时间感知红队研究的作者结果支持“边界状态通过不等于中间轨迹安全”，但本文不保留可用于现实绕过的载荷或优化参数 [@LN05] [@LN04]。若 I3 未中断，异常条件进入采样和缓存形成 I5 压力，经 I6 的不确定真实性信号后仍可能在 I7 被传播。残余风险还包括开放权重绕过服务端能力门，以及模型无法从条件本身判断真实世界同意与语境。

5.4 I4 训练、微调与个性化：后门/再学习 □ 可信更新、回滚、擦除双集与同意

I4 要求训练或更新只按获授权的数据、目标、代码和变更范围修改模型，并使更新后的异常行为、正常能力及撤回路径可追踪。攻击机制包括在优化中建立条件—异常输出关联、通过后续微调恢复被压低能力，或在主体驱动个性化中吸收未获授权的身份或风格。BadDiffusion、TrojDiff 和 BadT2I 的作者实验分别展示了不同扩散后门合同；BadVideo 把训练期异常推进到指定文本到视频设置 [@P001] [@P002] [@R-A003] [@P007]。这些研究的目标、数据、触发、判定器和正常效用不同，不构成可汇总的“后门强度”。

最早中断位置是更新编排：签名代码与数据清单、作业身份、可更新层限制和不可变日志先约束更新，训练中记录批次与模型差分，训练后以独立探针同时检查触发行为和清洁效用，并以不可变版本、灰度发布和回滚管理部署。概念擦除需并列擦除集与保留集，检查别名、多语言、图像条件和有限再学习；个性化还需把主体、用途、期限、模态、导出权及撤回绑定到同意令牌。ESD、Ablating Concepts 与 AdvUnlearn 的作者结果支持特定协议下压低概念可达性，不支持“从所有表示永久删除” [@P014] [@P015] [@P016]。正常成本包括训练与红队算力、合法概念连带损失、个性化摩擦和版本存储。

适应性绕过可借未见条件、组合组件、短时再微调、不同编码器或量化转换恢复异常；正常画质保持也不能代替提示遵循、身份、运动和安全拒绝等效用指标。更新若进入部署别名，异常会传给下游蒸馏、LoRA 与缓存；主版本回滚后，离线下载和衍生权重仍可能保留。故残余传播需连接 I2 的制品依赖图、I5 的推理暴露和 I7 的身份或平台后果。视频还要把帧外观与轨迹、动作顺序、镜头持续和音画同步分开验证；BadVideo 的作者结果不能替代恶意运动模块、音频分支或长时组合的独立证据 [@P007]。

5.5 I5 采样、隐私、缓存与资源：提取/侧信道/成本放大 □ 隔离、预算、近重复与熔断

I5 的合同要求推理查询不暴露训练样本、成员或租户秘密，不跨用户复用不应共享的状态，也不把低成本请求无界放大为计算、排队或账单压力。作者在图像扩散模型上报告了高预算查询与近重复检索下的训练样本提取，并把语料重复列为关键条件；视频记忆研究又区分内容记忆与运动记忆 [@P024] [@A047]。近似缓存研究则表明，共享相似性边界可引出提示恢复、错误复用或资源异常 [@P039]。三类结果的输出和分母不同，不能统称为一个隐私攻击成功率，更不能把图像缓存证据写成商业视频服务已遭成本放大。

最早中断控制随根因而分层：训练前去重和敏感身份治理降低记忆根因；请求入口按租户、模型组合和任务预算准入；运行时隔离潜状态与缓存键，采用可抢占调度、硬配额、超时、取消释放和成本熔断；输出端用训练集近重复检索与人工确认阻断明确泄漏。缓存键若绑定租户、模型、适配器、策略和精度，可减少跨上下文复用，却损失命中率和吞吐；严格近重复阈值又可能拦截合法相似创作。正常效用必须报告 P50/P95/P99 时延、吞吐、GPU 时间、质量、误拦和费用，而非只报攻击侧变化。

适应性绕过可能利用分布式低速账户、相似性阈值边界、跨模态切片、失败重试或反馈差异；防守方也可能因跨租户复用、取消不释放或记录过量提示而引入新的隐私面。当前语料没有足够一手证据支持生成式视频专用 DoS 的统一效果判断，因此资源控制属于条件化工程合同，不包含对现实端点的编排方法。若 I5 失守，候选输出仍须经过来源对应、身份确认和现实接触才进入 I7，不能由“相似媒体出现”直接推断受害；缓存和调度异常则可能继续传播为质量错误、侧信道或服务降级，三者应分别记录。

5.6 I6 检测、水印与来源：规避/移除/伪造 □ 多信号真实性证据栈

I6 保护的不是一个永久“真假”标量，而是检测、嵌入、载荷、签名、内容绑定、验证和显示在各自声明条件下保持可解释。攻击机制因对象不同而异：检测规避利用生成器与媒体链的域偏移产生假阴性或假阳性；水印移除、转移或伪造改变检出与归属；来源链攻击剥离凭证、破坏绑定或误导验证界面。DIRE、GenImage、Stable Signature、Tree-Ring、WAVES 与生成式去水印分别给出作者协议内证据 [@R-A016] [@R-A017] [@P028] [@P029] [@P030] [@P031]。这些结果不能合并为统一鲁棒率，也不能把未检出写成非合成。

最早中断控制是保留多信号而非投票抹平差异：生成端可嵌入内容信号并签发来源凭证，编辑端记录派生关系并重签，平台上传端分别保存检测分数、水印结果、C2PA 状态与输入版本，展示端区分“来源已验证”“统计检测”“未能验证”和“内容违规”。C2PA 2.4 规范定义声明、签名及 hard/soft binding，但不保证叙事真实；VideoSeal 与 VideoShield 的作者结果分别支持特定视频水印路线，不代表跨平台保留 [@O001] [@P033] [@R-A020]。正常代价包括嵌入与验证延迟、画质或时序影响、密钥和撤销治理、低基率误报、人工申诉及长视频资源。

适应性绕过可组合转码、裁剪、重生成、查询反馈、密钥失陷或跨平台元数据剥离；合法编辑和无障碍处理也可能造成相似信号损失，因此仅凭处理痕迹不能归因恶意。多信号冲突时，应保全原件并分别核验签名主体、撤销时点、内容绑定和检测分布，而不是多数表决。若 I6 失效，错误归属或“无标签即真实”的误解会在 I7 放大；反之，有效水印或凭证也只提供来源线索，不能自动证明主体同意、内容事实或平台已经处置。残余风险由不合作生成器、离线编辑、密钥治理、低基率误报和跨平台保留共同决定。2026 年 10 月的两个条目扩展了这一接口的攻击面。Cisco Talos 记录了四个恶意软件家族嵌入自然语言指令，操纵 AI 辅助分诊给出良性判定——84 个样本上约 35% 的判定偏移——检测器本身由此成为 I6 的目标。AIR Security 的 Web Hole 审计发现 36 个过期域名仍出现在智能体搜索结果中，是位于任何模型上游的可购买注入点。

5.7 I7 身份、版权、诈骗与平台滥用 □ 身份核验、传播限制、事件响应与救济

I7 的合同要求媒体制作、标识、上传、推荐、变现、举报和救济不在无授权条件下损害身份、隐私、财产、权利或公共信息。攻击机制不由模型能力单独构成，而须沿“取得可用媒体—发送或上传—目标接触或平台传播—组织或受众行动—可观察后果”建立证据链。香港政府书面答复确认的深伪会议诈骗可支持特定财产损失与调查事实，却不提供生成器、实时性或通用诈骗成功率 [@O048] [@O049]；司法、平台和媒体事件同样只能支持各自公开的程序与处置状态。

最早中断控制应靠近高后果授权点：真实人物生成与个性化先核验主体和用途，上传端保全原件并组合来源、身份和内容证据，推荐与广告端按风险限制规模化触达，支付或官方沟通采用独立回拨与多人授权，举报后搜索已知副本并提供可申诉的事件响应。StopNCII 与 Take It Down 的官方说明展示了设备端哈希和参与平台匹配的服务范围；它们不保证全网删除，也不把命中自动升级为违法认定 [@StopNCII2026] [@TakeItDown2026]。正常成本包括身份核验摩擦、人工复核、误删与收入影响、敏感证据保全和多语言受害者支持。

适应性绕过可利用私域通信、跨境和不合作平台、裁剪或再上传、账户网络、错误标签及对真实内容的“骗子红利”。因此平台处置需从可逆提示、降速和限制推荐逐步升级到隔离、移除或账户行动，并为高后果决定保留上下文与申诉；法规规定的透明度或通知义务也不等于技术检测或执行效果 [@O006] [@O009] [@O014]。残余传播表现为副本在平台间脱离原凭证、删除晚于曝光、离线权重继续生成，以及错误归属伤害真实创作者。I7 的结果分母应按独立身份、事件、接触、交易、权利主张或申诉选择，不能用上传数、举报数或实验识别率替代现实发生率。

5.8 跨接口传播、反例和未闭合证据

本文综合显示，七接口适合确定最早可干预的合同，却不构成严格一一对应的攻防表。数据去重既服务 I1，也降低 I5 记忆根因；制品签名保护 I2，却不能发现 I4 的行为异常；条件能力门主要中断 I3，也会减少 I5 资源暴露；真实性证据作用于 I6，但只有平台案件系统能把信号转成 I7 行动。应把同一控制的主保护接口、依赖、次级覆盖和失败传播各记一次，避免把纵深层数

重复计为独立效果。反例同样重要：签名可签署恶意制品，水印可在合法编辑中丢失，检测器可误标真实内容，平台下架也无法召回全部离线副本。

证据仍未闭合的位置包括视频专用资源放大、恶意运动模块与多适配器组合、超长上下文安全漂移、同步音画下的自适应攻防、商业视频记忆、跨平台来源保留和事件级救济效果。它们只能写成待验证缺口，不能由图像论文、静态仓库或产品声明补齐。由于 ASR、FID、FVD、AUC 的任务、分母、模型、预算和方差不同，本章只做同接口内的条件化定性综合；元分析状态保持 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE，不生成总体效应、统一安全分或异构排名。

05.E1 证据展开：I1：训练数据、授权、标注与上游记忆攻击

05.E1.1 安全合同、受保护资产与攻击者权限 I1 承诺训练、微调与评测数据具有可追踪来源、合法授权、正确标注、可控重复与明确隐私边界。受保护资产不只是数据库文件，还包括每个样本的来源主体、同意范围、许可条款、描述、时间与地点、身份、版本关系、去重族与撤回状态。对视频，还要记录片段边界、帧率、音轨、人物轨迹、动作标注、镜头剪辑与一段原视频被切成多少训练样本。

攻击者不一定需要训练集写权或模型白盒。数据投毒可以借助开放网页、图库、视频站点或上传接口，等待数据抓取和下一轮训练。未授权个性化则可只需收集他人的公开图像或片段，再调用正常个性化服务。内部攻击者或数据供应商则可以直接操作标注、去重规则、过滤阈值或数据版本。因此 I1 的典型能力特征是模型权重访问可以很低，但传播时间长、训练批次与数据管线知识重要。

05.E1.2 输入—机制—输出：投毒、标注操纵与未授权训练 概念定向投毒的输入是一组人类观感与模型特征指向不同的图文对，操作位置是抓取和训练数据，机制是让模型在特定概念附近学到错误视觉对应，输出是未来普通提示下的概念分布偏移。Nightshade 的意义不在于某个具体扰动配方，而在于它把“整体数据污染”具体化为“概念—目标的定向语义破坏”，并检查了数据清洗和模型变体的影响 [@P005]。为避免双用滥用，本文不保留其样本制作和优化操作细节。

标注操纵可以更直接：将人物、行为、风格、场景或安全属性系统性地错标、遗漏或过度泛化，使筛选器、安全对齐或生成模型学到错误边界。未授权训练的机制不必是数值污染：样本可以完全干净，但从未授权主体、用途超出原同意，或撤回后仍继续用于训练。这时失效的是授权与可追责性，而非样本像素完整性。Glaze 与 Anti-DreamBooth 从防守侧分别将未授权风格模仿与主体驱动个性化明确为威胁场景 [@P019] [@P020]。

05.E1.3 传播路径与代表工作谱系 I1 的典型传播是数据 → 训练 → 参数 → 推理 → 输出 → 分发。因为首破发生在数据，后续提示只是激活或观测位置。对投毒，数据抓取、自动重描述、去重和再训练可以中断或放大链条。对未授权个性化，传播是身份/风格样本 → 个性化任务 → 专用权重或适配器 → 反复生成。对记忆根因，传播是近重复样本 → 参数记忆 → I5 的主动查询提取。这个区分很重要：重复数据是上游根因，但提取攻击的首破操作在 I5，不应重复计数。

代表工作构成一条“保护—适应—边界”谱系。Glaze 聚焦风格模仿，Anti-DreamBooth 聚焦主体个性化，PhotoGuard 聚焦图像编辑条件，I2VGuard 与 Anti-I2V 则把主动保护扩展到图生视频的空间与时序表示 [@P018] [@R-A025] [@R-A026]。这些工作的共同结论不是“已经阻止未授权训练”，而是“在明确模型、预处理和扰动预算下提高攻击成本”。它们不替代授权台账、同意撤回、模型删除或平台救济。

05.E1.4 数据、指标、成本与失败条件 I1 评测的最小分母不应是“一组最好的展示图”。投毒需报告独立概念数、每个概念的污染/清洁样本数、训练数据总量、模型版本、训练步数、提示与种子集、目标概念效果、非目标溢出和清洁生成效用。主动保护需报告保护图像的感知质量、个性化后身份/风格相似、清洁图像泄漏比例、跨模型与跨预处理迁移，以及防守方制作扰动的时间/GPU 成本。Glaze 和 Anti-DreamBooth 都在全文中列出适用条件与失败边界，这些内容与正向结果同等重要 [@P019] [@P020]。

攻击失败条件包括：污染样本未进入训练集；来源或授权检查将其隔离；去重、重描述、转码或数据增强破坏其特征；攻击方使用的代理模型与训练方的实际编码器不同；攻击强度不足以压过清洁语料；主动保护被清洗或混入足够清洁图像；或保护本身的可见失真超出可用阈值。防守也会失败：近重复阈值可以误删合法连拍或拍摄片段，授权撤回可能无法同步到已发布检查点，异常聚类可对长尾风格产生偏见。

05.E1.5 视频不可约差异与防御入口 视频 I1 比图像多三个核心问题。第一，一段视频可被切成大量高相关短片段，如果去重只对帧或文件哈希，同一身份、场景与动作会被高度重复计入。第二，未授权对象从面孔或风格扩展到姿态、动作、口型、声音、场景和相机轨迹。第三，记忆不只是内容外观，还可表现为运动模式。Investigating Memorization in Video Diffusion Models 明确区分内容记忆和运动记忆，并指出仅以“整个视频完全复制”为标准会低估帧级与片段级风险 [@A047]。

因此防御应从上传时就建立身份和授权台账，在片段层做视觉、音频、运动与场景指纹去重，对自动视频描述做时间一致性审计，将高重复、权利不明或敏感身份片段放入训练前隔离区。最低评测单元应包含帧、片段、整视频和身份四级，同时报告授权状态、内容记忆、运动记忆、正常训练效用与误删成本。

05.E2 证据展开：I2：权重、代码、LoRA、适配器与供应链攻击

05.E2.1 安全合同、制品边界与最小权限 I2 承诺实际加载的制品与声明的名称、版本、来源、哈希、签名、依赖、许可证与审计状态一致。“制品”不只是主模型 checkpoint，还包括文本/视觉/音频编码器、VAE、ControlNet、LoRA、运动模块、安全分类器、调度器、自定义节点、序列化对象、推理加速插件、编码器库和容器镜像。只校验一个大权重文件会遗漏大量实际执行路径。

攻击者的最小权限是能让目标系统加载一个未被充分审计的制品。这可以是模型仓库上传者、插件作者、工作流分享者、依赖维护者，也可以是能改写下载链、发布标签或本地配置的中间人。攻击者可不知道云端运行时细节，但需知道制品接口与兼容基座。对多模块组合攻击，还可能需要知道加载顺序、权重缩放、量化方式和转换工具。

05.E2.2 输入—机制—输出：编码器、LoRA 与组合式后门 编码器后门的输入是一个与公称功能一致的编码器文件，机制是在条件嵌入空间建立隐藏映射，输出是特定条件下的语义重定向。Rickrolling the Artist 的威胁模型和评测告诉我们，条件触发虽然由提示传入，但不安全状态已在编码器被加载时建立 [@P003]。将其归为 I3 会把防御错放在提示过滤，而忽略制品哈希、来源和行为差分。

LoRA 后门的输入是独立低秩参数，机制是在不改变基座模型的前提下保存条件性异常行为，输出是加载后特定条件下的目标生成。MasqLoRA 在图像生成上提供了直接证据，并评估了恶意适配器与其他 LoRA 的可组合性 [@P006]。但是，视频模型上的运动模块、相机 LoRA 和音频模块恶意组合尚未形成同等完整的一手证据集。本文将“组合后才触发”作为防守测试合同，不将其伪装为已复现的攻击。

组合式供应链的更一般输入是基座模型、多个适配器、ControlNet、VAE、调度器与自定义节点的工作流图。机制可能是非线性组合：每个模块单独评估均看似正常，但特定顺序、缩放或量化后才显现异常。因为组合空间随模块数增长，静态“逐件扫描”不足以保证管线行为。

05.E2.3 传播、代表工作与防守反例 I2 的传播链是制品制作 → 仓库与标签 → 下载 → 序列化/转换 → 工作流组合 → 输出 → 二次分发。其特点是一次制作可以低成本复制到大量用户，并在不同前端与工作流中失去原始语境。用户看到的可能只是一个“风格加强”或“运动增强”节点，但系统执行的是带权重、自定义代码和依赖的完整制品。

防守反例一是“有签名所以良性”。签名只证明制品来自持有某密钥的主体且传输中未被篡改，如果签名者本身恶意，签名反而稳定了恶意制品的来源。反例二是“权重统计正常所以行为正常”。低秩参数或组合触发可能不被简单范数、离群值或直方图发现。BlackMirror 从黑盒指令—响应差异出发审查后门，提供了对静态检查的行为补充，但其评测仍限于所述图像模型和探针分布 [@R-A029]。反例三是“单模块通过即可组合”，组合可以改变作用顺序、嵌入尺度和量化特征。

05.E2.4 评测单元、成本、正常效用与失败条件 I2 的最小评测对象是“基座版本—制品版本—组合工作流—输入探针—随机种子”五元组，不是一个裸权重文件。必须记录每个制品的哈希、签名、安全格式、依赖、加载代码、合并顺序、缩放系数、量化/转换以及沙箱权限。行为指标必须同时包含触发输出、清洁提示语义、风格效用、输出质量、跨种子稳定性、合并前后差异和检测误报。

攻击成本一般由制品微调、测试与分发构成，传播成本可远低于基座模型训练。防守成本则可随组合数爆炸：若一个工作流可从数十个 LoRA、VAE 和运动模块中自由选择，全排列穷举不可行。实用策略应以允许列表和最小权限缩小组合空间，再为高风险组合做行为差分。攻击失败条件包括基座版本不兼容、签名/哈希允许列表拒绝、安全序列化阻止代码执行、合并或量化破坏触发行为、动态探针发现异常、或工作流根本未装载该制品。

05.E2.5 视频差异与可执行防御入口 视频供应链的核心差异是组件更多且功能正交性更差。一个角色 LoRA 改变空间外观，一个运动模块改变时间注意力，一个相机控制器改变轨迹，一个音频模块改变说话人或环境声，而插帧与量化模块改变时序质量与运行成本。异常可能只在三个或更多模块共同加载时出现。图像 LoRA 后门证据提供了风险类比，但未替代视频组合评测。

05.E3 证据展开：I3：提示、概念、多模态条件与生成控制劫持

05.E3.1 安全合同、条件空间和攻击者能力 I3 承诺用户提交的文本、参考图、起始视频、音频、掩码、深度、姿态、边界帧、轨迹和负面提示不会越过政策、用户权限或控制语义。关键资产不是“提示字符串”，而是条件经文本/视觉/音频编码后在联合嵌

入空间中的意图、时间指令与优先级。只对明文关键词做过滤，无法覆盖同义、拼写变体、学习式嵌入、图像隐含行为和音画组合意图。

攻击者能力从黑盒单次提交到白盒联合优化。SneakyPrompt 使用查询反馈在黑盒中搜索替代提示，说明拒绝/接受结果本身可以成为优化反馈 [@P008]。MMA-Diffusion 联合处理文本和图像条件，说明攻击面会在多模态输入中相乘，而非简单相加 [@P009]。视频模型中，攻击者可以仅提交看似正常的起始图和弱文本，但联合条件在时间补全中产生风险。VPA-Guard 与 SafeGen-Bench 将此类视觉提示和图像条件视频安全作为独立基准对象 [@R-A027] [@A033]。

05.E3.2 输入—机制—输出：语义越狱、多模态组合与概念恢复 文本越狱的输入是在人类或字符串过滤下显得无害，但在模型嵌入中保留目标语义的条件；机制是利用字面规则、嵌入语义和输出判定之间的不一致；输出是通过输入审核并诱导生成管线越过能力边界的条件。攻击的最高可证结论必须分三阶段：条件是否通过输入过滤；生成器是否产生目标语义；输出审核是否允许交付。仅通过第一阶段不是端到端成功。JailbreakDiffBench 将提示与图像审核器拆开比较，支持这种阶段化报告 [@R-A030]。

多模态组合的输入是文本、图像、掩码、边界帧或参考视频；机制是将敏感意图分散到多个单独看似正常的模态中，由生成器在联合嵌入或时间补全中重建整体意图；输出是在空间或时间上显现的目标内容。Two Frames Matter 中，安全问题正是边界帧与中间轨迹的差距 [@LN05]。本综述仅保留该机制的审核启示，不提供任何实际边界帧或有害提示。

概念擦除绕过可以从 I3 或 I4 开始。如果攻击者仅通过同义、学习式嵌入、图像条件或组合提示恢复被擦除概念，首破是 I3；如果攻击者重新微调或改写权重恢复概念，则归 I4。这一分界防止把“条件空间未覆盖”与“参数更新可逆”混为同一失效。

05.E3.3 传播路径、代表工作与反例 I3 的传播是条件 □ 输入审核 □ 编码表示 □ 生成中状态 □ 输出审核 □ 交付 □ I7 传播。这条链上任何一层的局部成功都不可替代端到端结论。SneakyPrompt 代表黑盒文本变体搜索，MMA-Diffusion 代表文本—图像联合条件，Jailbreaking the T2V Models 代表针对视频生成的优化式提示，TEAR 代表时序感知自动红队测试，Two Frames Matter 代表边界帧与轨迹补全 [@R-A023] [@LN04] [@LN05]。这些工作的评测对象、判定器、模型版本和攻击预算不同，因此本文不将其 ASR 合并或排序。

三个防守反例需特别强调。第一，词表拦截只覆盖字面表达，不覆盖嵌入语义、图像条件或时间组合。第二，输出图像审核不会自动检查视频事件，抽帧尤其可能遗漏短暂或延迟载荷。第三，在一组直接提示上不再生成某概念，不能证明该概念从文本、图像、潜变量和事件条件中都不可恢复。

05.E3.4 评测、成本、正常效用与失败条件 I3 评测必须拆分四个分母：条件是否通过预审核；生成是否完成且语义保留；输出是否被判定为有害；系统是否实际交付给用户。文本到视频还需报告帧、片段、事件和整视频四级判定，以及自动判定与人工复核的一致性。T2VSafetyBench 明确要求基于生成视频而非原始提示评估，同时将自动与人工判定分开报告 [@P034]。

攻击成本应至少包括查询数、代理模型训练成本、每个成功样本的生成数、人工筛选时间与失败请求。防御成本应包括多模态预审核延迟、生成中检查开销、输出审核延迟、人工复核负担和清洁内容过拒。攻击失败条件包括目标版本更新、代理迁移失效、查询关联和预算限制、联合意图检测、生成中能力门、输出片段审核，或生成结果未保留攻击目标语义。

05.E3.5 视频差异与分层防御入口 视频 I3 的核心不是提示更长，而是条件与输出的时间关系。敏感行为可以在多帧累积后成立，字符或图案可以被分散在不同帧，人物身份可在镜头切换中重建，起始与结束帧之间的轨迹可以由模型自主补全，音频可以为画面提供单独看不出的身份或语义。这意味着安全评测需要事件边界、身份轨迹、动作顺序、镜头和音画同步，不应用随机若干帧的平均分数代替。

分层防御的第一层在输入前，对文本、图像、音频和控制信号做联合意图理解，并将敏感能力与主体授权绑定。第二层在生成前或中间，预测可能的动作轨迹、检查中间潜表示或对高风险任务降级规格。第三层在输出，以滑动窗和完整事件做审核，同时检查音画。第四层在会话与租户，关联多轮变体、限制查询和中间结果泄漏。第五层在平台，保留审计日志、举报和申诉。T2VShield 的分层防御框架与其音画一致性评估可作为工程参考，但其作者协议不能自动转成商业平台现场有效性 [@R-A024]。

05.E4 证据展开：I4：训练、微调、个性化与安全对齐攻击

05.E4.1 安全合同、资产与攻击者权限 I4 的安全合同是：训练或更新过程只能按照声明的数据、目标、权限与变更范围修改模型，更新后的异常行为、正常能力和可撤回性应可追踪。受保护资产包括基座能力、安全对齐、概念擦除状态、个性化主体身份、风格边界、训练日志、优化器状态和版本谱系。这里的首破点是“参数更新过程”，与 I1 的数据入口、I2 的制品加载和 I3 的推理条件不同。相同的有害结果若由污染样本进入一次集中预训练造成，首破是 I1；若由已经制作好的恶意 LoRA 被加载造成，首破是 I2；只有当攻击者能够控制训练目标、样本配比、更新策略或个性化会话时，才归为 I4。

攻击者权限可分为四级。最低一级是普通用户能够调用托管个性化或主体驱动微调服务，并上传少量获授权或未获授权的样本；第二级是能影响训练集和标签、但不能改训练代码的数据贡献者；第三级是能配置损失、冻结层、训练轮次和安全正则的内部开发者；第四级是能修改训练代码、优化器与检查点的白盒主体。预算不只以 GPU 时间表示，还包括可提交的更新次数、每次可见的验证反馈、模型版本存续时间和绕过审查所需的人力。持续时间则应从上传开始，覆盖训练、部署、传播、撤回和缓存失效，而不是只记一次训练墙钟时间。

05.E4.2 输入—机制—输出：后门、安全恢复与再学习 训练后门的输入是带条件关联的样本、损失项或参数更新；操作位置在去噪器、条件编码器或两者的联合优化；目标是让特定条件与异常输出形成稳定映射，同时维持清洁输入上的表面效用；输出是一个在常规验证集上可能正常、在特定条件下异常的模型。How to Backdoor Diffusion Models、TrojDiff 和 BadT2I 分别展示了扩散模型后门的不同目标与威胁设定，但它们的训练配置、目标类型、数据和判定器并不等价，故不能将论文中的攻击成功率合并成一个“扩散后门强度”[@P001] [@P002] [@R-A003]。

安全微调恢复或擦除再学习的输入可以是原始或代理概念样本，机制是利用参数空间中仍保留的表示、邻近概念或可塑层，使被压低的能力重新可达；输出是更新后的模型恢复原本受到限制的概念或行为。判定“擦除被攻破”至少需要三个对照：更新前在明确评测集上确实不可生成；相同预算的清洁微调不导致相同恢复；恢复不是判定器波动或提示改写造成。若缺少第一项，就无法区分擦除本来不完整与后续再学习；若缺少清洁对照，就无法将恢复归因于恶意目标而非一般灾难性遗忘。

个性化与主体驱动更新的输入是人物、产品或风格样本及主体标识，机制是在少样本下建立新标识与视觉身份的关联；输出是可按提示合成该主体的新图像或视频。其双重风险在于，一方面未经授权的身份或风格可被吸收，另一方面防守者为保护主体加入的扰动也可能被预处理、更多清洁样本或不同基座削弱。Anti-DreamBooth 的实验说明必须同时看攻击后相似度、保护图可用性和跨设置稳健性，而不是把单一相似度下降直接写成永久保护 [@P020]。

05.E4.3 传播、代表工作、迁移与反例 I4 的传播链为数据或更新配置 □ 梯度与优化器状态 □ 检查点 □ 部署别名 □ 下游蒸馏、量化或 LoRA□ 用户输出 □ 平台传播。训练后异常一旦进入“最新”别名，可能被继承到多个地区、产品与下游适配器；反过来，即便主版本撤回，边缘缓存、用户下载和衍生权重仍可能保留。因而撤回不是把网页链接删除，而是需要不可变版本号、依赖图、失效列表和下游通知。

BadVideo 将后门威胁直接推进到文本到视频模型，并报告其指定设置下的后门行为、正常质量与适应性防御 [@P007]。这项证据支持“时间生成模型可在训练更新处被植入条件异常”，但不能据此断言所有架构、商业模型或运动模块都同等脆弱。图像后门常以单张目标内容或风格为输出；视频后门则可能作用于主体、动作、镜头、时序位置或连续轨迹。只有当评测覆盖完整片段、动作顺序和时间定位时，才能称为视频级后门。

三个反例限定外推。其一，白盒训练攻击在只提供黑盒推理 API 的服务上并不成立；用户可调用个性化并不等于能修改基座。其二，后门在某一文本编码器、分词器或噪声调度器上有效，不代表经过模型升级、合并或量化仍可迁移。其三，正常画质保持不等于正常效用保持，语义遵循、身份一致、运动自然、跨语言提示与安全拒绝均需独立测量。

05.E4.4 数据、指标、成本与失败条件 I4 最小评测单元是“基座版本—初始安全状态—更新数据—更新配置—更新后检查点—输入/种子集”。后门评测需分别报告条件命中、目标语义、清洁语义、清洁视觉质量、异常溢出、跨种子稳定性与检测器误差。再学习评测需报告更新前后同一概念集、邻近概念、正常概念和人工复核。个性化评测还需报告主体相似、背景泄漏、姿态与风格多样性、训练样本近复制、未授权身份混淆和删除请求后的残留。

成本应包括样本获取与授权状态、训练 GPU/时长、超参数搜索次数、可访问层、可观察反馈、模型存储与撤回成本。不同论文只要任一项不同，成功比例就没有共同分母。攻击失败条件包括训练样本被隔离、更新只作用于受限适配器、关键层被冻结、安全正则或回放数据压制异常关联、独立验证发现清洁溢出、版本变更使条件失效、或者部署系统拒绝未签名检查点。防守失败条件则包括验证集没有覆盖隐藏条件、只测画质、训练日志不可追溯、或撤回未覆盖衍生制品。

05.E4.5 视频新增状态与防御入口 视频 I4 增加了时间注意力、运动先验、相机控制、帧间缓存、音频分支和长片段课程等可更新状态。一次更新可能在单帧上看似无害，却改变动作方向、事件先后、身份在镜头间的持续性或音画同步。因此应把空间清洁效用和时间清洁效用拆开：前者检查帧质量与主体外观，后者检查轨迹、动作、镜头、闪烁、口型和完整事件。BadVideo 提供后门视频证据，但“恶意运动模块与角色 LoRA 组合”“音频分支条件后门”和长时序潜伏触发仍缺少同等质量的一手实证，应保留为开放缺口 [@P007]。

防御入口依次是：训练前验证数据与授权；训练中限制可更新层、记录样本—梯度—版本谱系并监测异常关联；训练后用独立、保密且分层的触发探针检查空间和时间行为；部署时执行签名、灰度发布与版本锁定；事后保留撤回、回滚、衍生制品追踪和用户通知。任何“已对齐”声明都应绑定到具体检查点和评测日期，不能随模型继续微调而永久继承。

05.E5 证据展开：I5：采样、潜空间、隐私提取、缓存与服务可用性

05.E5.1 安全合同、资产和访问模型 I5 承诺推理运行时不会因查询暴露训练样本、成员或模型秘密，不会跨用户复用不应共享的状态，也不会被低成本输入系统性放大为失控的计算、排队或账单压力。受保护资产包括训练图像与视频、身份属性、提示与参考素材、随机种子、潜变量、中间缓存、租户边界、模型 API、吞吐、延迟、GPU 容量与成本预算。缓存是隐私与可用性的交叉点：它既可能让输入相似性泄漏，也可能被构造为大量无效命中或失效，从而破坏质量或资源分配。

攻击者通常只需黑盒查询，但能力层级差异很大：匿名单请求、持账户的多请求、可观察延迟或缓存命中的灰盒用户、能读潜变量和梯度的白盒用户，以及掌握多个租户或模型端点的协调主体。必须记录速率限制、计费、输出分辨率、片段长度、种子控制、返回的中间状态和失败消息，因为它们共同决定攻击预算与可观察信号。

05.E5.2 输入—机制—输出：记忆提取、推断与重复输出 训练数据提取的输入是一组候选条件或查询，机制是利用生成模型对高重复、易记忆或特定训练实例形成的异常高概率重现；输出是与训练样本近似或可识别对应的媒体。Extracting Training Data from Diffusion Models 在明确威胁模型下展示了图像扩散模型的训练样本提取，并讨论数据重复与去重 [@P024]。这一结果不等于任意单次相似输出都来自训练集：确证需要来源样本、近重复检索、成员/非成员对照、人工核查和生成预算。

视频隐私不能只用整段文件哈希判断。Investigating Memorization in Video Diffusion Models 区分内容记忆和运动记忆，并以帧、片段与运动层证据分析视频扩散模型 [@A047]。因此输出可泄漏静态身份或场景，也可能泄漏一段可识别动作。一个视频若只在少数帧接近训练片段，整视频平均距离可能掩盖泄漏；反之，常见动作相似也不必然证明训练成员关系。最低证据链必须把候选训练片段、去重状态、相似性阈值、人工复核和非成员基线放在一起。

成员或属性推断的输出是对“某样本是否参加训练”或敏感属性的估计，而不是媒体本身。模型提取的输出则是足以模仿目标模型行为的代理。三者需要不同分母：训练数据提取按独立训练实例计，成员推断按成员/非成员样本计，模型提取按查询预算和保真任务计。把它们统一写成“隐私攻击成功率”会丢失实际风险。

05.E5.3 缓存、随机性、计算放大与 DoS 证据边界 近似缓存以输入或中间表示的相似度决定复用结果，目标是降低扩散推理成本。Attacks on Approximate Caches in Text-to-Image Diffusion Models 证明缓存匹配边界本身可以成为攻击面：攻击者可使不应复用的请求被错误复用，或使应命中的请求失配，并由此影响输出正确性、延迟与成本 [@P039]。其结论适用于论文所述缓存设计和威胁模型，不能扩大成“所有图像/视频生成服务均已被拒绝服务攻破”。

关于生成式图像或视频服务的输入诱导计算放大、排队饥饿和账单耗尽，本轮定向检索没有找到足够具体且经同行评审的一手实证，能够同时报告服务架构、攻击预算、请求分布、资源曲线、正常租户影响和适应性资源防御。因而本文不借用语言模型 DoS 数字，也不把云服务一般性公告改写成视觉生成复现。现阶段只能给出待验证命题：分辨率、帧数、采样步数、控制分支、重试和并发可能共同决定资源占用；是否可被不对称放大必须在受控环境中测量。

合格的可用性实验应定义每请求合法上限，按请求和租户记录 GPU 时间、显存峰值、排队时延、取消后的资源释放、缓存命中、失败重试、成本与正常请求完成率；设置等量正常工作负载、同计费预算对照和自适应限流；并报告防守前后清洁质量与吞吐。为避免降低现实滥用门槛，本文不提供构造高耗请求的具体载荷、并发参数、阈值探测或绕过步骤。

05.E5.4 传播、评测、成本与失败条件 I5 的传播链可以是查询 □ 条件编码 □ 随机采样/潜状态 □ 缓存与调度 □ 输出 □ 相似性比对 □ 隐私后果，也可以是查询 □ 资源估计错误 □ 队列与 GPU 占用 □ 同租户或跨租户延迟 □ 服务降级。提取攻击的后果需经过身份确认或来源对应才进入 I7 现实伤害；仅生成一张相似图不是受害者已经受损的证据。缓存异常也需区分质量错误、隐私泄漏和资源损耗，三者不能互相替代。

评测必须保留独立分母和置信不确定性。提取侧记录独立训练实例数、每实例查询预算、近重复候选数、人工确认数、数据重复程度和非成员误报；缓存侧记录真正/错误命中与失配、输出效用、延迟、计算和租户影响；可用性侧记录吞吐、尾延迟、GPU 时间、取消释放、成本和服务等级。成本包含查询费、账户数、搜索时间、候选筛选和外部数据访问。攻击失败条件包括训练数据去重、隐私过滤、输出近重复阻断、随机性与速率限制、缓存键纳入安全关键上下文、租户隔离、资源预估与硬配额、取消可抢占，以及反馈不足以支持自适应搜索。

05.E5.5 视频差异与防御入口 视频将 I5 从单次采样扩展为长时运行状态。帧数、分辨率、运动分支、条件窗口、跨帧注意力、解码、插帧、音频和后处理共同消费资源；流式系统还会保留 KV、潜变量或用户会话缓存。隐私上，同一身份可跨镜头出现，训练片段可被重新剪辑，运动记忆可在外观变化后保留，音频还可能泄漏说话人。因此去重、近重复阻断和租户缓存隔离都必须在帧、片段、整视频、运动和音频多层执行 [@A047]。

防御入口包括：训练前去重与敏感身份过滤；推理前按租户和任务估算资源并实施帧数、时长和并发预算；推理中做可抢占调度、超时、取消释放和缓存命中审计；输出端做训练集近重复检索和身份/运动复核；平台端监测账户关联、异常查询与跨租户

时延。剩余风险是相似性阈值会在隐私保护与合法创作之间产生误报，严格缓存隔离会损失效率，长视频的多级检索成本又可能接近生成成本。任何防御结论都应同时报告正常用户延迟、质量和费用。

05.E6 证据展开：I6：检测、水印、来源证明与归属规避

05.E6.1 安全合同、资产与攻击者能力 I6 的安全合同不是“所有合成内容都能被一个分类器永久识别”，而是检测、嵌入、签名、凭证、验证和显示各环节在声明条件下保持可测的真实性信号，并对不确定结果作合适解释。受保护资产包括水印有效载荷与密钥、检测器决策边界、来源凭证、创作与编辑历史、内容—主体归属、平台标签以及公众对证据含义的正确理解。I6 首破发生在真实性信号本身：合成内容被误判为真实、真实内容被误判为合成、水印被移除或伪造、凭证被剥离或绑定到错误内容、验证器或 UI 将状态错误呈现。

攻击者可只拥有最终媒体和公共检测 API，也可能知道算法、持有生成模型、控制编辑链或接触签名密钥。能力必须拆成黑盒查询、灰盒算法知识、白盒模型/梯度、密钥持有和平台权限五级。裁剪、转码、压缩、再拍摄与常规编辑可能在无恶意意图下破坏信号；有意规避则会根据反馈自适应。两者在技术测试中都应覆盖，但现实归因不能仅凭媒体经过处理就推断恶意。

05.E6.2 输入—机制—输出：检测规避、水印移除与伪造 检测规避的输入是生成或编辑后的媒体，机制是利用训练分布、生成器版本、后处理和真实采集链之间的域偏移，使判定器不再稳定；输出是假阴性或假阳性。DIRE 与 GenImage 提供了图像生成检测的代表性方法和跨生成器评测，但其表格结果绑定到具体训练/测试划分与生成器，不能直接外推到后来的视频模型、屏幕录制或平台转码 [@R-A016] [@R-A017]。低基率部署还会放大假阳性的社会成本，因此准确率不足以描述平台性能，必须报告灵敏度、特异度、阳性预测值、阈值与真实流量基率。

水印移除的输入是带标记内容，机制是通过失真、编辑或生成式重建削弱检测统计；输出是感知内容仍可用而水印不可检或有效载荷错误。水印伪造则试图让未授权内容通过检测、指向错误来源或携带错误身份。Stable Signature 与 Tree-Ring 分别把信号根植于生成过程的不同位置，并报告特定变换下的稳健性 [@P028] [@P029]；Invisible Image Watermarks Are Provably Removable Using Generative AI 给出生成式移除的理论与实验边界 [@P031]；WAVES 则把多种水印和处理放入共同基准，但依然不能代表开放世界所有攻击 [@P030]。这些结果说明“不可见且对若干变换稳健”不等于“不可移除、不可伪造或可作唯一归因证据”。

来源证明的输入是媒体、声明、哈希或感知绑定、证书链与动作记录，机制是在签名验证、内容绑定和信任列表中建立“谁在何时用什么工具做了什么”的证据；输出是有效、无效、未知或部分可验证状态。C2PA 2.4 明确区分声明、硬/软绑定和验证过程 [@O001]。凭证缺失只能表示链条不可用或未提供，不能自动证明内容为假；凭证有效则说明签名和绑定验证通过，也不自动证明媒体中每项叙事为真、主体已同意或使用目的合法。

05.E6.3 传播、归属错误与评测合同 I6 的传播链为生成/采集 → 标记或签名 → 编辑 → 导出 → 平台转码 → 下载/截图 → 再上传 → 验证器 → UI 标签 → 用户决策。信号可能在每次派生时减弱，凭证可能与媒体分离，平台 UI 也可能把“未验证”误写成“AI 生成”。错误归属随后进入 I7：创作者被误指控、真实事件被否认、受害者申诉被延迟，或伪造媒体借“无水印”获得不当可信度。NIST 的合成内容透明度报告把检测、水印、来源与人类/组织过程视为互补工具，而非单一万能判定 [@O005]。

评测必须对应攻击者知识与媒体生命周期。检测器需报告已见/未见生成器、编辑和采集设备、平台转码、跨域与低基率；水印需报告嵌入容量、感知质量、鲁棒性、误检、伪造、密钥管理、定位和开销；来源证明需报告签名有效性、绑定在裁剪/重编码后的状态、凭证保留率、撤销与 UI 理解。WAVES 的知识假设表和变换矩阵可用作水印测试结构，但不能与检测器准确率合成单一分数 [@P030]。

成本至少包括攻击处理时间、查询次数、模型和算力、内容质量损失、人工筛选；防御成本包括嵌入/验证延迟、存储、密钥轮换、证书和撤销、平台集成、人工申诉。失败条件包括攻击使内容不可用、无法转移到未知标记、密钥和验证 API 不可访问、来源链保留且平台拒绝无凭证内容，或多信号联合仍能识别异常。防守失败则包括只测试单次压缩、用已知生成器训练测试、忽视真内容误报、把凭证缺失等同伪造，或平台再上传时丢弃元数据。

05.E6.4 视频水印、音画检测与时间定位 视频的 I6 状态包括逐帧信号、跨帧传播、镜头切换、局部裁剪、帧率变化、插帧、删除帧、音轨替换和平台分段编码。逐帧图像水印即使每帧可检，也可能在视频中闪烁、积累可见伪影，或被时间变换破坏。VideoShield 研究扩散视频水印的空间与时间定位，VideoSeal 研究开放式视频水印与时间传播；它们为视频专用评测提供了实证，但结论仍绑定到具体模型、变换集合和视频长度 [@R-A020] [@P033]。

视频检测也不应只把帧分数平均。短暂伪造可能仅在一个动作转折或数帧口型中出现，平均会稀释；连续背景瑕疵则会造成高度相关的重复证据，不能把每帧当独立样本。AVFF 从音频与视觉特征融合检测视频深伪，提示音画不一致是一类有用信号，但跨数据集结果同时提醒域迁移的限制 [@LN02]。音画一致不能单独证明真实：同步生成或后期配音可同时改变两种模态；不一致也可能来自正常剪辑、网络延迟或无障碍配音。

最低视频评测单元应包含帧、连续窗口、镜头、整段视频和音画事件，报告定位误差、最短可检持续时间、跨镜头与平台转码后的性能、真视频误报和长视频计算开销。对实时流还需报告检测延迟与撤回窗口，因为事后准确识别并不能消除已经完成的直播传播。

05.E6.5 分层防御入口与剩余风险 I6 防御应采用多信号证据栈：生成端嵌入模型或内容水印并签发来源凭证；编辑端记录允许的动作与派生关系；平台上传端同时验证凭证、检测水印、运行内容与身份审核；展示端区分“已验证来源”“检测为合成”“未能验证”和“内容违规”；事件响应端支持撤销、申诉与证据保全。欧盟《人工智能法》第 50 条、中国《人工智能生成合成内容标识办法》分别提出透明度或显式/隐式标识与传播环节义务，但法律义务不能替代技术鲁棒性测试 [@O006] [@O009]。

剩余风险包括开源或离线生成不嵌入信号、合法编辑使凭证失效、密钥泄漏、验证器和信任列表版本漂移、跨平台元数据丢失、低基率误报与公众误解。正确表述应是“多信号提高可追踪性并缩小否认空间”，而不是“有水印即可证明真实性”。

05.E7 证据展开：I7：身份、版权、诈骗、政治传播与平台滥用

05.E7.1 安全合同、现实资产与因果证据链 I7 是媒体从生成系统进入现实组织和平台的接口。其安全合同是：内容的制作、标识、上传、推荐、变现、举报、处置与救济不应无授权地损害身份、隐私、财产、版权、公共讨论或人身安全。受保护资产包括个人肖像与声音、同意和尊严、未成年人安全、作者与权利人的作品、账户和资金、选举与公共信息生态、平台信任及调查证据。

I7 与前六类的关键区别是结果不能由模型能力直接推出。严谨证据链至少包含：模型或编辑工具能产生相应媒体；攻击者实际制作并取得可用输出；媒体被上传或发送；平台分发或目标接触；受众产生认知或行为反应；财务、名誉、心理、隐私或公共后果发生。任一中间环节缺失时，应写为能力、暴露、传播或潜在风险，而不是既成伤害。NIST 对合成内容风险的梳理同样强调技术信号需放在具体用例和组织流程中评估 [@O005]。

05.E7.2 身份冒充、非自愿内容与未成年人风险 身份攻击的输入可以是参考图、公开视频、声音或公开人物素材，机制是身份条件化、换脸、口型与声音合成，输出是可被误认为目标主体参与的媒体。风险强度不仅取决于视觉相似，还取决于姓名、账户、上下文、受众关系和传播话术。未经授权的亲密影像属于高危场景，其伤害即使受众知道内容为假也可能成立，因为侵害对象包含尊严、隐私和持续骚扰，而非只有受骗。

SafeSora 将文本到视频安全对齐建立在人类偏好数据上，并公开其数据与模型限制，为模型层风险分类提供了证据 [@LA18]。Sora 2 System Card 描述了产品层的安全栈、肖像与来源措施及持续部署评估 [@R-A035]。这两类材料分别反映研究基准与特定产品自述，均不能单独证明真实平台事件率；系统卡尤其需要与独立测试、申诉数据和部署时间对应。

未成年人风险要求年龄不确定时采用更谨慎的权限和处置策略，但不能通过模型自动判断外貌年龄就完成法律归类。美国 TAKE IT DOWN Act 对非自愿亲密视觉描绘及通知移除流程给出法定定义和时限 [@O014]。本文只将其作为美国联邦法律的一手文本，不外推到其他法域，也不把通知删除等同源文件、缓存和跨平台副本全部消失。

05.E7.3 版权、风格、记忆与授权边界 版权与风格风险横跨 I1、I4、I5 和 I7：训练数据授权在 I1，个性化或再学习在 I4，训练实例提取在 I5，发布、商业利用与权利救济在 I7。风格相似、训练成员、作品近复制和法律侵权是四个不同命题。Glaze 与 Nightshade 分别以艺术家保护和提示特定投毒为目标，说明创作者技术反制的动机与机制，但论文实验不裁判具体法域的版权结论 [@P019] [@P005]。训练数据提取则能为记忆风险提供技术证据，仍需来源、授权和法律要件才能进入个案判断 [@P024]。

评测应把主体或作品的独立数量作为分母，记录授权状态、训练集出现频率、近重复程度、提示与种子预算、输出相似性、人工权利人核查、发布范围和经济使用。只展示一个高度相似样本会受到选择偏差；只报告感知距离不能区分受保护表达、一般题材和共同风格。防御入口包括许可与撤回台账、来源可追踪、训练与输出近重复阻断、个性化授权、权利人通知、下架与争议保全。

05.E7.4 诈骗、政治传播与平台放大 诈骗链通常把合成媒体与社会工程、账户接管、支付请求和时间压力结合。模型只提供可信外观或声音，资金损失还依赖渠道、身份验证和受害者决策。因此评测不应把“人类在实验中认为视频真实”直接换算成诈骗成功率。更可执行的防线位于高风险操作：独立回拨、双人审批、交易延时、账户异常检测和证据保存，而非只要求普通用户凭肉眼识别。

政治传播同样需要分开内容生成、投放、推荐、跨平台搬运、受众暴露、认知变化和投票行为。深伪检测、水印或标签可以帮助披露来源，却可能因错误标签反向削弱真实证据。欧盟与中国的透明度/标识规则为部署治理提供制度边界 [@O006] [@O009]；但是否降低特定选举中的错误信念，需要平台与受众层研究，不能从条文或模型基准推断。

平台放大使同一媒体在下载、截屏、剪辑、配音和再上传后脱离原始凭证。平台应记录首次上传、派生关系、标签变更、推荐曝光、举报、处置与申诉，而非只统计删除条数。删除率没有统一风险分母：一个高曝光事件与大量零曝光上传不可简单等权；举报量也受可见度、用户构成和界面影响。

05.E7.5 评测、成本、失败条件与平台防御 I7 最小评测单元随后果变化：身份冒充按独立身份与受众任务；非自愿内容按事件、受害者和副本；版权按独立作品/权利主张；诈骗按独立接触或交易；政治传播按内容、曝光和受众。必须报告平台、地区、时间窗、可见度、标签状态、受众基线与人工复核。不同来源的投诉率、识别率、检测率和实验说服率不能汇总为“现实危害百分比”。

攻击成本包括获取身份素材、媒体制作与筛选、账户或渠道、投放、维持可信上下文和逃避处置；防御成本包括审核、人工复核、受害者支持、证据保全、跨平台哈希共享、申诉与误伤。攻击失败条件可能是身份授权门、输出审核、来源凭证、平台传播限制、支付与账户验证、受众回拨或快速通知删除。防守失败包括只删单一 URL、缺少相似副本搜索、处置延迟、对多语言和小群体误判、或未保留司法与申诉证据。

平台防御应按制作、上传、推荐、交易和救济分层：高风险身份生成需要授权；上传时验证来源并做多模态审核；推荐时把不确定或争议内容与规模化曝光隔离；交易与官方沟通使用独立身份认证；举报后快速冻结传播、搜索派生副本、通知受害者并保留申诉。剩余风险来自私域通信、跨境平台、开源离线生成、标签疲劳和对真实内容的“骗子红利”。

表：七接口攻击族的统一比较

接口	攻击族	受保护资产	所需访问	评价单位
I1	概念定向数据投毒	语料完整性与概念语义	能将少量样本送入后续抓取或训练集	概念—提示—生成样本
I1	未授权风格、身份训练	同意、版权与主体特征	能抓取公开图像或上传他人图像	主体、风格和查询组
I1	训练语料近重复与隐私根因	训练个体的机密性	上游数据收集或训练管线权限	训练样本、身份、视频片段
I2	文本编码器或解码器替换	模型制品完整性	能上传或置换模型组件	组件版本和行为探针集
I2	LoRA、插件适配器后门	可组合参数与用户信任	可发布独立适配器	基座—适配器—触发三元组
I2	多组件组合触发	整体管线行为	分别控制或影响若干良性外观组件	组合矩阵而非单一模块

注：数据源为 `paper/tables/attack_comparison.csv`；正文显示 6/22 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

6. 跨接口纵深防御：组合、信任根与失效传播

6.1 七接口与五防御域的交叉映射

本文把防御归入五个域：数据与供应链、训练与条件、推理与资源、真实性基础设施、平台治理与救济。它们与 I1—I7 是交叉关系，而非七组互斥工具：数据域优先保护 I1/I2，训练与条件域优先保护 I3/I4，运行时域优先保护 I5，真实性域优先保护 I6，平台域优先保护 I7；同时每个域都可能截断上游失效的后续传播。矩阵中的“覆盖”只表示控制有相应入口，不表示在相同协议下经过了生产验证。

组合时先为每个风险选择一个最早控制，再增加独立失效模式的纵深层。例如，未授权主体素材首先由 I1 授权账本中断，I4 同意令牌控制个性化更新，I7 身份核验和副本处置限制现实传播；三者不应被加总为“三次成功”。相反，若上游没有数据身份，后续检查即使拦住一个输出也不能纠正训练来源。本文综合据此记录“受保护合同—执行主体—输入证据—正常效用—撤销动作—残余传播”，不提出普适最小集或统一最优组合。

6.2 数据、制品、参数与运行时信任根

信任根不是风险模型给出的高分，而是能够稳定回答“谁批准了什么对象、哪一版本在何处运行”的身份与状态。数据层依赖来源记录、授权主体和不可变清单；制品层依赖字节摘要、签名主体、透明记录与依赖图；参数层依赖训练编排身份、签名代码/数据清单、作业日志和独立评测集；运行时依赖租户绑定、策略发布签名、只追加日志及受控密钥。异常检测、后门扫描和审核器是可更新证据源，不能反过来充当这些对象的根身份。

信任根也必须支持失陷语义。签名密钥泄漏时，要区分历史上带可信时间证据的对象、可能受影响的时间窗和新签名禁用；数据撤回时，要区分后续训练排除与历史模型未消除；策略回滚时，要定位使用旧阈值作出的案件。C2PA 规范与安全指南提供签

名、时间、撤销和信任锚的规范语义，但规范一致不等于业务事实真实或平台互操作 [@O001] [@O002]。缺少版本、时间和部署图时，所谓“撤销”最多是发布新状态，不能证明所有节点已停止信任。

6.3 真实性信号与平台行动的非替代关系

检测、水印、C2PA 与平台处置回答四类不同问题。检测是对现有媒体的统计推断，可覆盖不合作生成器，但受开集漂移和低基率误报影响；水印是在生成或编辑时嵌入的信号，证明的是相应检测合同下存在某信号，不直接证明事实或授权；C2PA 把签名声明、内容绑定与编辑关系组织成可验证来源链，凭证缺失不等于伪造，凭证有效也不等于叙事为真 [@O005] [@O001]。因此四者不能共用一个准确率，也不能用简单投票消解冲突。

平台行动是决策层：它把原始文件、检测、水印、凭证、身份、语境和政策证据转成标签、限制传播、人工复核、移除、申诉或恢复。平台厂商关于自动标签或信号来源的公告只能证明声明的产品接口；例如 YouTube、TikTok 和 Meta 的材料不提供跨平台准确率或申诉效果 [@O044] [@O045] [@O042]。若把检测分数直接升级为不可逆处置，会把统计误差变成账户、收入或表达损害；若把有效凭证当作免责，又会忽略恶意签名者、无授权使用和内容事实。正确组合是保留每个信号及版本，再由可重放案件记录作条件化行动。

6.4 撤回、版本、申诉与跨平台失效

撤回的对象和执行范围必须显式区分：数据记录可阻止后续训练，制品摘要可阻止受控节点新加载，检查点别名可回滚，水印或签名密钥可撤销信任，平台案件可恢复内容或收入。任何一种撤回都不会自动清除离线权重、用户下载、衍生媒体、CDN 副本和不参与平台。系统应保留对象标识、首次可能失效时间、处置时间、已确认节点和未覆盖范围，而不是以界面中的“已删除”概括全部状态。

申诉是防御正确性的一部分，而非检测后的行政附录。高后果行动需要可重放的原件摘要、解析器与模型版本、阈值、信任列表、政策条款和人工理由；规则或密钥纠正后，应能批量定位受影响案件并恢复。跨平台共享只能传递经签名、目的受限、带过期时间的事件证据，接收方仍需独立验证，防止误报随合作网络放大。32 项事件卡显示公开材料常缺生成器、初始账户、完整传播和申诉结果；因此跨平台处置只能陈述已观察动作，不能用下架数量推断风险降低幅度。

6.5 正常效用、成本、适应性绕过和拒绝门

每个组合控制都要同时报告正常效用与运行成本：数据筛查的长尾误删，制品准入的生态兼容，训练防御的保留能力，条件审核的合法误拒，缓存隔离的吞吐损失，水印的画质和时序影响，检测的低基率误报，以及平台行动的复核、申诉与受害者支持。适应性攻击会针对最弱依赖改变来源、组件组合、输入模态、媒体处理或传播渠道；因此“多层部署”只有在失效模式相对独立、证据被保留且处置可撤销时才增加防御价值。

拒绝门应由风险和证据缺口触发，而不是由某个排行榜阈值触发：无法确认制品身份时不进入生产；高风险主体缺少同意时不启用相应能力；多模态审核超时时高风险作业不静默放行；来源信号冲突时不自动作法律归因；无法保全高后果案件的申诉证据时不执行不可逆惩罚。开放权重、私域传播和跨境不合作使任何组合都有残余风险。故本章只给出“在这些依赖与成本下可组合”的逻辑，不声称存在对所有模型、模态、法域和平台均最优的最小防御集。

06.E1 证据展开：数据治理与组合供应链防御

> 证据截止日期：2026-08-09。本部分是分类型综述中的防御与部署章，不是异协议排行榜。“来源明确报告”“厂商部署声明”“本文跨来源综合”与“本地局部实验”分开表述。任何水印或检测的高 AUC，都不直接证明真实平台中的转码保留、低基率误报、人工复核、下架、防再上传和申诉已形成闭环。

06.E1.1 证据口径与通用控制卡 防御的结果不只是“挡住了多少攻击”。本部分对每类控制使用同一张控制卡：保护接口、受保护资产、威胁假设、控制机制、执行主体、训练/推理改动、正常效用、时延与资源、误报/漏报、密钥或信任根、适应性绕过、组合依赖、撤销/更新、平台保留、失败处置和残余风险。经验与实现证据按论文作者实验（AUTHOR_EVAL）、独立攻击/比较（INDEPENDENT_EVAL）、本地有边界实验（PARTIAL_RUN）、静态工程审计（STATIC_AUDIT_ONLY）、厂商公告/系统卡（VENDOR_CLAIM）和现实事件级处置（INCIDENT_OUTCOME）标注；标准、法规与服务说明另标为只支持规范语义（NORMATIVE_SEMANTICS_ONLY）或官方服务范围（OFFICIAL_SERVICE_SCOPE）。只有 INCIDENT_OUTCOME 能直接说明“从证据到处置”的特定现实链条，但它也不能反推算法的通用准确率；规范和厂商来源均不得升级为独立效果实测。

06.E1.2 从“文件可下载”到“运行时组合可信” 数据和供应链防御保护的不是一个文件夹，而是从数据候选、预处理、训练作业、基础权重、文本编码器、VAE、ControlNet、LoRA、运动模块、音频模型到推理容器的组合身份。威胁者可能只能公开发布少量图像，可能能发布一个签名但恶意的 LoRA，也可能获得仓库或训练作业权限。如果不先分层权限，“清洗数据”和“签名模型”就会被误写成互相替代的解决方案。

本章的最小安全合同是：（1）每个训练单元能回答来自哪里、是否授权、何时可撤回；（2）每个可执行或可加载制品有精确字节身份、发布主体和依赖图；（3）一个制品通过静态检查不代表它与其他组件合并后行为正常；（4）身份或密钥失陷后，可以停止新加载、找到已部署实例并回滚；（5）真实平台上的完整性证据不因缓存、量化、格式转换或镜像复制而静默漂移。

06.E1.3 许可、来源、去重与撤回账本 数据账本的第一件事不是给每张图生成一个“合法/非法”布尔值，而是保留来源 URL 或库标识、抓取时间、许可版本、主体/表演者同意范围、语料用途、地域、保留期、删除请求和后续派生作业。文件 SHA-256 适合确认字节级身份，但相同画面的缩放、截图和转码会改变它；感知指纹可以帮助找近重复，但有碰撞、阈值与对抗操纵风险。因而工程上应并存精确哈希、多种感知表示、语义嵌入和人工复核状态，不用一个相似度阈值承担授权判定。

近重复去除同时具有隐私和安全价值：它可减少训练集中的局部高频样本，并为记忆/提取审计提供候选。但去重策略可能误删正常的连拍、新闻系列、动画关键帧或少数群体的长尾表达；视频又必须区分字节重复、单帧重复、片段重复和事件/轨迹重复。效用报告应同时给出去除率、误删率、少数类覆盖、训练成本变化和后续记忆审计，而不是只说“数据更干净”。

撤回要从一张数据记录传播到数据分片、中间缓存、特征库、训练作业、检查点、微调制品和近重复输出缓存。若无法从已完成训练中低成本消除影响，系统应记录“已从后续训练排除，历史版本未消除”，并将更强的遗忘或重训练作为风险决策，不得用用户界面上的“已删除”掩盖模型版本仍在服务。

06.E1.4 投毒筛查、异常聚类与训练前隔离 Nightshade 类定向投毒说明，攻击者可以利用图像表示和描述之间的差异让少量样本进入大规模语料，因而简单的 URL 阻断或像素重复检测不够 [@P005]。可执行的数据网关应先做格式解码与恶意载荷扫描，再对图像—文本一致性、语义局部密度、来源集中度、类内近重复和与已知投毒策略的结构相似性进行多视角筛查。被标记样本进入不能执行外部代码、不直接进入生产训练的隔离区；对高风险来源按上传批次、时间窗和账户联系追踪，避免只在单样本上判断。

正常效用的主要代价是长尾数据损失、复核人力和训练延迟。误报是有特色的艺术风格、少数语言描述或新闻现场图被判为异常；漏报是自适应攻击者模拟正常来源、重描述或将毒性分散到多个账户。所以阈值不应永久固定：需保留筛查模型版本、人工翻案样本、后续训练异常和攻击簇并定期重校。信任根是数据集清单的不可篡改存储、审批身份和独立留存的样本哈希，不是异常检测器本身。

06.E1.5 个体保护、同意与“训练前摩擦”的上限 Glaze、Anti-DreamBooth 与 DiffusionGuard 以对抗扰动保护风格、主体个性化或图像编辑，证据属于特定模型、预处理链和攻击预算内的作者实验 [@P019] [@P020] [@P022]。它们的保护接口是训练或编辑输入，执行主体是内容拥有者或发布工具，优点是不要求改变攻击者的模型服务。代价是图像像素改动、处理时间、跨模型迁移不确定和对授权编辑的阻碍。LightShed 对这类扰动的检测/净化表明，攻击者可把保护机制本身作为学习目标 [@P023]。

因此这类方法应被定位为“训练前摩擦”，不是法律许可、数据删除或平台处置的替代。组合防御应把扰动、授权账本、身份验证、采集退出、个性化作业同意令牌和后续输出处置联系起来。请求撤回时，系统不能只删上传原图：还要禁用主体标识符、停止相关微调作业、下架 LoRA、更新近似匹配索引并保留可审计的处置原因。

视频保护还要考虑帧抽样、光流、编码和时序一致性。逐帧独立产生扰动可能造成肉眼可见的闪烁，也可能在视频压缩后被消弱；对一幅首帧有效不等于对整段图像到视频的身份沿用有效。评测分母必须同时有帧、片段、视频和主体四层，正常效用包含时序稳定、授权编辑成功和转码后观感。

06.E1.6 安全序列化、精确签名、SBOM 与受信仓库 模型权重文件是数据还是程序，取决于加载器。Python pickle 可在反序列化时执行代码；Hugging Face 的官方文档明确建议仅从可信主体加载、使用签名提交和 safetensors，并说明导入扫描是 best-effort、并非 100% 防护 [@O037]。PyTorch 自 2.6 起在调用方未传入 `pickle_module` 参数时，`torch.load` 默认使用 `weights_only=True`；它收窄动态导入和任意对象构造面，但官方文档仍列出拒绝服务、可能的内存破坏和下游恶意对象风险 [@PyTorchSerialization2026]。所以安全格式是去掉一类执行面，不是对权重行为的安全证明。

制品发布应绑定：不可变摘要、发布者身份、签名/时间戳、训练代码提交、基础模型 ID、数据清单版本、超参数、转换工具、量化参数、许可和已知风险。SBOM 不只列 Python 包，还要列文本编码器、VAE、ControlNet、LoRA、运动模块、调度器、自定义 CUDA/编译扩展和服务镜像。Sigstore/Cosign 等制品签名可将签名、短期证书和透明日志证明放入 bundle，

用于证明特定字节的发布链 [@SigstoreBlob2026]。但签名不证明签名者良性，也不证明 LoRA 与指定基础模型合并后没有触发器。

受信仓库需要做“准入—隔离—发布—撤销—溯源”全链：未签名或未登记制品不能进入生产；高风险格式在无网络、只读文件系统、低权限容器中解包；分析结果与制品摘要共同签名；被撤销版本无法被新作业引用；运行时遥测能回到具体制品图。误报是不常见但正常的自定义操作被拦截，漏报是恶意逻辑不在静态导入中暴露或制品本身只含行为后门。失败时应默认不加载而不是跳过检查，但也应提供带审批的隔离研究路径。

06.E1.7 组合行为差分：供应链防御的最后一公里 对可组合生成栈，真正的审计单位是“基础模型 + 文本编码器 + VAE + 控制/风格/主体 LoRA + 运动/音频模块 + 采样器 + 量化 + 运行时”的实例。测试分三层：单制品静态审计，二元/高风险组合的行为差分，以及生产运行时的漂移监测。行为差分固定提示集、负面提示、随机种子、采样步数和输出判定器，比较加载前后的拒绝、目标触发、正常任务、身份相似、内容策略和资源曲线。视频还要固定片长、帧率、运动条件、镜头脚本和音频，检查只在组合时出现的跨帧或音画触发。

组合空间不可能穷尽。因此要优先测试权限高、受欢迎、新上架、共享编码器或需执行自定义代码的制品，并使用覆盖阵列而不是随意选样。发布后的处置包括废弃摘要、更新组合允许列表、消除节点缓存、取消长作业、对已产生内容做风险通知，而不是只从下载页删除。如果签名密钥或仓库账号失陷，需将“身份仍为真”与“签名时刻已不可信”分开呈现，撤销结果应在离线节点刷新后才能完成闭环。

06.E1.8 本章综合：可接受的主张上限 数据账本能证明某笔记录的来源和处理状态，不能自动解决法律授权；签名和哈希能证明字节与签名主体，不能证明行为良性；安全格式能去除一部分反序列化执行面，不阻止模型后门；扰动式个体保护能提升特定攻击成本，不是永久撤回。综合而言，这一层的部署目标是让每个数据和制品有可追踪身份、最小权限、组合评测和可撤销去向，并把未覆盖的组合明确标为残余风险。

表：数据与供应链防御的条件和失败

控制	保护接口	执行主体	最低机制	主要失败条件
许可与来源账本	I1	数据治理、训练平台	记录来源、用途、撤回和派生作业	历史模型影响可能无法低成本消除
多表示去重与异常聚类	I1	数据入口	精确哈希 + 感知 + 语义 + 人工复核	长尾误删与自适应投毒
隔离解码与安全序列化	I2	制品入口	无网络低权限加载、安全格式	行为后门不依赖代码执行
签名、SBOM 与透明日志	I2	仓库、构建平台	绑定字节、主体、依赖与转换	签名者可恶意或密钥失陷
组合行为差分	I2、I4	发布门禁	固定条件比较组件加载前后	组合空间无法穷尽
同意令牌与撤回	I1、I4、I7	个性化产品	绑定主体、用途、期限与导出权限	已下载开放权重难以远程失效

注：数据源为 `paper/tables/data_supply_defense.csv`；正文显示 6/8 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

06.E2 证据展开：训练、安全对齐、概念擦除与个性化防御

06.E2.1 保护的是更新合同，而不是一次评测的模型印象 训练和对齐防御首先保护 I4：参数更新应由被授权的数据、代码、目标函数和操作主体产生，并在新的微调、合并、量化或采样器下保持预期的安全行为。威胁假设至少分为三档：开发者自己可控的数据/训练流被污染；第三方提供了表面正常的检查点或适配器；攻击者只在部署后使用提示、图像条件、学习嵌入或短时再微调来恢复被擦除能力。这三档对应可信训练、制品验收和自适应安全评测，任一层都不能独立覆盖其他层。

执行主体包括训练平台、模型安全团队、数据治理者、个性化产品所有者和独立红队。信任根是受保护的训练编排身份、已签名代码/数据清单、不可篡改的作业日志和独立保留的评测集。训练 loss 下降、干净样例观感正常或单一安全分数通过都不是完整性证据。正常效用要同时测提示遵循、主体一致、时序质量、安全内容的误拒和任务外性能。

06.E2.2 可信训练、后门扫描与参数回滚 后门防御不应只寻找一个已知像素触发器。BadDiffusion、TrojDiff 以及视频场景的 BadVideo 已将触发表示扩展到噪声分布、语义条件和时空元素，防御评测要按攻击者控制训练的程度、触发持久性和目标类型分层，而不合并异构 ASR [@P001] [@P002] [@P007]。训练前对数据批次、梯度异常、训练脚本与初始噪声进行身份检查；训练中监测局部类或提示的异常收敛、批次来源与模型差分；训练后在多采样器、多种子、多义表达、图像/潜空间条件与视频运动上搜索。

后门扫描的误报是调色、特殊艺术风格或罕见运动被判为触发，漏报是触发依赖同义词、多轮上下文、组件组合或延迟帧。运行开销可能是大量生成样本和多模态判定器，这会与生产时间表直接冲突。因此发布门禁应设定可追踪的最低覆盖率而不是一次性“已红队”标志。如果发现可重现触发，处置应包括冻结检查点、保全作业证据、阻止下游微调、追踪已部署版本、回滚并用新的攻击集复验。

06.E2.3 概念擦除与机器遗忘：“找不到”不是“不存在” ESD 和 Ablating Concepts 把概念控制部署在模型参数，AdvUnlearn 进一步将对抗条件纳入学习 [@P014] [@P015] [@P016]。这些工作支持“参数更新可降低特定协议中的概念可生成性”，但不支持“概念已从所有表示中永久删除”。检验必须同时包含擦除集和保留集，固定基础模型、概念定义、攻击预算和正常效用，并让攻击者使用别名、组合描述、多语言、图像条件、学习嵌入、潜变量和短时再微调。

误报是近邻合法概念或艺术史语义被连带压制，漏报是未见表示空间恢复目标。这种防御的“密钥”不是密码学密钥，而是概念定义、保留集、策略阈值和攻击套件；信任根是这些资产的版本与审批。更新机制应允许新增表达、回归旧攻击并将误伤概念加入保留集。若新攻击成功，不应立即声称模型“完全失守”；应定位失败表示、评估正常效用后重新擦除，并在修复前用推理层能力门和输出复核封住暴露面。

视频概念比单帧对象更难定义。“某人”可以由面孔、声音、动作与环境共同表示，“某事件”可能只在帧顺序上成立。如果训练只对单帧文本概念做擦除，不能声称已处理动作、镜头语义或音画身份。视频双重测试需要帧级内容保留、片段级事件拒绝、轨迹身份和音画一致四类分母。

06.E2.4 安全对齐、再对齐与自适应红队 对齐的目标是让模型和产品在有害条件下拒绝、安全转化或将请求交给更严格能力门，同时对正常创作保持可用。训练时可结合策略数据、对抗条件、保留/拒绝对和采样期安全目标；但输入审核、参数对齐与输出审核是三个不同控制位置。只用历史红队提示训练容易过拟合固定词表，因此发布前应分出未见攻击者，并显式允许黑盒、代理迁移、多模态和长上下文攻击。

高拒绝率可以来自系统真正识别有害意图，也可能只是过度拒绝了医学、新闻、艺术或少数语言。因此同一张表要报告：有害请求中的有效响应分母、有害输出、拒绝、正常请求误拒、边界请求成功和多语种/不同用户组。对视频还要报告产生一半才被拦截的 GPU 秒、最长漏检区间和首次告警时延。运行时若攻击簇迅速增长，应先收紧能力门、保留证据，再在离线修复参数；不应为追求上线速度直接用新对齐检查点覆盖可回滚版本。

06.E2.5 个性化的同意令牌、权限边界与撤回 个性化应把“拥有照片”与“获得模型建立/视频演绎权”分开。最小同意记录应指明主体、申请者、输入类型、允许用途、禁止主题、模态、地域、有效期、是否允许导出权重/视频和撤回窗口。平台在上传前完成身份核验，训练编排器仅接受与作业参数绑定的短期令牌，发布器检查导出权和到期时间，下游生成请求再核对主题范围。

撤回必须具有服务级语义。如果 LoRA 已导出到用户设备或开放仓库，中央平台无法让全部副本失效；它能做的是撤销受信状态、阻止再分发、向合作平台发风险信号、停止后续训练并对已知输出提供处置渠道。因此用户界面应显式告知“中央撤回不能擦除已下载副本”。这一残余风险是开放权重生态与闭源 API 之间的根本差异，不应被更精美的同意页面掩盖。

06.E2.6 本章综合：参数防御必须与运行时封锁互补

06.E3 证据展开：推理时条件审核、能力门与资源防御

06.E3.1 推理防御的系统边界和记账单位 推理层保护 I3 与 I5：条件不得越过策略/授权边界，租户不得读取或影响他人状态，一个请求不得无界放大 GPU、显存、队列和账单，输出不得未经最后审核直接进入分发。攻击者可能只能黑盒调用，但可以分布式发请求、观察拒绝或时延、反复试探边界；灰盒用户还可提供参考图、首尾帧、掩码、运动轨迹或自定义 LoRA。

记账单位不能只是单个 HTTP 请求。应建立“用户/租户—会话—作业—派生重试—输出—发布”链，并为每层记录实际消耗、政策版本、检查结果与处置。信任根是身份/租户绑定、策略发布签名和只追加审计日志；审核分数是证据，不是信任根。日志要有最小化和保留期，否则防止滥用的监控会变成提示、主体图像和生成结果的新隐私库。

06.E3.2 多模态规范化、语义审核和授权差分 第一道网关先解码和归一化：字符编码、同形异义字、隐藏 Unicode、文本 OCR、图像内容、掩码、姿态、深度、轨迹、音频转录和元数据要在同一请求对象中可见。然后分别做策略语义、身份/授权和技术安全检查。“描述某人”可能符合一般内容策略，但没有获得该人的个性化同意；“更换背景”可能本身正常，但掩码越过了授权编辑区域。因而一个统一有害分数无法代替这三种判断。

对语义审核的误报常见于否定、引述、教育、历史与少数语言；漏报来自同义替换、长上下文分散、文字与图像条件拆分、只在运动后形成的语义。SneakyPrompt、MMA-Diffusion 和概念检索类工作表明，固定词表或只审文字的控制存在可明确表述

的失败面 [@P008] [@P009]。防御更新应从翻案和绕过样本生成新语义测试，但不把具体恶意提示暴露给审核 API。高不确定性请求可转为需用户确认编辑范围、需更强身份核验或仅输出低风险草图，而不必只有“通过/拒绝”两种结果。

06.E3.3 能力门、查询关联与分层开放 能力门根据身份、年龄/组织、使用场景、主体同意、模态、分辨率、片长、上传输入、自定义制品和发布范围定义权限。例如，未验证用户可只使用短、低分辨率、不含真实人物上传的生成；已验证企业也不应默认获得他人肖像个性化或无限批量生成。Sora 2 系统卡所述的输入阻断、输出阻断、未成年人更严阈值、能力限制、举报和人工复核是厂商部署声明，可说明架构位置，不等于独立地证明各类攻击下的效果 [@O020]。

查询关联不只计数，还观察对同一目标的绕过收敛：连续的同义替换、参考图递进、掩码扩展、首尾帧建造和多账户分散。执行需要账户/设备/支付/组织等有限信号，因此必须定义目的限制、保留期和申诉。误报可能冻结正常反复创作，漏报可能来自分布式低速账户。高风险响应应从降低并发、延长冷却、禁止外部发布到暂停账户递进，并保留足以说明决策的记录。不能把检测阈值和账户关联特征全部回显给攻击者，但要向被处置用户告知策略类型、影响和申诉途径。

06.E3.4 采样期安全引导与输出片段复核 采样期安全引导能在不重训基础模型的情况下改变潜空间轨迹，而输出审核检查已形成的画面、动作、身份和音频。两者的差异决定了成本与失败模式：采样期引导每步都可能增加计算并伤害提示遵循，输出审核可能在高成本生成完成后才阻断。图像可以全图复核；视频需同时使用密集帧、滑动片段、镜头边界、身份轨迹和音画联合检查，否则延迟出现的载荷会落在抽帧空隙中。

评测不能只给帧级平均准确率。应报告片段级事件召回、最长漏检区间、首次告警时延、局部伪造定位、切镜后身份重识别、配音/网络延迟下的正常误报、GPU 秒与丢弃输出比例。对流式数字人，系统应有中断输出、降级成静态/无声模式、标记风险片段和保留有限证据的处置路径。如果多模态审核超时，高风险能力应 fail closed；低风险创作可以降级，但不应静默略过。

06.E3.5 租户隔离、缓存分区、预算与成本熔断 推理服务的安全属性包含机密性、完整性和可用性。近似缓存会用语义相似性复用中间状态，因而缓存键必须绑定租户、模型/适配器组合、安全策略、精度和输出范围；跨租户复用即使提升吞吐，也需要独立隐私和投毒威胁评估。命中信号和延迟可能泄露其他用户的提示分布，缓存内容也可能被毒化；缓存分区、来源绑定、命中信号平滑、短生命期和一键失效是镜像控制。

资源防御要同时设定提示/参考输入大小、分辨率、帧数、生成步数、控制分支数、并发、排队、重试和租户 GPU 秒/账单预算。熔断不只看 QPS：当单作业显存、队列头阻塞、重试放大或下游转码积压超阈时，可停止长视频、降低分辨率或将作业转离互动队列。误报是合法的长视频/批量工作流被限制，漏报是分布式低速作业或优惠/重试逻辑绕过计费。评测应与等资源正常重负载对照，报告 P50/P95/P99 时延、吞吐、峰值显存、GPU 秒、失败重试和单任务成本。目前生成专用 DoS 的高等级一手实证仍稀缺，因而这部分是威胁建模与最低部署契约，不宣称已证明某一最佳阈值。

06.E3.6 日志、撤回、申诉与残余风险 每个输出应能回答使用了哪个模型组合、哪版策略、哪些检查器和什么处置，但日志不应默认保留完整敏感提示、主体图片或被阻断的私密内容。可使用结构化策略标签、不可逆请求摘要、限时加密证据库和带审批的调取。规则、模型、检测器、信任列表和限额必须都有版本，可分批发布、快速撤回和完整回归。

误拦的用户需要可理解的原因类别和申诉通道；但系统不必泄露可直接用于绕过的模型分数和精确阈值。申诉结果应回流到误报集和策略校准，却不能把人工一次特例自动升格为全局允许。即使输入、采样和输出都审核，开放权重仍可在平台外绕过控制，闭源 API 也无法判断所有现实身份、同意和语境。因而本章输出是可更新的风险网关，而不是对有害生成能力的彻底消除。

表：训练、条件与推理防御的部署合同

控制	接口	部署时点	最低机制	残余风险
可信训练与作业签名	I4	训练前、中	代码数据清单、身份、批次追踪	不能证明无未知后门
后门扫描与发布回归	I4	训练后	多触发、多种子、多采样器	搜索覆盖不足与适应性触发
概念擦除 + 保留集	I4	训练、微调	擦除与正常效用双分母	别名、图像条件和再微调恢复
多模态输入规范化	I3	请求入口	文本、OCR、图像、轨迹、音频统一对象	长上下文和跨模态分散
身份、用途能力门	I3	入口与编排	同意、年龄、场景、片长、导出分层	跨账户与离线开放权重
采样期安全引导	I5	生成循环	按步约束潜空间并记录额外开销	质量下降和新表示绕过

注：数据源为 `paper/tables/training_condition_inference_defense.csv`；正文显示 6/9 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

06.E4 证据展开：检测、水印、指纹、签名与真实性基础设施

06.E4.1 真实性不是一个可由单模型输出的标量 “这是 AI 生成的吗”、“这个文件在签名后改过吗”、“这个画面与受害者提交的文件相同吗”、“这份来源声明由谁签发”和“画面中的事情真实发生过吗”是五个不同问题。前四个可由技术证据部分回答，最后一个需要与外部事实、取证、上下文和责任主体连接。NIST AI 100-4 将内容认证/来源、标记/水印、生成检测、源头防止和软件测试并列为不同技术路线，而非一个真假分数 [@O005]。C2PA 规范本身也强调，它不对来源数据是“好”还是“坏”做价值判断，而是让关联、格式、签名与篡改可被验证 [@O001]。

因此真实性基础设施应使用“多证据保留原则”：保留每个信号的原始结果、媒体版本、解码成功与否、阈值/信任列表版本、不确定性和冲突，再由策略层作出标签、限流、人工复核、下架或保留等决策。“未检出水印”不能改写成“非 AI”；“C2PA 签名有效”不能改写成“内容为真”；“检测器高分”不能改写成“由某用户使用某模型生成”。

06.E4.2 六种证据层的正式区分 ** 内容检测（detection）** 是对已有图像或视频计算生成/篡改可能性、局部伪造区域或生成器属性的统计推断。它不要求生成时注册或持有密钥，因此可以覆盖没有合作的生成器；但分布漂移、平台压缩、未见生成器、后期摄影和自适应扰动会使误报与漏报显著变化。GenImage 与 DeepfakeBench 的价值是把跨生成器、退化和统一预处理问题变成明确基准，不是证明任一检测器可直接开放世界部署 [@R-A017] [@P035]。

** 嵌入水印（watermark）** 是在生成、摄影或编辑时将信号加入像素、频域、潜空间、视频时空状态或音频中。其证据合同是“一个具有检测能力的系统在某类变换后找到某信号”，而不是对内容事实、身份授权或整条编辑史的证明。典型权衡是鲁棒性—不可感知性—载荷容量—嵌入/检测成本；密钥复用、检测 API 泄露和多样本共谋会引入新风险。

** 内容指纹（fingerprint/perceptual hash）** 从内容固有特征计算索引，不向像素额外嵌入信号。它适合查找已知文件的近重复、恢复丢失的来源声明、阻止已知 NCII/CSAM 再上传；但对全新生成的类似场景、大幅裁剪/重演、阈值边界与对抗碰撞有限。C2PA 2.4 将 fingerprint 定义为可识别内容或近重复的固有属性集，并将它与隐形水印一起归为 soft binding，但实施指南要求软绑定匹配经验证，不得替代 hard binding [@O001] [@C2PAGuidance24]。

** 精确哈希与数字签名（hash/signature）** 对字节串或按规范排除某些容器区域后的绑定计算摘要，再用私钥对声明签名。它对未授权篡改有强的可检测性，但普通重编码也会改变精确字节；信任取决于签名者身份、证书链、时间戳、撤销查询和私钥保护。签名者可以恶意，密钥可以被窃取，所以“签名有效”与“声明可信”必须分开。

C2PA/Content Credentials 是把资产内容绑定、签名声明、操作、成分关系、验证状态、证书信任和可选软绑定组成的来源协议。它不是水印算法，但可记录水印/指纹算法并通过仓库恢复被剥离的 manifest。它证明“声明与资产在指定信任模型下可验证”，不证明摄影场景、叙述或签名者所填字段为真。

平台标签与处置记录是策略层证据：标签可以来自用户披露、C2PA、厂商水印、内部检测或人工复核，处置可以是保留、限制推荐、增加语境、阻止变现、下架、防再上传或交给执法。这一层的效果必须用事件时间、触达、误处置、申诉和重复上传测量，不能用上游 AUC 代替。

06.E4.3 内容检测：开集、低基率和自适应攻击 检测器的最小评测合同包括真实媒体来源、已见/未见生成器、内容类型、解析度、编解码链、编辑、对抗预算、类别基率、阈值和人工翻案。论文内部平衡数据的 95% 准确率，在千分之一真实阳性的上传流中可能仍产生大量假阳性。因而平台应报告固定极低 FPR 下的 TPR、精确率/阳性预测值、不确定区间、不可判定比例和人工复核能力，而不只是 ROC-AUC。

开集漂移不是一次性“泛化测试”可解决。模型更新、相机计算摄影、社交平台滤镜、HDR、截图、拼图、局部生成和再生成都改变统计特征。视频需在帧、片段、视频、镜头和身份层次分别校准；随机抽帧可能错过局部伪造，帧级多数投票会淹没短片段攻击。音画异常可帮助检测，但正常配音、网络延迟、多语言和遮挡会产生误报；当攻击者联合生成面孔、声纹和口型时，这类异常又可消失。

检测系统的信任根是数据版本、阈值审批、输入解码与运行时完整性，不是模型网络的不可解释权重。自适应绕过包括白盒梯度、代理迁移、查询试探、压缩下保留的扰动和只修改高显著区域。更新要评估新生成器和新媒体链，但旧阈值仍要保留以重建历史决策。高分检测仅应触发额外证据检查或有限临时措施；对永久下架、法律归因或账户惩罚，需要来源、身份、上下文和人工复核。

06.E4.4 水印的五个独立任务：嵌入、检测、载荷、定位和归属 稳定签名、Tree-Ring 与众多生成时/后处理水印使用不同嵌入位置，所以它们的威胁假设不可直接排名 [@P028] [@P029]。一个系统可能只回答是否存在信号，也可能解码生成器/账户 ID；对局部编辑又需要时空定位。归属还要求密钥、载荷注册库与冲突规则。所以“检出率”不能代表载荷 bit accuracy、局部定位 IoU、误归属率或多用户共谋安全。

水印攻击至少有四个目标：移除真水印、在未注册内容中伪造信号、将甲主体信号转移到乙内容、使一个局部修改不被定位。WAVES 的价值是在共同攻击套件与感知质量下比较多种图像水印，但其结论仍限于所选算法、数据和攻击集 [@P030]。生成式再生成移除、利用公开 VAE 近似 Tree-Ring 潜空间的移除、黑盒伪造、可控再生成，以及把水印图像视为初始帧并用 next-frame prediction 生成语义近似后继图像的移除等一手攻击证据表明，开发者必须分别测试移除与伪造，并将可得样本数、查询、密钥知识、感知质量和平台编码列为攻击预算 [@P031] [@A059] [@A060] [@A061] [@A062]。这些结果不支持“所有水印必然失败”，而是要求每个鲁棒性主张都说清威胁模型；其中 Crack in the Bark 直接支持的是特定 Tree-Ring 移除，伪造证据来自另列的黑盒伪造研究。

密钥与载荷生命周期包括生成器主密钥、每版本子密钥、每租户/每资产随机化、检测服务限流、密钥轮换、泄露撤销和历史验证。完全公开检测可提高可审计性，也可向自适应攻击者提供反馈；完全闭源可限制查询，却引入不透明误归属和厂商锁定。可行折中是公开协议与评测契约，保护生产密钥，向独立审计者提供受控的黑盒或执行环境，并保留公开的误报申诉。

06.E4.5 本地局部实验对水印与元数据的证据上限 本项目实际运行了一个程序化合成媒体环境：6 张 512×512 图像、48 帧、8 fps、6 秒的无声视频，使用 32 bit 全局 DCT-QIM 玩具水印、字节级 SHA/HMAC 与 PNG/MP4 玩具元数据 [@DitseReproduction2026]。这是 `PARTIAL_RUN`，不是任一论文复现，HMAC 密钥公开在配置中以便复算，不是生产公钥签名，元数据也不是 C2PA。

局部观察有明确但很窄的证据上限：精确 SHA/HMAC 只对原字节成功，任何重编码或像素变换即失效；玩具元数据是否存活取决于处理链是否复制，无损重封装也可在显式剥离时立即丢失；DCT-QIM 在所测 JPEG、缩放、噪声和模糊下存活，但图像中心 80% 裁剪后 0/6 检出，视频同类裁剪后 0/48 帧检出；视频 CRF35 和 250 kbit/s 下分别只有 21/48 与 18/48 水印帧检出，CRF35 干净对照还出现 1/48 假阳性。

这些数字的分母是固定合成模板的派生媒体，不是独立自然视频或多生成器研究；420 个视频变换帧不是 420 个独立研究单元，不可用于推断真实部署 FPR。它们只支持一个工程结论：精确完整性、容器元数据和内容内嵌信号的失效面不同，部署必须分层并对实际转码链测量。它不支持玩具水印、HMAC 或元数据可以解决真实性。

06.E4.6 C2PA 2.4：绑定、声明、信任与直播视频 截至本综述时间窗，C2PA 官方规范站的现行 2.x 版本是 2.4（2026 年 4 月）。这一版引入 crJSON 派生视图、repository receipt 声明、新资产格式/声明，并对操作、成分、动态视频和密码学做扩展 [@O001]。crJSON 是由 C2PA 数据派生、用于配置评估/互操测试/验证报告的 JSON-LD 视图，它本身不可独立验证也不是输入格式。这个边界很重要：用平台导出的简化 JSON 作为法医原件，会丢失签名和二进制容器链。

核心验证将声明格式、签名、可信时间戳、证书状态、断言、成分和资产 hard binding 分步处理，并区分 Well-Formed、Valid 与 Trusted。Valid 要求签名通过、签名时刻落在凭据有效窗口，并结合可信时间戳与 OCSP/撤销信息判断签名时状态；Trusted 还要求证书链连到已知 trust anchor [@O002]。因此，证书后来正常过期不自动否定带有合格时间证据的历史签名；这三个状态也都不表示“事实真实”。验证器是处理不可信输入的解析器，C2PA 实施指南显式提醒内存安全、解析、SSRF、信息泄露和 DoS；不应为查远程 manifest 让验证服务获得任意网络权限 [@C2PAGuidance24]。

规范对剥离边界的表述很清楚：完整或局部修改 manifest 内被签名保护的数据可被验证发现，但 C2PA 不保护整份 manifest 从资产中被删除 [@O002]。当社交平台重编码或删元数据时，soft binding 可用水印或指纹在 manifest repository 中恢复候选；但近似匹配不精确，应对返回结果做缩略图/内容绑定验证并提供人工复核。当一个水印作为 bound soft binding 时，manifest 中需有对应 `c2pa.watermarked.bound` 动作和 soft binding assertion；C2PA 本身不指定某个水印算法。

对普通或分片 ISO BMFF/MP4 资产，C2PA 2.4 延续 BMFF hard binding，可用 BMFF hash map 与 Merkle 结构绑定分片资产；把多个片段简单拼接并不自动产生符合规范的单文件。如需在两种打包形态间转换，重包装应作为 ingredient 并记录 `c2pa.repackaged` [@O001]。

直播与动态打包是另一套段级验证合同：规范为 ISO BMFF/CMAF 给出逐段 Manifest Box，或由会话密钥签名的 `verifiable-segment-info`；其中逐段 manifest 的 `bmffHash` 不使用 Merkle 选项。MPEG Transport Stream 仍不在该规范支持范围内 [@O001]。这表明真实视频保留不是“拷贝一个元数据字段”，而是打包器、CDN、编辑器、平台转码与播放器共同实现的协议；普通 fMP4 的 Merkle 绑定结果不得直接外推为直播段验证效果。

06.E4.7 C2PA 信任列表、撤销、仓库回执与隐私 C2PA 于 2025 年中启动官方一致性计划和 Trust List，临时列表于 2026-01-01 冻结；官方 Conformance Explorer 提供生成器、验证器与信任列表的动态记录 [@O003] [@O004]。Trust List 管理受信锚与合规证书颁发机构，不等同于终端或中间签名凭据的实时撤销查询；后者还需结合可信时间戳、OCSP/证书状态及验证器的网络失败策略 [@O002]。因此“旧 Trust List”主要影响信任锚集合，“撤销状态陈旧或不可达”影响具体凭据状态，两者必须分别记录。规范一致性或列表收录可增强实现对规范的信心，但不是业务真实性审核，也不能单独证明跨厂商实现已经互操作。

撤销计划必须在事故前建立。密钥可能直接泄露，也可能是攻击者获得 HSM 签名请求权。C2PA 安全指南对计划退役、密钥失陷和更大 PKI 事件区分处理，并说明缺少可验时间戳时，撤销可能导致无法判断签名是否早于失陷 [@O002]。运营者需要把证书标识、首次可能失陷时间、发现时间、撤销时间、受影响 manifest 和对外通知联系起来，而不是只更换一把新钥。

2.4 新增的 repository receipt assertion 可在 update manifest 中记录 manifest 被某仓库接收和可在某 URI 验证的仓库特定证明 [@O001]。它能为“某时刻已登记”和 manifest 丢失恢复提供新支点，但 proof 字段语义由仓库定义，不能认为所有仓库保证同一等级的不可抵赖。软绑定查询还可能泄露用户在查什么媒体；指南建议尽量在客户端计算绑定并对仓库查询明确 opt-in。永久、公开的来源还可能暴露摄影者身份、地点或已编辑前的敏感版本，所以数据最小化、选择性披露、离线验证与纠错渠道应与持久性共同设计。

06.E4.8 SynthID：厂商嵌入与公众验证能力的边界 Google DeepMind 的官方页面将 SynthID 描述为在 Google 生成产品的图像、视频片段、音频与文本中嵌入信号的工具；视频水印声明目标包含裁剪、滤镜、帧率变化和有损压缩下的存活，并可通过 Gemini 上传媒体进行检查 [@O029] [@GeminiVerify2026]。后一官方帮助文档也提供了必要的负面语义：未检出 SynthID 只能表示未识别为 Google AI 生成/编辑，内容仍可来自其他 AI；简单/抽象内容或幅度很小的编辑可令结果不确定；多次变换后仍可漏检；视频中某一区间检出不表示该区间的每个部分都有信号 [@GeminiVerify2026]。

截止日前，OpenAI 官方帮助页也表示在 OpenAI 生成图像中组合使用 C2PA 与 SynthID，并将两者统一放入官方验证工具的来源信号 [@OpenAIProvenance2026]。这证明产品声明与跨厂商采用，不自动证明在不同社交平台、视频复合编辑、屏幕录制或自适应移除下的独立存活率。SynthID 检测根及具体检测协议是厂商控制的；平台若用它触发不可逆处置，必须另外提供样本保全、分数版本、独立复核、误归属申诉和密钥事故通知。

06.E4.9 VideoSeal、VideoShield 与视频时空存活 VideoSeal 是可嵌入任意图像/视频的开放神经水印框架，其作者将编码等变换纳入训练，并用 temporal watermark propagation 避免对所有高分辨率帧完整嵌入 [@P033]。官方仓库提供整视频、音画和分片流式路径，也明确整段音画脚本将完整视频加载内存、不适合长视频，需使用流式推理 [@VIDEOR]。这些是开放实现与作者评测，本项目对仓库状态仅为 `STATIC_AUDIT_ONLY`，没有下载检查点或运行论文基准。

VideoShield 把生成时信号嵌入视频扩散模型的噪声/潜状态，通过反演恢复水印，其保护对象、所需模型访问和可适用的视频生成架构与 VideoSeal 不同 [@R-A020]。两者不应用论文内最高数字排名。共同评测合同应对同一视频内容、解析度、帧率、码率、载荷、低 FPR 阈值和资源预算，逐项及组合测试重编码、缩放、裁剪、抽帧、插帧、变速、切镜、拼接、局部替换、录屏、音轨替换与平台多次转码。

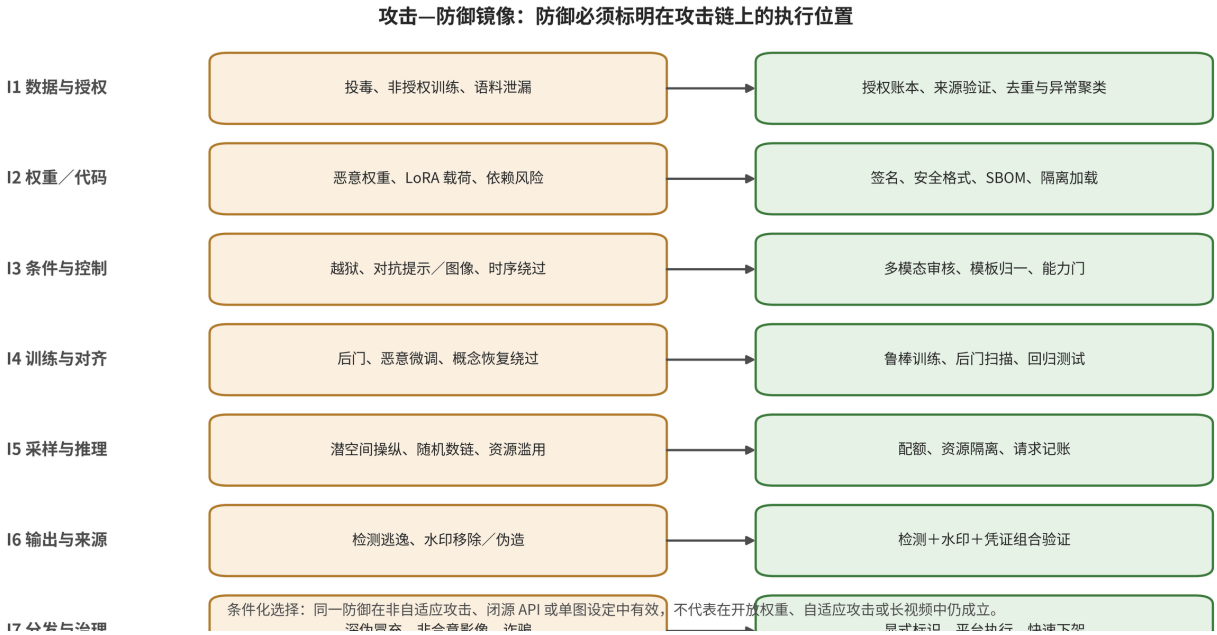
视频指标必须包含：整个视频是否有信号，片段检出与定位，最短可检片段，最长漏检区间，可解载荷准确率，干净假阳性，视频质量/时序闪烁，嵌入吞吐，检测延迟，峰值内存与单小时视频成本。直播还要测量状态丢失、分片乱序、断流恢复、动态码率和音画不同步。不经过实际 CDN/转码器/下载链的结果只能说是论文或实验室变换下的鲁棒性，不能称平台保留率。

06.E4.10 从生成到申诉的来源生命周期 一条可运营的生命周期如下：生成器按资产嵌入水印/载荷，生成 C2PA manifest，用受保护密钥签名，将签名、模型/编辑操作和软绑定写入；可选将 manifest 注册到仓库并保存回执；编辑器使原资产作为 ingredient，在新版本记录操作并重签名；打包/转码器为新字节创建可验证的新条目，而不复制已无效的旧签名；平台上传时同时保存原文件验证结果和每个传播输出的存活结果；消费者见到的是分层语义，而不是绿色“真”徽章。

在元数据被剥离时，平台可尝试水印或指纹恢复候选 manifest，但必须把恢复证据与原生 hard binding 验证区分。当水印、C2PA 和内容检测冲突时，不应投票：有效 C2PA 可能由恶意签名者产生，水印可能被转移或伪造，检测器可能分布外误报。处置应保全原文件，查签名主体/撤销/时间戳，检查软绑定的内容一致性，在厂商或权利人渠道验证载荷，并由人工考虑事件上下文。

撤销要同时处理签名证书、水印检测密钥/算法版本、manifest repository 映射、平台缓存和人机界面。对过去签名内容，顺序更换密钥应尽可能保留旧签名的历史有效性；密钥失陷则要标记首个可能影响时间窗，不能一概把所有历史内容显示为“伪造”。申诉需保留用户上传原始文件、验证器/信任列表版本、原始状态码、检测结果和最终人工理由，从而可重建当时决策。

06.E4.11 本章综合：互操是协议问题，效果是经验问题 检测、水印、指纹、签名、C2PA 和平台处置是互补证据，不是六个竞争同一指标的算法。C2PA 2.4 规范化并覆盖了更多视频打包与软绑定场景，但规范覆盖不等于任意两种实现已经互操作，更不等于每个社交平台已保留；SynthID 和 VideoSeal 可提供内容内嵌信号，不等于证明其他生成器为真或可追到用户；检测器可覆盖未合作生成器，不等于开放世界可单独执法。部署必须把“规范上能表示”、“工具中已实现”、“跨实现互操作测试已通过”、“实验中能存活”、“平台处理后仍保留”和“已触发正确处置”作为六个独立门禁。



表：检测、水印、签名与来源证明的合同差异

机制	保护对象	信任根/输出	优势	关键失败
后验检测器	输出内容	分类分数、特征	无需改生成器	域迁移、低基率误报、自适应规避
生成时内容水印	图像、视频信号	秘密消息或检出统计	可与生成绑定	重编辑、生成式洗涤、密钥治理
元数据声明	文件容器	标签或声明字段	实现简单	转码、截图易丢失
密码学内容凭证	资产与编辑历史	签名、清单、信任链	可验证来源和修改声明	缺失凭证不能证明伪造
精确字节签名	特定文件字节	哈希、HMAC、数字签名	可核验完整字节	任何转码都改变身份
检索、近重复匹配	已知资产库	指纹、嵌入和人工复核	支持再上传追踪	未知内容、碰撞与阈值

注：数据源为 `paper/tables/provenance_comparison.csv`；正文显示 6/7 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

表：真实性证据从生成到申诉的生命周期

生命周期阶段	保护对象	生产/责任主体	最低记录	验证动
采集	相机原始图像、视频	采集设备与操作者	设备声明、时间、可选位置、资产哈希与签名	校验设
生成	模型原始输出	生成服务、本地模型	模型、产品声明、生成操作、事件 ID、hard binding、可选水印	验签并
注册	manifest 与软绑定索引	manifest repository	manifest 标识、资产绑定、登记主体、仓库回执	校验回
导入	外部素材、ingredient	编辑器	原资产 manifest、父子关系、导入时间和用途	验证原
编辑	时间线和操作	编辑器与操作者	裁剪、生成填充、调色、配音等实质操作断言	验证操
导出重签	新媒体字节	编辑器、渲染器	新 manifest、新 hard binding、父 ingredient 和签名	对最终

注：数据源为 `paper/tables/provenance_lifecycle.csv`；正文显示 6/16 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

06.E5 证据展开：平台治理、事件响应与受害者救济

06.E5.1 平台标签不是真实性裁决，也不是处置闭环　本层保护的接口是内容从上传、审核、推荐、广告、下载到举报和申诉的分发界面；威胁假设是攻击者会混用无标记生成器、元数据剥离、重编码、录屏、局部替换、误导性标题和“真实素材 + 合成片段”，同时也会利用平台误标压制真实新闻或原创作品。机制首先不是再加一个检测器，而是定义相互独立的四类状态：来源

证据状态、内容风险状态、传播处置状态和调查置信度。执行主体包括平台信任与安全、内容完整性、法务、产品展示、推荐与广告团队，不能把所有责任交给模型服务。

YouTube 2026 年的官方更新将标签来源扩展到创作者披露、C2PA/Content Credentials、内部检测和部分合作信号，并说明“完全由 AI 生成”的 C2PA 标签不可由创作者移除；同一公告也明确，标签本身不自动影响推荐或变现 [@O044]。YouTube 帮助页另规定，持续不披露可能导致平台主动加标、移除内容或暂停合作计划 [@YouTubeDisclosure2026]。这两条分别证明“界面展示规则”和“潜在执法权限”，并不提供标签准确率、处置一致性或申诉改判率。TikTok 官方称已使用 Content Credentials、创作者标签工具与不可见水印等组合信号，为超过 30 亿条视频加上标签；该累计量不能改写为“30 亿次自动检测”，也不提供各信号占比或独立准确率。Meta 关于标签覆盖的说明同样属于平台自报，不是独立有效性研究 [@TikTokTransparency2026] [@O045] [@O042]。

效用成本在于标签可降低一部分认知不确定性，却占用界面注意力、审核计算和客服资源；低风险内容全面突出标注可能产生“标签疲劳”，高风险仿冒只给轻量标签又可能不足。误报会污名化摄影、特效或辅助编辑，漏报会让用户把“无标签”错误理解为真实。信任根是平台收到的原文件、验证器与信任列表版本、创作者声明和可审计的规则版本，而不是截图上的徽章。自适应绕过包括去除 manifest、转移水印、把生成片段缩小后拼入真实视频、跨平台下载上传和声称为讽刺。更新时必须版本化阈值、标签文案、政策例外与模型；真实平台保留要按“上传原件—内部母版—每种转码—下载件—二次上传”逐跳实测。残余风险是观众仍可能把来源证据误读为事实核查，因此高影响事件还需情境核验和人类调查。

06.E5.2 上传证据管线：先保全，再验证，后融合 保护接口是上传入口及其异步审核队列；威胁假设是攻击者会触发解析器漏洞、提交压缩炸弹、用大量近似副本耗尽检测预算，或在平台转码后制造“证据消失”的争议。推荐机制按顺序执行：对用户上传原始字节做内容寻址并隔离保存；限制解码时间、像素/帧数和容器递归；在沙箱中解析 C2PA；冻结信任列表、撤销状态和验证器版本；提取可见/不可见标记；按预算运行开放世界检测、身份/相似度和政策分类；随后才融合为决策记录。C2PA 官方实施指南本身提醒验证器要防畸形输入、资源耗尽、SSRF 与外部资源获取风险 [@C2PAGuidance24]，所以“验证来源”也属于不可信输入处理。

执行主体是上传网关、媒体基础设施、来源验证服务、模型审核服务与案件编排器。实用性取舍包括同步路径只做低延迟安全解析和强信号验证，重型视频逐帧/分段检测放入异步队列；高传播速度或涉及选举、金融、未成年人和亲密影像时提高预算。资源表至少记录 CPU/GPU 秒、峰值内存、外部查询数、每分钟可审视频时长和 P50/P95/P99 决策延迟。误报和漏报必须在真实流量基准率下报告，不能用均衡测试集 AUC 代替阳性预测值；多模型同源训练数据导致的相关误差也不能当作独立投票。

信任根为原始对象哈希、不可变事件日志、可复现的规则包和受控密钥；软绑定恢复仅产生候选，不得覆盖 hard binding 失败。适应性绕过测试要含多次转码、录屏、画中画、局部音轨替换、帧率抖动、短片段插入、字幕遮挡和对检测器查询探测。撤销更新需把“新模型上线后是否重扫历史高风险内容”写成策略；旧结果不能静默重算而覆盖当时证据。平台处置前保留原件、派生件和中间状态；对无关普通内容按最小化原则设短保留，对案件证据按法律依据延长并做访问审计。残余风险是跨平台上游字节不可得，平台只能陈述当前所见证据。

06.E5.3 从降速到移除：比例性处置阶梯 本节保护的接口是推荐、搜索、分享、广告、变现和账户执法；威胁假设是同一技术信号在不同上下文风险差异巨大，例如明确标注的影视特效、讽刺内容、未经同意的性化合成、冒充官员发布紧急指令不能共用一个阈值。机制是将行动拆成可逆到不可逆的阶梯：不动作、提供来源详情、降低摩擦式提示、限制推荐/广告、停止变现、限制分享、年龄或地域限制、隔离待审、移除具体内容、限制账户，紧迫伤害时再按法定渠道转介。每一级都要有触发证据、复核责任、失效时间与申诉路径。

执行主体分别是产品界面、推荐与广告系统、人工审核、法务和紧急响应团队。效用、时延和资源不能只看模型吞吐：轻量提示对创作者损害较小却可能不足以阻止病毒式传播；移除可快速减害却增加误删、复核和证据保全成本。误报代价取决于表达权、收入和公共利益，漏报代价取决于受害者安全、金融或选举影响。信任根应是版本化政策与可审计案件记录，而非单一模型供应商分数。攻击者会通过分批账户、缩短片段、改变姓名拼写或先在小平台扩散再回流绕过；因此需关联近重复哈希、传播图和账户行为，但同时限制过度关联与隐私扩张。

规则更新应支持回滚和抽样复核；撤销一项错误检测规则后，平台需识别受影响案件并主动恢复推荐、变现或账户状态。真实保留不仅指水印在转码后是否存在，还包括证据在推荐缓存、CDN、下载件和申诉系统中能否关联回原件。处置指标至少分开报告：标注覆盖率、审核等待时间、可见量降低、有效举报到首次行动时间、申诉率、改判率、复发率和受害者确认结果。即使这些指标良好，离线或加密传播、镜像站和境外账户仍是残余风险。

06.E5.4 身份仿冒、NCII 与未成年人材料的受害者入口 保护接口是由被描绘者、监护人或授权代理发起的举报、身份核验、哈希登记和紧急下架通道；威胁假设是攻击者发布未经同意的亲密影像（包括合成内容）、儿童性虐待材料、勒索素材或冒充视频，并在收到下架后以裁剪、镜像、拼接和新账户重发。机制必须同时提供可访问的表单、最少必要身份核验、原件或 URL 证据、安全哈希、重复副本匹配、快速人工升级、搜索/推荐去放大和申诉反滥用。

StopNCII 让成年人在设备上对私密内容生成哈希，并把哈希发送给参与平台匹配；它只覆盖参与平台，匹配后的行动仍取决于平台政策，提交者也可撤回案件 [@StopNCII2026]。NCMEC 的 Take It Down 面向未满 18 岁时拍摄的裸露或性内容，同样在设备上生成哈希；其官方 FAQ 明确服务面向参与的公开或未加密平台，不能保证从整个互联网移除 [@TakeItDown2026]。这两项是隐私保护的跨平台基础设施，不等于感知哈希能发现所有裁剪/重绘，也不等于任何命中自动证明违法。

执行主体包括受害者支持团队、平台安全、NCMEC/合作组织、法务及必要时执法机构。延迟 SLO 应按伤害等级设定，紧迫案件以分钟到小时计，而普通版权或来源争议可允许更长复核；资源包括全天候人员、创伤知情培训、加密存储、哈希服务和多语言支持。误报可能被用于报复性审查，漏报则会让受害者反复寻找副本；信任根是合规请求、提交者权限、受控哈希数据库和双人复核。适应性绕过要求测试感知变换与语义近似，同时避免把一般相似人物误判为受害者。

美国 TAKE IT DOWN Act 的 FTC 合规页说明，第 3 节自 2026 年 5 月 19 日起生效，涵盖合格请求后的移除以及平台识别出的已知相同副本，并规定 48 小时窗口 [@FTCTIDA2026]。法律义务不能被简化为“检测器命中即删除”：平台仍须核验请求范围、保存必要证据、避免二次暴露、提供申诉，并记录无法控制的外部副本。撤销/更新包括当事人撤回哈希、法定范围变化、匹配算法升级和错误命中清除。残余风险包括私人群聊、端到端加密、非参与平台、新变体及首次上传前没有登记的内容。

06.E5.5 申诉、透明度与可重放证据 保护接口是从自动命中到人工复核、用户通知、申诉、恢复和事后审计的案件系统；威胁假设包括误标真实内容、伪造他人签名/水印嫁祸、恶意批量举报，以及政策或模型更新后旧决定不再成立。机制要求每次行动生成“可重放决策包”：原始文件或合法最小副本的哈希、解析/检测器及版本、输入变换、阈值与校准集版本、C2PA 状态码与证书链、撤销查询时间、平台政策条款、人工理由、派生输出和通知时间。用户通知应区分“AI 来源信号”“身份仿冒风险”“政策违法”和“法律请求”，避免用模糊的“虚假内容”替代可争议事实。

执行主体是案件平台、人工审核、模型风险、隐私与法务团队；独立监督方可抽样审计高影响类别。资源开销主要是证据存储、复核工时、多语言解释和旧版本重放环境；低风险案件可保留摘要，高影响不可逆决定应保留足够长以覆盖申诉和监管时限。误报在申诉中应按来源拆分，漏报通过受害者追诉、外部事实核查和事件回溯补充；“申诉率低”可能只是入口不可见，不能当作高准确率。

信任根为不可篡改案件日志、角色分离和受控时间戳。攻击者可能用对抗样本污染申诉附件、社会工程骗取恢复或反复提交拖垮队列，因而附件仍需沙箱处理并设置速率限制，但高伤害个案不能被机械限流。撤销与更新需支持批量定位受旧密钥、旧信任列表或错误阈值影响的案件，恢复内容与收入，并通知受影响者。平台保留应证明原上传与转码输出能由内容标识关联，但访问必须最小化。最终残余风险是证据链本身无法判断场景是否讽刺、是否获得同意或陈述是否真实，必须由情境规则和人类判断补足。

06.E5.6 跨平台事件响应与情报共享边界 保护接口是平台、模型提供商、新闻机构、事实核查组织和受害者支持机构之间的事件协作；威胁假设是高影响合成内容会在数分钟内跨平台复制，单个平台的哈希、签名或账户信息不足以阻断传播，同时过度共享又会泄露受害者材料或形成黑名单滥权。机制采用事件级而非用户级的最小共享包：内容强/软哈希、已验证签名状态、首次观察时间、受影响身份、具体政策风险、允许的共享目的、过期时间和联系人；禁止把未校准检测分数包装成“已确认伪造”。

执行主体是各组织的安全运营中心、来源验证团队、隐私/法务和紧急联络点。效用来自减少重复分析和更早发现镜像，代价是标准映射、全天候响应、权限治理与跨境合规；紧急共享追求分钟级，常规趋势数据可日/周批量。误报会跨平台放大，漏报会留下传播空隙，因此接收方必须独立验证并记录本地决定，不能以“合作伙伴命中”作为唯一信任根。攻击者可通过细微编辑逃避精确哈希、伪造事件包或污染举报源；应使用签名传输、来源认证、最小权限、速率限制和反馈质量评分。

撤销时，发起方要发布更正/失效通知，接收方要能定位并复审此前行动；更新包括新增变体哈希而不扩张到语义无关内容。平台真实保留通过跨平台往返样本测试，但不得上传真实受害材料做常规压测，应使用合成同意数据。处置输出不是全网统一删除，而是各平台按本地政策执行并回传匿名化状态。残余风险在于不参与者、封闭群组、跨法域冲突以及公共利益新闻资料可能需要保留而非抹除。

06.E5.7 截止 2026-08-09 的规则快照与可迁移治理 保护接口是产品上线和规则持续合规；威胁假设是组织把一次性法规清单当成永久事实，或者因各法域术语相似而直接复制同一标签与处置。中国《人工智能生成合成内容标识办法》自 2025 年 9 月 1 日施行，形成显式、隐式标识及传播平台核验/展示责任，并禁止恶意删除、篡改、伪造标识 [@ChinaLabeling2025]。欧盟《人工智能法》第 50 条建立机器可读标记和深度伪造披露等透明度义务；欧委会于 2026 年 7 月发布指南，相关第 50 条义务在 2026 年 8 月 2 日适用，并配套自愿行为准则 [@O006] [@EUArticle50Guidelines2026] [@O007]。这些是截至检索日的规则状态，不是法律意见；具体主体、例外、无障碍和艺术/讽刺呈现仍需法务分析。

执行主体是政策、法务、产品、工程与区域运营。机制应把法规要求映射到统一控制对象：谁生成/编辑、什么内容、何时和如何披露、机器可读信号、用户可见标识、平台核验、日志、申诉与监管报告；地区差异通过配置层实现，避免分叉不可审计代

码。资源包括地区测试、翻译、无障碍设计、合规取证和规则监控；更新 SLO 应覆盖法规生效前演练和紧急补丁。误报/漏报既是模型问题，也是术语范围和例外实现问题。

信任根是正式法源、带日期的官方指南、内部批准记录和测试证据，新闻稿或厂商博客只作政策快照。自适应绕过包括把 AI 输出说成轻微编辑、跨境账户分发、删除隐式标识或将真实内容加伪标；需要来源验证与行为调查互补。撤销/更新要保留历史规则和适用日期；平台保留率须按地区客户端、上传 SDK 和导出功能实测。最终处置仍应比例、可申诉并保护合法创作。残余风险是标准、法规和平台实现继续变化，本综述只能冻结到 2026-08-09，部署者必须设置持续监控而不是引用本文替代复核。

表：平台控制、责任主体和处置时限

责任主体	主要控制	证据链	执行者	失败处置
模型、API 提供者	能力门、输入输出审核、速率限制	请求—输出—模型版本	供应商安全、平台团队	拒绝、降级、封禁、
开放权重发布者	制品签名、模型卡、撤销通告	权重、代码、依赖摘要	发布者与仓库	撤销信任但不能删除
创作者工具	主体同意、编辑范围、导出标签	项目、输入资产与导出版本	工具商、创作者	阻止导出、警告、申
企业媒体流水线	双人审批、来源凭证、密钥隔离	资产链、审批与发布记录	企业安全、法务、编辑	隔离、撤回、事件响
分发平台	上传检测、凭证读取、标签、下架、防再传	上传者、资产、处置与申诉	信任与安全团队	降权、标签、下架、
执法与受害者支持	报告入口、证据接收、时限与救济	事件级证据和身份核验	平台、执法、社会机构	快速保护、取证、法

注：数据源为 `paper/tables/platform_governance.csv`；正文显示 6/6 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

7. 视频生成专项综合：时间、运动、音画与流式状态

7.1 最小评测单位与有效分母

视频安全至少要同时声明五级评测单位：帧用于瞬时视觉状态，连续窗口或片段用于动作和局部音画关系，镜头用于剪辑与身份连续，整视频用于完整叙事，身份/事件用于跨镜头或跨文件后果。T2VSafetyBench 的作者协议以生成视频而非原提示判定，图像条件视频基准也把行为序列和时间风险作为对象 [@P034] [@A033]。这些证据支持分层分母，不意味着任一基准已覆盖长视频、直播或所有身份事件。

有效分母不能写成抽取帧总数：相邻帧高度相关，帧级命中也不等于独立样本。协议应分别报告独立提示、种子、片段、镜头、视频、身份和事件数量，并在同一视频内保留相关结构；条件通过、生成完成、视频风险、输出阻断和实际交付又是连续但不同的分母。画质、时间一致、身份持续、事件判定、音画同步、人工复核、正常效用和资源成本不得先归一化成单一安全分。作者百分比只有在片长、帧率、模型、审核器、预算和不可判定规则一致时才可比较；本综述未获得满足汇总的独立方差与协议。

7.2 边界帧、时空后门、运动与轨迹

边界帧与中间轨迹属于不同安全对象：输入审核可能只看到文本、首帧或末帧，而生成器决定它们之间的动作与镜头。Two Frames Matter 的作者结果支持“边界状态安全不推出中间事件安全”，TEAR 的作者协议则把时间语义与输入过滤分开 [@LN05] [@LN04]。BadVideo 的作者实验在指定文本到视频训练设置下展示时空后门，并同时讨论正常质量 [@P007]。三者不能相互替代：条件补全、红队搜索与训练后门具有不同权限和因果位置。

评测应在完整片段和事件边界上记录目标是否形成、持续多久、何时首次可见，并改变模型版本、片长、帧率、纵横比、相机运动和条件模态；清洁对照要保留正常复杂运动与叙事。最早控制包括联合审查边界条件、生成中分段检查、镜头与事件级输出复核，以及运动模块的签名和组合差分。适应性绕过可能延迟语义、跨镜头分散或利用长上下文；防御则可能因全面拒绝复杂运动而获得虚假安全。现有图像 LoRA 后门与整体视频后门仅提供类比和局部直接证据，不能写成独立恶意运动模块已在多基座上被验证。

7.3 音画联合身份、语义与审核

音频携带说话人、语言、情绪和事件线索，画面携带面孔、口型、动作与场景；两者分别正常时，组合仍可能形成冒充，分别异常时也可能只是合法配音、翻译或网络延迟。AVFF 的作者结果表明音视觉特征融合可用于深伪检测，并同时暴露跨数据集迁移限制；T2VShield 的作者框架把音画一致性纳入多层视频防御 [@LN02] [@R-A024]。这些研究支持联合建模方向，不证明同步生成的高质量音画必然可检，也不能把音画不一致直接归因恶意。

最低协议应按独立说话人、身份、语言、事件和视频计数，比较视觉、音频、简单融合与时序联合模型，纳入原录、授权配音、压缩、噪声、剪辑、跨语言和同步合成，并报告身份确认、时间定位、延迟与人工复核。主体驱动系统还必须把“有权上传素材”“有权生成指定表达”“有权公开传播”分开；系统卡中的肖像和音画缓解属于厂商对特定产品版本的声明，不是第三方效果 [@R-A035]。对直播或会议，最终分母还包括从事件出现到首次告警、停止传播和副本召回的时间，离线准确率不能替代实时处置。

7.4 内容/运动记忆、缓存与长时资源

视频隐私需区分内容记忆与运动记忆：模型可能不复制整段文件，却重现身份背景、连续帧、特有动作或声音。视频记忆研究的作者分析直接支持帧、片段和运动层的区分；图像训练数据提取仅提供查询和去重关系的历史参照 [@A047] [@P024]。确证需要候选训练片段、授权与重复状态、视觉/运动/音频匹配、非成员基线和人工核查。整视频平均距离会掩盖局部泄漏，而常见动作相似又不能单独证明训练成员。

长视频还把资源从一次采样扩展到跨帧注意力、解码、插帧、音频、后处理和会话缓存；流式服务中的取消释放、队列、状态恢复和跨租户复用均需单独测量。近似缓存论文提供的是文本到图像共享服务证据，尚不足以证明长视频或商业流式架构中的同等攻击效果 [@P039]。因此最低测试只在隔离环境随片长与模态增加负载，报告 GPU 秒、峰值显存、尾延迟、取消释放、正常任务完成和质量；工程防御采用租户预算、可抢占队列、分段提交、缓存安全键和重试上限，但不宣称已有视频专用最佳阈值。

7.5 视频水印、来源、转码与首次告警

视频真实性不能用逐帧图像水印的平均检出代替。删帧、插帧、变速、切镜、局部替换、音轨更换、分片编码和平台多次转码会改变信号与分母。VideoSeal 的作者结果与开放实现支持时间传播式嵌入路线，VideoShield 的作者结果支持生成时潜状态信号及空间/时间定位；两者所需模型访问、数据、变换和资源合同不同 [@P033] [@R-A020]。图像水印研究只能提供变换类别的类比，不能作为视频时空存活事实。

报告应区分整视频检出、片段定位、最短可检持续时间、最长漏检区间、载荷准确、干净假阳性、时序闪烁、吞吐、峰值内存和首次告警。C2PA 2.4 为普通、分片和动态视频给出不同绑定与验证语义，但规范可表示不等于 CDN、编辑器、播放器和平台已经互操作 [@O001]。平台必须从上传原件到内部母版、每种转码、下载件和再上传逐跳测试，保留验证器与信任列表版本；直播还需测断流、乱序和状态恢复。即使事后检出准确，若首次告警晚于传播窗口，也不能写成风险已被及时中断。

7.6 可继承结论、不可继承结论与开放缺口

图像研究可继承的是合同与实验设计：数据和制品需要身份，攻击与正常效用要双分母，检测要考虑未知生成器与低基率，水印要写清攻击知识，来源凭证不等同事实，平台行动需可申诉。不可继承的是数值和事实结论：图像上的 ASR、AUC、水印存活或扰动迁移不能自动成为视频结果；单帧检测不能代表片段、镜头或事件；图像近重复不能定义运动记忆；离线转码不能证明直播状态；人脸相似不能替代联合音画身份与授权。

开放缺口集中在恶意运动或相机模块、多适配器组合、跨镜头和超长上下文漂移、同步音画自适应攻防、商业服务内容/运动/身份记忆、视频专用成本放大、跨平台来源长期保留与受害者救济。每项后续研究都应预先绑定模型版本、片长、帧率、镜头、音画、预算、正常效用和停止规则；缺少这些字段时只能称机制提示或工程假设。本文未把视频与图像异构结果元分析，未将静态代码存在升级为运行，也未进行端到端论文复现；这些缺口因此保持开放，而不是由综述措辞闭合。本章来源证明分析所假定的生成器分布在 2026 年 10 月剧烈移动：OpenAI 直接移除 sora-2 与 sora-2-pro 端点（410 Gone，未指定后继）；Google 排定三个 Veo 3.1 预览端点自 2026-10-22 关闭，指定 Gemini Omni 1.1 Flash 接替；Kling 4.0 发布；自托管层同步扩张——FLUX 3 Image Klein 开放权重，Wan 3.0 登顶公开榜单，MiniMax H3、HunyuanVideo 1.5 与 LTX-2.5 确认可自托管。一个月移除一个前沿 API、替换另一个并扩张开放权重层，直接改变检测主张所能覆盖的生成器集合；来源与水印基线应按新分布重新锚定。

07.E1 证据展开：视频生成专项：时间、运动、音画与实时传播

07.E1.1 将七个首破接口重新投影到视频状态　视频不是“许多独立图像的集合”，而是由帧、连续片段、镜头、主体轨迹、相机轨迹、事件、音频、编辑历史和流式状态共同构成。七接口在视频中保持可区分的合同，但不被假定为数学互斥：I1 处理训练片段、动作和音频的来源与污染；I2 处理基座、运动模块、角色 LoRA、音频编码器和工作流制品；I3 处理文本、起始/边界帧、参考视频、姿态、轨迹和音频条件；I4 处理时间层、个性化和对齐更新；I5 处理长时采样、记忆、缓存与资源；I6 处理跨帧水印、音画检测和来源链；I7 处理身份、传播与现实后果。多数对象可指定 `primary_first_break`，真正同步失效、证据歧义或信息不足时分别保留 `co_primary`、`ambiguous` 与 `unknown`。

同一事件可能跨多个接口，但分类以第一个被破坏的安全合同为准。例如，未授权肖像先进入训练集归 I1，恶意角色 LoRA 被加载归 I2，边界帧诱导中间事件归 I3，个性化训练劫持归 I4，训练片段被黑盒提取归 I5，视频水印在转码后失效归 I6，随后冒充账户传播归 I7。后续接口记录传播，不重复计为独立攻击家族。这种方法使防御能够放在最早有效的位置。

07.E1.2 最小评测单元与有效分母 视频安全至少需要五级评测单元。帧级捕捉短暂视觉内容；窗口或片段级捕捉持续数帧的动作与局部音画关系；镜头级捕捉剪辑和身份连续；整视频级捕捉完整叙事；身份/事件级跨越多个镜头和文件。对动作顺序、因果和口型而言，单帧没有定义完整目标；对闪烁水印而言，整视频平均又会隐藏局部失败。评测协议必须先声明风险属于哪一级，再指定分母。

有效分母不是抽取的总帧数。相邻帧高度相关，把每帧当独立样本会虚增样本量和置信度。应报告独立提示、独立种子、独立片段、独立身份或独立事件的数量，并对同一视频内相关性分层。T2VSafetyBench 基于生成视频而非提示进行安全判定，SafeGen-Bench 针对图像条件视频建立评测，这两类设计支持从条件成功、生成成功到视频判定的逐级分母 [@P034] [@A033]。

最低指标集合包括空间语义与画质、时间一致性、身份持续、动作/事件准确、音画同步、局部与整段安全判定、人工复核、正常效用、生成成本和失败率。若涉及水印，再加时间定位、跨帧鲁棒和转码；若涉及隐私，再加训练片段对应、内容/运动记忆和非成员误报；若涉及可用性，再加 GPU 时间、显存、尾延迟和取消释放。不同指标不得先归一化再平均成缺少实际含义的“综合安全分”。

07.E1.3 边界帧、轨迹与时序组合攻击 视频条件具有延迟显现属性：输入审核看到的是文本、起始帧或若干边界帧，生成器输出的是它们之间的动作轨迹。Two Frames Matter 说明仅检查两个边界状态不能覆盖模型补全的中间时间过程 [@LN05]。TEAR 将时间感知引入自动红队，支持以事件和轨迹而非孤立帧构造评测 [@LN04]。这些论文给出风险机制和特定模型结果，但本文不复述可直接用于越过现实系统的提示、优化目标或参数设置。

长时序还会产生组合语义。每一帧都可能不违规，但动作顺序、镜头切换或字幕—画面组合构成违规事件；相反，一帧看似敏感也可能在纪录、医疗或反暴力语境中有合法含义。防御需要在生成前预测风险轨迹，在生成中分段检查，在输出后以完整事件复核，并保留时间定位供申诉。随机抽帧只能作为成本优化的第一阶段，不能作为高风险任务唯一审查。

攻击迁移评测需改变模型版本、帧率、长度、纵横比、摄像机运动、条件模态和审核器，同时记录查询预算。失败可能来自生成模型无法保持目标轨迹、边界条件被联合审核、生成中检查中止任务、音画或事件判定器发现异常，或输出质量下降到不可用。清洁效用则要检查正常创作的动作多样性和叙事完整性，避免防御将所有复杂运动都误拒。

07.E1.4 运动模块、相机控制与长时记忆 运动模块和相机控制器改变的不只是外观，而是时间注意力、速度、方向、镜头切换与视角。供应链上，它们可以与角色 LoRA、VAE、ControlNet 和插帧器组合；训练上，它们可被单独更新；推理上，它们接收轨迹或姿态条件。由此产生的安全测试应覆盖模块单独加载、两两组合和风险驱动的高阶组合，而不是把所有排列穷举后宣称完备。

本轮检索确认了图像 LoRA 后门 [@P006] 和文本到视频整体模型后门 [@P007]，但没有找到可同时满足以下条件的一手研究：恶意运动模块或相机 LoRA 作为独立分发制品，在多个视频基座和组合工作流上展示后门，报告哈希/版本、清洁运动效用、适应性防御与完整片段判定。这个缺口必须如实保留。工程上可以先采用允许列表、签名、SBOM、沙箱、组合差分和撤销机制，但不能把预防性控制写成已证实的攻击复现。

长时记忆还会跨片段或流式会话传播。角色身份、场景和运动状态可能存入上下文、缓存或参考记忆；局部异常随后影响远处帧。研究应报告风险随片段长度、镜头数和上下文窗口的曲线，设置相同计算预算的短片对照，区分普通质量漂移、安全事件漂移和记忆泄漏。当前公开安全基准多集中于短片段，超长视频和持续会话证据仍不足。

07.E1.5 音画联合身份、语义与审核 视频中的声音携带说话人身份、语言、情绪、环境和事件线索。视觉与音频可各自显得正常，组合后却形成冒充或欺骗；也可能画面异常而配音明确说明是讽刺、教育或重演。因而音画攻击与防御不能只把两个独立分类器的分数相加，应对“谁在何时说什么、口型是否匹配、声音与场景是否一致、身份是否获授权”建模。

AVFF 展示音视觉特征融合的深伪检测，并包含跨数据集评测 [@LN02]。T2VShield 也把音画一致性纳入视频防御框架 [@R-A024]。这些工作支持联合审核方向，却不能证明同步生成的高质量音画一定会被发现。正常配音、翻译、无障碍音轨和网络延迟都可能造成不一致，若缺少这些清洁基线，防御可能对合法内容产生系统性误报。

合格协议应按独立说话人、身份、语言、事件和视频计数，报告纯视觉、纯音频、简单融合与时序联合模型的对照；包含真实原录、合法配音、压缩、噪声、剪辑、跨语言和同步合成；测量检测、身份确认、时间定位、跨域、延迟和人工复核。对直播或会议，还需报告从事件发生到拦截的时间，因为高离线准确率无法弥补实时传播窗口。

07.E1.6 视频隐私、内容记忆与运动记忆 视频训练数据包含更多可识别维度：面孔、身体、住所、车牌、儿童、医疗或工作场景、声音、步态、动作与拍摄者轨迹。一个模型可能不重现整段视频，却在多个输出中复现同一身份背景、连续帧或特有运动。Investigating Memorization in Video Diffusion Models 对内容与运动记忆的区分，为最低分析框架提供了直接依据 [@A047]；图像训练数据提取工作则提供了查询式提取与去重关系的历史参照 [@P024]。

视频隐私确证需要比图像更严格的来源台账。候选训练集可能被切片、重编码、变速、裁剪或去音轨，文件哈希不足；视觉近重复、运动特征、音频指纹和时间对齐需共同使用。还应报告候选训练片段在语料中的重复次数、是否公开可得、授权状态、模型访问预算和非成员对照。常见动作或场景高度相似不是成员证明，身份相似也可能来自个性化能力而非记忆。

防御包括训练前跨模态去重和敏感身份授权、训练中隐私监测、输出端帧/片段/运动近重复阻断、查询关联与速率限制、受害者查验和删除流程。剩余风险是严格阈值会误拦常见镜头，跨模态检索成本高，删除后的衍生检查点仍可能保留。现有证据仍不足以估计商业视频生成服务中的总体记忆率或个体风险，不能从少数开放模型外推。

07.E1.7 长时资源、流式状态与服务可用性 图像生成通常有较明确的单次任务边界，视频则把成本乘到帧、窗口、解码、音频、插帧与后处理。流式或交互式生成还保留跨轮状态，使单请求配额不能完全代表占用。风险状态包括高估或低估的资源预留、取消后未释放、跨租户缓存、长任务排队、失败重试和部分结果回传。

近似缓存攻击为图像扩散运行时提供了具体证据，说明缓存相似性边界会影响输出和资源 [@P039]；但尚无足够一手实证证明其在长视频、音画联合或商业流式架构上的攻击效果。视频 DoS 也缺少具备明确攻击预算、正常租户分母、GPU/队列测量和适应性防御的公开研究。因此本章只提出可证伪测试：在隔离环境中随时长和模态逐步增加负载，测资源曲线、取消释放、尾延迟和正常请求完成；不提供面向现实端点的请求编排或阈值探测。

工程防御包括任务准入估算、按租户和组织的总预算、可抢占队列、分段提交、硬超时、取消回收、缓存安全键、失败重试上限、成本告警和跨租户隔离。测试必须同时报告正常视频质量、长任务完成率和用户等待，避免以全面禁用长视频换取表面可用性。

07.E1.8 跨接口纵深防御与未闭合议程 视频安全的纵深链条从数据和制品开始，而不能把压力全部交给最终内容审核。I1 的授权、片段去重与敏感身份治理减少记忆和权利风险；I2 的签名、SBOM、沙箱和组合差分控制运动模块与 LoRA；I3 的联合条件审核与轨迹预测覆盖边界帧；I4 的时间层训练审计和版本撤回控制更新；I5 的近重复阻断、租户隔离与资源治理保护隐私和可用性；I6 的跨帧水印、音画检测与来源链提高可追踪性；I7 的传播限制、身份验证、受害者救济和证据保全降低现实后果。任何单层失效都应由后续层限制传播，但后续层的存在不应成为上游放松的理由。

当前证据最清晰的部分是：图像扩散后门、条件越狱、训练数据提取、图像水印攻防，以及若干短视频安全基准、视频后门和视频水印 [@P001] [@P008] [@P024] [@P030] [@P034] [@R-A020] [@P007]。仍未闭合的七项议程是：（1）生成式视频专用 DoS 与成本放大；（2）恶意运动模块、相机 LoRA 与多适配器组合；（3）跨镜头和超长上下文的安全漂移；（4）同步音画生成下的自适应攻防；（5）商业视频模型中的内容/运动/身份记忆；（6）水印和来源凭证跨平台再上传的长期保留；（7）从模型输出到现实伤害的事件级、低基率和受害者中心验证。

这些缺口的优先级可由可证伪性排序：先固定系统边界和最小评测单元，再公开版本、预算、分母、清洁效用与失败条件，随后测试适应性防御和跨平台迁移。没有这些要素时，静态仓库阅读只能称代码审计，作者表格只能称报告值，产品系统卡只能称厂商一手自述；它们都不能改写为本地端到端复现或现场有效性证明。

07.E1.9 四类部署场景的验证合同 文本到视频服务的核心输入是文本，系统通常在提交前审核文字、在生成后审核视频。它的验证合同应包含直接风险表达、语义改写、长提示、多轮修改和跨语言条件，但不能把红队语料公开成可直接搬用的违规提示集合。每个条件需要记录预审核结果、是否启动生成、生成是否完成、完整视频风险、片段定位、输出审核与最终交付。若只记录“提示被接受”，便无法证明模型产生了目标事件；若只记录“某帧被判异常”，也无法证明内容被用户获得。T2VSafetyBench、视频越狱研究与 TEAR 共同说明视频输出和时间轨迹应进入判定，而不是以提示文字代替生成结果 [@P034] [@R-A023] [@LN04]。

图像到视频服务还接收人脸、人物照片、作品或场景图。其首要问题是输入图像本身可能安全，但模型补全的动作、镜头或上下文越过授权边界。I2VGuard、Anti-I2V 与 VPA-Guard 从保护输入图像和视觉提示防护的不同方向提供证据 [@R-A025] [@R-A026] [@R-A027]，SafeGen-Bench 则把图像条件视频的安全评测独立出来 [@A033]。验证时应按独立主体和独立图像计数，记录图像授权、保护前后感知质量、正常动画效用、跨模型与跨预处理迁移，并以完整动作而非首帧相似度判定风险。防守方扰动若让合法动画完全不可用，不能只因阻止了某类滥用就称为无代价成功。

主体驱动或数字人系统往往联合肖像、声音、文本脚本、动作模板和品牌资产。它的安全合同应把“有权上传素材”“有权生成某种表达”“有权公开传播”分开；拥有一张公开照片不代表获得人物代言、亲密内容或政治表达授权。测试应使用经过许可的合成或志愿者素材，避免在红队过程中制造新的受害者内容。身份持续性、声音相似、口型、脚本语义、场景和账号标签需联合评

估，同时记录同意的范围、期限和撤回。Sora 2 System Card 所述肖像控制与来源措施可以作为产品机制案例，但其覆盖范围和现场效果仍绑定到相应版本与厂商评测 [@R-A035]。

编辑、延长和流式视频系统的输入不仅是素材，还包括已有时间线、掩码、局部重绘、前后边界、历史会话与连续状态。风险可能在多轮修改后累积：每次编辑单独合规，组合后的叙事或身份却发生变化；旧片段的来源凭证可能在导出时丢失；延长任务还可能复用前序缓存。验证合同需要保存每轮输入、策略版本、编辑范围、派生关系和审核决定，在完整时间线重新评估，而不能只检查最新增加的片段。对直播式生成，应设置可中止点和延迟上限，并区分“检测到”“停止传播”“召回副本”三个结果。

四类场景均应包含正常任务对照。文本到视频要保留合法复杂叙事与跨语言创作；图像到视频要保留经授权的人像动画、教育和无障碍用途；数字人要保留明确同意的客服、培训和艺术表演；编辑/流式系统要保留纪录、新闻剪辑与实时可视化。防御如果只在恶意集上报告召回，却不报告这些清洁任务的拒绝、延迟、质量与身份错误，就无法用于部署决策。尤其在低基率环境中，少量假阳性可能影响大量正常用户，因此阈值应随场景后果、人工复核能力和申诉渠道调整。

场景化验证还必须有时间维度。上线前的离线基准用于发现已知失效；灰度阶段验证版本、地区、语言和负载变化；上线后监测模型、策略、审核器和平台转码的漂移；重大事件后回放已保存的匿名化证据；撤回时检查旧版本、缓存和衍生制品。每次报告都绑定模型哈希或不可变版本、审核器版本、日期与评测集版本。若系统更新后只沿用旧报告，应标注证据过期，而非把一次通过解释为永久认证。

跨场景的攻击成本也必须统一记账但不能合并结果。黑盒条件攻击记录查询和生成预算；个性化攻击记录样本、训练与等待；供应链攻击记录制品制作和传播；隐私提取记录候选检索和人工确认；真实性规避记录处理、查询和质量损失；平台滥用记录账户、投放和维持可信上下文。相同的“成功一次”可能对应完全不同成本与现实可达性。综述只做机制与证据等级比较，不把异构百分比排成简单榜单。

最后，场景验证应预先规定停止和披露规则。研究人员一旦观察到可能指向真实个人、未成年人、私密素材或可用服务弱点的输出，应停止扩展生成，隔离证据、限制访问并通知适当责任方；公开论文只保留足以复核结论的机制、分母与摘要，不公开可复用载荷。对于尚未闭合的 DoS、恶意运动模块和长时音画组合，应先在本地隔离模型或合成数据上做最小风险实验，只有在取得授权并设置资源与伦理上限后，才考虑真实服务验证。

07.E1.10 从风险发现到受害者救济的闭环　视频攻防的最后一个评测对象不是分类器，而是处置闭环。模型或平台发现高风险内容后，需要回答谁能看到原始证据、谁有权暂停生成或传播、如何通知被冒充者、如何搜索相似副本、如何处理申诉、如何保留调查材料，以及何时解除限制。若只有检测分数而没有责任主体和时限，风险可能在组织交接中继续传播。若为了追查而无限保存敏感媒体，又会制造新的隐私和访问风险。

闭环的第一阶段是事件分级。系统应结合内容类型、身份可识别性、主体是否同意、受众规模、传播速度、是否涉及未成年人、是否伴随支付或公共事务，以及来源证据状态决定优先级。自动模型可以提供候选标签和时间位置，但高后果决定需要受训练人员复核。复核者应看到必要而最少的信息，并受到访问控制、审计和心理健康保护。不能以“模型置信度高”为由跳过法律和语境判断。

第二阶段是遏制与证据保全。生成端可暂停交付，上传端可限制推荐与转发，平台可对相似副本建立临时匹配，但这些措施要区分紧急冻结与最终认定。保全记录应包括不可变媒体摘要、来源凭证状态、模型与策略版本、时间线、处置动作和访问日志，同时对原始敏感素材加密隔离。只保存截图可能丢失音轨、时间定位和凭证；只保存完整副本又可能超过必要范围，因而需要分级保存和到期删除。

第三阶段是通知、申诉与修复。被冒充者或权利人应获得可理解的通知、提交补充证据的渠道和处置进度；普通上传者应能知道限制原因并对误报申诉。修复不应只删除首个链接，还应检查派生剪辑、音轨替换、镜像上传、搜索索引和推荐缓存。对于经过验证的来源内容，应能恢复标签和分发，避免真实性基础设施变成压制合法表达的工具。美国相关通知移除法定流程提供一种制度例证，但具体平台仍需依据适用法域设计 [@O014]。

第四阶段是复盘和预防。事件结束后要把首破接口、遗漏信号、决策延迟、误报、受影响主体、传播路径与救济结果映射回数据、制品、训练、推理、真实性和平台控制。若根因是未授权训练片段，单纯增强输出审核不能闭环；若根因是平台账号接管，重训生成模型也不会解决。复盘产生的规则、探针或哈希需要版本管理，并测试其对正常内容与弱势群体的副作用。

闭环评测至少报告发现时延、人工确认时延、暂停传播时延、相似副本覆盖、申诉处理、恢复正确内容、受害者通知和证据删除，而不是只有“删除数量”。这些指标的分母分别是独立事件、独立副本、独立申诉和独立受害者，不能互换。对于直播或高传播事件，还应报告在处置前已发生的曝光，因为快速事后删除不能抹去既有观看和下载。

图像与视频生成的六个比较维度

比较维度	图像生成	视频生成
最小分析单元	单张像素／潜变量	帧、片段、镜头与音画联合状态
攻击持续性	常以单输出成功判定	须区分瞬时命中与跨帧稳定控制
评测预算	样本与查询成本较低	解码、长上下文、人评与存储成本更高
安全判定	主体／概念／伪影检查	动作、时序、身份连续、音画同步
水印与来源	裁剪／编码／生成式编辑	帧率变换、分镜、抽帧、跨帧伪造
平台处置	图片可独立标签／下架	需片段级定位、实时检测与上下文保留

外推合同：只有攻击权限、预算、帧／片段判定、时序指标与平台变换均被显式控制时，图像结论才可作为视频子命题的证据。

表：图像与视频安全证据合同差异

维度	图像最小合同	视频新增合同	应报告	禁止替代
样本单位	单图、单次输出	帧、片段、镜头、整段	逐层分母与不可判定项	只报平均帧分数
时间一致性	通常无时序	身份、动作、物体与背景持续	轨迹一致、漂移、最长失效段	挑选成功帧
触发语义	像素、文本、潜变量	轨迹、帧序列、延迟事件、音画组合	触发可见度与持续时间	逐帧触发替代片段触发
安全判定	主体、概念、伪影	事件、叙事、动作与音画同步	片段级召回与定位误差	单帧审核等同整段安全
资源与时延	请求级 GPU、时延	解码、长上下文、流式状态	首次告警、GPU 秒、队列占用	丢弃失败请求不计成本
真实性	裁剪、压缩、编辑	抽插帧、变速、分镜、直播转码	变换链、窗口检出、状态恢复	只测原始编码

注：数据源为 `paper/tables/video_contract.csv`；正文显示 6/8 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

表：视频特有状态、攻击模式与证据成熟度

接口	视频状态	攻击模式	评价单位	证据状态
I1	训练片段和时间标注	对动作、镜头或事件描述的投毒	片段—标注对	间接证据，需专门动作
I1	身份轨迹和行为序列	未授权人像视频训练个性化模型	身份—片段—时间	有保护研究与系统声明
I2	运动模块、时空 LoRA	恶意适配器只在特定组合中显现	基座—空间 LoRA—运动模块组合	高优先级开放缺口：无
I3	边界帧与中间轨迹	输入或首尾帧安全，中间补全形成有害事件	完整片段与事件边界	有新近预印本与基准，
I3	长时序与分镜	载荷延迟显现、跨镜头组合或只在长上下文成立	镜头、事件与整视频	现有工作主要短片段；
I3	相机轨迹与物体运动	通过参考图或控制信号诱导未授权运动或场景	轨迹与动作片段	有视觉条件基准，缺物

注：数据源为 `paper/tables/video_risk_matrix.csv`；正文显示 6/16 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

8. 多源证据的现实与工程检验

8.1 学术论文与官方代码：机制、实现与未运行边界

学术论文主要支持特定威胁模型、机制、作者协议结果和明确限制；官方代码可进一步确认入口、配置、依赖和数据合同，却不自动确认论文数值。V2 正文的跨研究综合只引用作者报告或规范语义，27 项统一深析移至附录作为证据卡，而不是把作者表

格改写为本地结果。中央 41 张论文卡的状态均为 NOT_ATTEMPTED，且 paper_main_protocol_run=false；因此即使某论文有官方仓库、全文和固定提交，也只能说明证据身份较可追踪，不能称主协议已复现。

论文间只在攻击权限、模态、输入、评测单位、预算和清洁效用相容时做条件化比较。BadDiffusion、SneakyPrompt、WAVES、T2VSafetyBench 等分别代表训练后门、条件越狱、水印压力测试和视频安全基准，但其指标没有共同分母 [@P001] [@P008] [@P030] [@P034]。官方代码的帮助入口通过、源文件可解析或许可证存在，只能支持实现可检查；权重、数据、专用环境、作者配置和完整运行缺失时必须停在静态审计。代码与论文不一致时，应记录版本差异并降低可复现主张，而不是择取较有利的一方。

8.2 系统卡、标准、产品与法规：声明和义务

系统卡、产品帮助和厂商公告能证明某组织在特定日期对版本、能力、缓解或生命周期作了何种声明；它们不能替代第三方攻击评测。标准主要定义可表示对象、验证状态和互操作要求；法规与司法文本定义义务、程序与适用时间，而不测算法效果。C2PA 2.4 可支持来源声明与绑定的规范语义，Sora 2 系统卡可支持厂商自述的产品安全位置，欧盟与中国正式文本可支持透明度或标识义务 [@O001] [@R-A035] [@O006] [@O009]。四类材料的结论不得互相升级。

产品暂停、恢复、退役或新增标签是可观察的组织动作，原因只有在来源明示时才能归因；服务下线也不等于开放权重消失。标准合规、信任列表收录和平台读取凭证可以提高协议可用性，却不证明每个实现跨平台保留，也不证明用户正确理解。法规生效可作为部署门的日期事实，但执行覆盖、误报、申诉和现实减害仍需事件或平台数据。本文因此把 VENDOR_CLAIM、规范语义、法定义务和事件结果分列；任何跨层推断都标明“本文综合”及其条件。

8.3 32 项事件的因果链与未知字段

32 张事件卡是有目的的新闻、官方、司法、产品和政策样本，不是发生率抽样。每卡只计一次，并依次记录生成或编辑是否确认、如何进入传播或业务流程、可观察后果、独立现实伤害和官方或平台响应；事件发生日期与证据发布日期分开。香港深伪会议诈骗的政府答复可确认特定转账损失，平台公告可确认下架动作，刑事材料可区分指控、认罪、裁决与扣押 [@O048] [@O049] [@O055] [@O056]。这些事实都不能反推某生成器的总体攻击率或算法因果效果。

事件中普遍未知的字段包括生成器和版本、是否实时生成、攻击预算、初始账户、跨平台完整传播、受害者分母、标签误报/漏报、申诉和长期后果。供应商与平台自报适合证明其声明或动作，高信誉媒体在缺少一手卷宗时只提供受限交叉；法规、司法与政府记录也仅在相应程序范围内更强。32 这一数量、主题簇分布和报道密度均不表示时间趋势。本文综合只把事件用于检验论文机制是否具有现实可达的链条、哪些组织控制实际出现，以及在哪个未知字段必须停止归因。2026 年 10 月提供了四个从边界两侧检验本章检查方法的活案例。Storm-1516 网络冒充实人的 AI 视频捏造对美国参议院候选人 James Talarico 的不当行为指控，取证与平台分析确认伪造；西班牙 PP 党的大选广告使用 AI 操纵的执政党关联人物形象——归属可辨但仍有争议；德里警方抗议图片混用真实照片与未标注 AI 增强，多团队复核三张归因真实拍摄、一张无法判定；俄勒冈一家媒体撤回对某候选人热传视频的深伪标注——证据崩塌，被指的倒置国旗为真。检测输出如今双向失效：伪造媒体以候选人为目标，深伪指控本身也已成为一种可能失效的工具。

8.4 本地 PARTIAL_RUN 与七仓库 STATIC_AUDIT_ONLY

本地真实性实验使用 6 张程序化合成图像、48 个源帧和无声视频，比较精确 SHA/HMAC、易失容器元数据与全局 DCT-QIM 玩具信号；状态严格为 PARTIAL_RUN [@DitseReproduction2026]。它未使用论文模型权重，未复现 Stable Signature、Tree-Ring、VideoSeal 或 C2PA，也未覆盖生产密钥、公开验证、跨平台上传或受害者处置。局部数值只说明这组固定合成输入和预注册处理下三类信号有不同失效面，不能形成产品鲁棒率、置信区间或论文排名。

七个公开仓库仅完成入口、配置、依赖、许可、提交和数据/权重合同的只读检查，状态均为 STATIC_AUDIT_ONLY；大型权重与数据未下载，论文指定环境和主配置未运行，故 end_to_end_runs=0。视频局部实验的逐帧结果也只能支持帧级命题，不能替代 VideoSeal 的学习式时序传播或平台首次告警评测 [@P033]。静态审计通过表示当前快照可被检查，不表示作者指标成立；即使未来只完成导入、帮助命令或单样本可视化，状态也不能自动升级为论文复现。

8.5 多源证据的一致、冲突与停止规则

多源一致只在它们指向同一对象、版本、时间和命题时增强可信度：论文机制与官方代码入口相合，可提高实现可检查性；系统卡与产品日志相合，可确认厂商声明的部署位置；标准状态与验证记录相合，可确认规范步骤；官方或司法记录与平台动作相合，可补足特定事件链。来源冲突时不按数量投票，而是比较直接性、版本、独立性和定位范围，并保留未知。法规不能证明执行效果，事件不能证明算法准确，局部实验不能证明论文主结果，静态代码不能证明运行。

停止规则由可比性和复现状态共同触发：缺共同终点、独立分母、攻击预算、模型协议或方差时，不汇总 ASR、FID、FVD、AUC，也不生成森林图、异质性或统一排名；状态为 NOT_ATTEMPTED、PARTIAL_RUN 或 STATIC_AUDIT_ONLY 时，不使用“已复现”措辞。本文的统计状态保持 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE，端到端运行保持 end_to_end_runs=0。因此本章完成的是证据用途与停止边界的检验，不是把多源材料融合成一个确定性真实性分数或生产有效性证明。

\newpage

9. 讨论：跨家族解释与条件化部署决策

9.1 中央问题与四个 RQ 的受限回答

对中央问题，本文综合得到的受限答案是：图像与视频生成系统的攻防起点不是统一的“有害输出”，而是端到端链条中最先失效的安全合同；只有把该接口与攻击者权限、模态状态、评测单位和证据层一并锁定，才能讨论最早中断点和部署选择。**RQ1** 因此由资产、主体、能力、首破接口和后果证据的联合编码回答；**RQ2** 则显示，七接口上的机制可按权限、传播、成本、正常效用和失败条件做协议受限的定性综合，但不支持把异质数值并成一个安全分。

RQ3 的答案是把防御镜像到首破接口，同时披露信任根、正常效用、适应性绕过、操作成本与残余传播；这些控制之间是有条件的互补，不是已经证明的通用最优组合。**RQ4** 的答案是严格分层使用论文、代码、系统卡、标准、法规、事件与局部实验：它们分别支持机制、实现、声明、义务、现实链条或工程合同，不能相互升级。以上是本文在现有证据上的综合与推断，不是防御因果效果证明、法律意见或统一最优方案。

9.2 跨接口共同机制、反例与替代解释

本文综合的跨接口共同机制不是某种媒体伪影，而是信任根、版本、权限或证据链在上游失效后向下游传播。数据授权、制品完整性、条件能力门、租户与资源隔离、真实性信号和平台案件处置分别对应不同中断点；组合它们的理由是避免单点失效继续传播，而不是证据已表明组合必然提高生产效果。

反例和替代解释要求降级对单一信号的语义。未检出不等于真实，签名或来源声明不证明叙事为真或获得同意，没有凭证也不等于伪造；检测、水印、指纹、签名、C2PA 与平台规则回答的问题并不可互换 [@O005] [@O001]。观察到的失败也可能由版本漂移、数据集身份捷径、低基准率、转码链或组织执行能力造成；若未做对应消融，不应将其单独归因于模型或某项控制。

9.3 闭源 API 与开放权重

对闭源 API，本文推断的条件化组合是把账户认证与高风险能力门、输入规范化、租户和速率隔离、输出审核、水印与来源声明、可审计事件记录、紧急停机和可申诉处置连在同一责任链上。它只在供应商可以观察请求与资源、可保护密钥并为误报提供复核时成立；产品系统卡支持的是该产品的缓解声明与评测边界，不能外推为闭源服务已形成行业闭环 [@O020]。

对开放权重，接收者可以移除运行时审核、水印和日志，因而条件化重点前移到发布前能力评估、安全权重格式、哈希与签名、SBOM、可复算构建、分阶段访问和安全公告。扫描和 `weights_only=True` 缩小的是已知反序列化攻击面，并不保证制品无后门、无拒绝服务或无内存破坏 [@O037] [@PyTorchSerialization2026]。若危险能力可低成本释放且缺乏可行缓解，本文的推断是延迟开放或转为受控 API；这是风险条件下的发布门，不是对所有开放模型的泛化结论。

9.4 创作者工具与企业媒体供应链

创作者工具的条件化目标是保存编辑谱系，而不是把每次调色、去噪或合法后期等同于“完全生成”。只有在采集或导入、实质生成与编辑操作、软件版本、原素关系和每次导出的可验证 manifest 能被记录，且用户能检查与纠正归属时，该谱系才能支持有限的来源判断。C2PA 对编辑关系、软绑定和视频资产的表达能力不替代对披露语义、隐私、无凭证旧工具和实际平台保留的实施选择 [@O001] [@C2PAGuidance24]。

企业媒体供应链需要把软件制品签名与 SBOM、媒体水印与来源声明、内容扫描与审批日志分为三条互补轨道。签名回答发布主体与字节完整性，媒体凭证记录对素材和操作的声明，审批日志记录发布责任；任一轨道都不能替代恶意行为扫描与实际内容审查 [@SigstoreBlob2026]。本文推断的上线条件是，组织能在指定恢复时间内定位某素材、模型、证书或供应商影响的派生产物，并能撤回、保全和恢复；未经生产等价链验证时，这只是设计门而非效果声明。

9.5 分发平台、受害者救济与高风险业务

对大规模分发平台，本文推断的组合是把上传时的安全解析、凭证验证与廉价哈希，和针对高风险、快速传播或被举报内容的深度检测、身份复核与人工案件系统连接。低基准率下的行动应由风险和证据质量共同驱动，并按地区、语言、内容长度和风险类别报告误报、漏报、时延和人工负载。平台自报的标签规模或功能上线只支持其覆盖声明，不替代独立抽样的精确率、召回率与处置后果 [@TikTokTransparency2026] [@O042] [@O044]。

受害者救济和高风险业务不应由“AI 概率”单独启动不可逆处置。条件化建议是保存上传原件和当时决策上下文，为身份仿冒、非自愿亲密影像等高伤害案件提供紧急通道、身份与权限独立核验、证据保全、重复阻断和可重放申诉；对新闻、教育、艺术与合法后期则保留人工复核与恢复路径。这是本文对证据和责任链的部署推断，不构成法律意见，也不证明任一平台已达到救济效果。

9.6 最小组合、上线门、SLO 与明确拒绝条件

本文所谓“最小组合”是受具体伤害预算约束的责任链，不是通用产品清单。其候选项包括数据许可与版本账本、制品与依赖安全摄取、训练发布评估、条件与资源控制、合作式来源信号与开放世界检测、逐跳保留测试、比例性处置、受害者入口、申诉、撤销和事件透明度。具体部署只应选取能对应已登记资产与首破接口、有明确运营负责人并能在生产等价链上重放的部分。

上线门应把威胁模型、正常效用与组合攻击、低基准率误报预算、端到端保留、密钥与模型撤销演练、事件值班、受害者响应和申诉恢复同时变成可验收条件。SLO 应在各自场景中预注册生成与审核尾延迟、视频吞吐、低误报点召回、转码后信号保留、撤销传播、首次行动与申诉恢复，而不复制跨场景阈值。不能保存决策证据、无法轮换信任根、没有生产等价链测试、高伤害业务缺紧急通道，或用厂商自测直接触发不可逆删除且无复核，都应是明确的 NO-GO；条件式 GO 必须限定流量、能力、地区、风险类别和终止阈值。

09.E1 证据展开：跨家族综合与部署决策

09.E1.1 决策原则：以接口和损失函数选控制，不做异协议排名 部署决策保护的是从数据许可、训练资产、生成 API、编辑器、来源记录到平台处置的完整责任链；威胁假设是管理者会用一个易比较的数字替代多维风险，把高 AUC 检测器、强水印、合规签名或内容凭证误当成可互换产品。机制从资产—接口—对手—损失—证据五元组开始：先列明最不能承受的误报、漏报、延迟、隐私与中断，再选择跨层控制。检测覆盖未知来源，水印提供合作式内容信号，指纹支持匹配与恢复，签名认证声明主体，C2PA 组织声明与编辑链，平台规则决定实际行动；它们不能按单一“准确率”排名 [@O005] [@O001]。

执行主体是产品负责人、模型安全、数据治理、媒体基础设施、信任与安全、隐私/法务和独立审计。效用/资源预算需以每万次生成、每小时视频和每百万次上传分别核算，包括峰值延迟、GPU、存储、人工案件和第三方查询。每项控制都必须给出 FP/FN 与不可判定状态；信任根和密钥/模型版本必须可轮换。适应性绕过采用组合测试，不允许只测单项压缩。更新与撤销要覆盖历史资产、缓存和申诉案件；平台真实保留用端到端样本证明。决策输出是“在给定条件下允许上线/限量上线/阻断”，残余风险则由明确责任人签收，而不是写成笼统免责声明。

09.E1.2 封闭生成 API：强审计与速率控制优先 保护接口是托管图像/视频生成 API、账户、提示词、参考媒体和输出下载；威胁假设包括越狱绕过、身份仿冒、批量生成、凭证盗用、对审核器探测和去标再传播。最低控制包是输入规范化与分层审核、身份/高风险类别门禁、租户与速率隔离、采样中间或输出审核、每个输出的不可关联公众身份的事件 ID、内容水印、C2PA 声明、审计日志、举报与快速撤销。Sora 2 系统卡一类提供的是特定产品的风险缓解声明与评测边界，不能外推为全行业闭环 [@O020]。

执行主体是模型提供商。正常效用成本包括高风险请求的额外延迟、视频检测 GPU、日志和申诉人员；应给普通创作低延迟路径，对高影响身份与未成年人风险使用异步或人工确认。误报会阻断合法影视、教育或新闻用途，漏报会使规模化滥用直接利用供应商基础设施；信任根是账户认证、受保护签名/水印密钥、发布清单和不可变日志。攻击者可切换账户、分步生成再外部组合、使用 API 输出训练去水印器，故必须关联行为但设置隐私边界。

密钥泄露、审核模型回归或错误策略上线时应暂停相应高风险能力、轮换密钥、标记影响窗口、重扫公开高影响输出并允许申诉；不能删除所有历史来源记录。真实平台保留需选择主要下游逐项验证水印和 C2PA 在上传/转码/下载后状态。处置包括拒绝、降级能力、冻结令牌、人工升级和受害者渠道。若没有可量化滥用监控、紧急停机、事件保全和负责人，则即使离线安全分数很高也应 NO-GO。残余风险是输出一旦下载，提供商无法控制离线编辑与再传播。

09.E1.3 开放权重发布：发布门禁不能依赖运行时强制 保护接口是模型权重、配置、tokenizer、采样器、演示代码和镜像；威胁假设是接收者可移除审核、水印和日志，微调恢复已擦除概念，或通过不安全反序列化植入代码。因此部署机制从运行时控制转向发布前能力评估、数据与许可记录、权重格式最小化、哈希与签名、SBOM、可复现构建、分阶段访问、许可证和事件

响应。Hugging Face 的 pickle 扫描被官方描述为尽力而为且不能保证安全；PyTorch 的 `weights_only=True` 缩小反序列化攻击面但不保证防拒绝服务或内存破坏 [@O037] [@PyTorchSerialization2026]。签名只能证明发布主体/字节完整性，不证明权重无后门。

执行主体是模型开发者、仓库运营者和下游部署者。资源包括全面能力测试、构建与签名服务、镜像扫描、访问审核和安全公告；开放发布后撤回能力有限，因此更重视发布前门禁。误报是过度限制低风险研究或把未知扫描项当恶意，漏报则可能永久扩散危险能力/后门。信任根是硬件或受控密钥、透明发布记录、独立复核和可验证哈希；攻击者可能夺取维护者账户、替换依赖、复用旧签名或将恶意行为藏在代码而非权重。

撤销更新必须发布受影响版本、哈希、严重性、替代件和检测方法，并向镜像传播；不能声称删除中心仓库即让所有副本失效。平台保留概念在此是“签名与安全公告能否伴随镜像/派生模型”，必须抽查主要仓库和容器注册表。处置可停止推荐/下载、吊销签名身份、隔离版本并通知部署者，但已下载副本仍是残余风险。若模型危险能力可低成本释放且缺乏可行缓解，结论应是延迟开放或只提供受控 API，而非用易移除水印作为发布理由。

09.E1.4 创作者编辑工具：保持编辑谱系而非惩罚合法后期 保护接口是相机导入、时间线编辑、生成填充、配音、滤镜、导出与协作；威胁假设是工具既可能辅助合法后期，也可能把真实人物局部替换、在复杂时间线中丢失来源，或因每次小编辑都打显眼 AI 标签而误伤创作者。机制是把原素材作为 ingredient，记录实质生成/编辑操作和软件版本，在每次导出创建新的可验证 manifest；硬绑定随新字节重签，软绑定只作恢复。C2PA 2.4 对编辑关系、软绑定、视频打包和分片直播提供表达能力，但实现者仍需决定哪些操作披露、如何呈现及如何处理隐私 [@O001] [@C2PAGuidance24]。

执行主体是编辑器厂商、相机/采集设备、云协作服务和发布出口。效用成本是签名与 manifest 生成通常远低于视频渲染，但外部素材解析、仓库查询和长时间线 ingredient 图会增加延迟/存储；界面必须允许用户查看并纠正归属。误报包括把调色、去噪或无实质生成误标为“完全生成”，漏报包括插件绕过记录或导出器剥离。信任根为采集/编辑器签名身份、受保护密钥、操作语义和用户确认；攻击者可使用未签名插件、屏幕录制或把生成片段烘焙成普通媒体。

更新时要迁移 manifest 解析和旧算法验证；密钥撤销要区分被攻陷与正常轮换。平台保留需用目标导出容器、剪辑软件、消息应用和主要平台实测，不能假设规范支持等于工作流保留。处置以提示缺失、要求披露或限制高风险发布为主，不能因缺少 Content Credentials 就删除内容；旧相机、开源工具和隐私保护工作流本就可能没有凭证。残余风险是来源链可证明谁声明了什么，却不能证明编辑后的叙事真实或已获人物同意。

09.E1.5 企业媒体供应链：签名、来源与安全扫描三轨并行 保护接口是素材采购、DAM、转码农场、广告合成、审批、CDN 与归档；威胁假设包括第三方素材冒充、依赖或插件被投毒、签名密钥泄露、转码剥离 manifest、内部人员越权和错误版本发布。机制同时部署软件供应链签名/SBOM、媒体 C2PA/水印、权限审批、内容扫描和版本化归档：软件签名回答“哪个构建主体发布了该二进制”，媒体凭证回答“谁对素材和操作作何声明”，检测器回答“当前字节呈现何种可疑模式”，审批日志回答“谁准许发布”。Sigstore/Cosign 的 blob 签名适合独立制品，但签名验证不能替代恶意行为扫描 [@SigstoreBlob2026]。

执行主体为安全工程、媒体运营、品牌/法务和供应商管理。资源预算覆盖每次摄取与发布验证、转码后重签、HSM/KMS、仓库存储和抽样人工审片；低延迟直播需把验证前移并采用分片策略。误报会阻断播出或广告档期，漏报会造成品牌冒充和大规模错误分发；信任根为企业 PKI/允许清单、职责分离、可信时间和不可变归档。攻击者可能以合法供应商签名提交恶意素材、复用撤销前证书或从无凭证支线注入，因此必须验证内容、合同和行为，不能只验签。

撤销更新要演练供应商证书失陷、检测器回退、错误素材召回和下游缓存清除；每个派生转码保存父子关系和发布目的。真实保留通过转码矩阵和 CDN 抽样衡量。处置从隔离素材、停止流水线、吊销权限、撤回发布到通知客户，且保留法证证据。若组织无法在规定恢复时间内定位“使用了某模型/素材/证书的所有产物”，则供应链可追溯门禁失败。残余风险来自无法控制的外部截屏、供应商内部欺诈和跨组织时钟/身份不一致。

09.E1.6 大型分发平台：信号融合必须绑定案件与行动 保护接口是每日海量上传、直播、推荐、广告、搜索和举报；威胁假设是低基准率下即使很小 FPR 也会产生大量误判，而高影响合成内容可能在重型审核完成前扩散。机制采用分级预算：上传同步做安全解析、可信凭证验证和廉价哈希；高风险类别、快速增长内容和举报案件进入深度视频检测/身份匹配；来源信号与政策风险分别存储；行动由风险和证据质量共同决定。平台自报的累计标签或部署规模只能用于了解覆盖范围，并须注明是否包含创作者披露、凭证和不可见水印等不同来源；它不能替代独立抽样的精确率、召回率和处置后果 [@TikTokTransparency2026] [@O042] [@O044]。

执行主体是媒体基础设施、完整性模型、推荐/广告、人工审核、事件响应和申诉团队。资源与时延指标必须按地区、语言、内容长度和风险类别分层；直播需设首检、持续检测和断流恢复 SLO。误报/漏报按实际基准率和最终案件结果估计，人工结论也需一致性审计。信任根包括验证器、平台政策、原文件保全和审查角色分离；攻击者会用多账户、短片拼接、压缩、讽刺包装和对抗举报。

更新与撤销要求灰度发布、影子评估、阈值回滚、历史高风险重扫和受影响案件复审。真实保留率要在平台每种转码/下载路径持续抽样，水印和 manifest 分开报告。处置阶梯、受害者通道与申诉必须同时上线；若只有检测 API 而没有案件系统、人员和可逆行动，则为 NO-GO。残余风险是加密私域、跨平台重发、政治/文化语境差异以及平台自身激励可能扭曲执行。

09.E1.7 上线门禁、SLO 与撤销演练 保护接口是从开发到灰度、正式发布和事故恢复的变更管理；威胁假设是团队在发布前只跑静态基准，发布后才发现平台转码、水印密钥、信任列表、申诉容量或人工队列失败。机制设置七个门禁：威胁模型与资产登记完成；正常效用和组合攻击评测达标；低基准率误报预算可接受；端到端平台保留实测通过；证书/密钥/模型撤销演练通过；事件与受害者响应有值班和时限；申诉可重放并能恢复错误行动。任一高伤害接口缺失负责人或证据，即为阻断条件。

执行主体是变更评审委员会，但每项 SLO 必须有单一运营负责人。建议报告而不预设统一阈值的指标包括：P95/P99 生成与审核延迟、每小时视频吞吐、低 FPR 点的分层召回、转码后水印/凭证保留率、签名验证不可用率、撤销传播完成时间、有效受害者请求到首次行动时间、申诉等待与改判率、事件证据完整率。阈值应由具体伤害预算决定，不能跨协议或场景复制。

信任根是已批准测试集、生产遥测、密钥与规则发布系统、原始证据和独立抽查。自适应测试每次大版本至少覆盖多步组合；攻击知识变化时增量更新，不把测试集公开细节变成唯一门槛。撤销演练要实际更换测试密钥/信任列表、定位历史资产、让平台 UI 更新并恢复误判内容；纸面流程不算通过。真实平台保留要用合成或授权样本在生产等价链路跑通。处置包括自动回滚、关闭高风险能力、切换人工、通知下游与发布透明说明。残余风险由负责人按日期复审，超过接受窗口自动升级。

09.E1.8 最小可部署组合与明确的拒绝条件 最小组合不是“买一个检测器”，而是：数据许可与版本账本；安全权重/依赖摄取；训练发布评估；输入输出风险控制；至少一种合作式来源信号加开放世界检测；C2PA 或等价的签名声明链；平台逐跳保留测试；比例性处置；受害者快速入口；可重放申诉；密钥、模型和规则撤销；事件透明度。保护接口覆盖五层，威胁假设覆盖非合作生成器、内部失陷、密钥事故和跨平台自适应编辑。执行责任必须在 RACI 中落到个人/团队，预算必须包含人工与受害者支持而非只含 GPU。

明确 NO-GO 条件包括：把“未检出”展示为“真实”；用厂商自测直接触发不可逆删除且无独立复核；不能保存上传原件或重建当时决定；无法轮换/撤销密钥；没有端到端转码和编辑测试；高风险身份/NCII 产品没有紧急通道；开放权重危险能力无可行缓解却以水印为理由发布；序列化或插件可执行不可信代码；日志收集远超处置目的且无删除策略。条件式 GO 必须列出流量、地区、能力、风险类别和终止阈值。

误报与漏报不可合成一个“安全分”，信任根不可隐藏在供应商黑盒里；绕过发现后要更新攻防矩阵并重新测组合链；撤销要同时触达内容、凭证、缓存、案件和用户界面。真实平台保留必须以实际接收的字节为证。即便全部门禁通过，仍有非参与工具、离线传播、未知攻击、语境判断与治理激励风险，因此最终结论应是“可在给定边界内运营并持续审计”，而不是“解决了生成媒体真实性问题”。

部署形态与安全层的必要性分布

	数据／供应链	训练／条件	推理／资源	真实性	平台处置
闭源 API	重要	必要	必要	必要	必要
开放权重	必要	重要	重要	受限	重要
创作者工具	必要	重要	必要	必要	必要
企业媒体	重要	必要	必要	重要	必要
分发平台	必要	必要	重要	必要	重要

表：部署条件、控制组合与残余风险

部署场景	核心资产	主导威胁
封闭图像生成 API	账户、提示、参考图、输出和密钥	越狱、身份仿冒、批量生成、去标传播

部署场景	核心资产	主导威胁
封闭视频生成 API	长视频、关键帧、音轨、租户 GPU 和输出来源	时序越狱、短违规片段、资源耗尽、帧率、转码去
开放图像模型权重	权重、配置、tokenizer、仓库和演示代码	移除审核、水印、恶意序列化、镜像替换和危险微
开放视频模型权重	大权重、视频 VAE、编码器、推理插件与示例工作流	组合依赖投毒、移除审核、规模化身份滥用和资源
创作者图像编辑器	原图、图层、生成填充、插件和导出文件	局部生成来源丢失、轻微编辑误标、未签名插件
长视频、直播编辑与分发工具	时间线、fMP4、CMAF 分片、音轨、转码版本和直播状态	分片乱序、断流、动态码率、音画替换和长视频内

注：数据源为 `paper/tables/deployment_decision.csv`；正文显示 6/10 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

10. 局限、伦理、双用途与作者责任

10.1 检索、筛选、语言、地域与版本局限

本项目是带审计记录的 taxonomy survey，不是 PRISMA 意义上的严格系统综述。OpenAlex 候选池与定向网页、正式会议页、系统卡、标准、法规和事件来源只构成当前证据包；搜索引擎缺乏稳定总命中数，部分 `raw_count` 为 `NR`，且未执行所有数据库原生导出、双人独立题名摘要筛选、全部全文双审和完整前后向引文收敛。因此，来源规模不能证明穷尽性，缺失来源可能改变 taxonomy 的覆盖与讨论权重。

版本、语言和地域偏差进一步限制外部效度。当前细粒度定量结果有时依赖作者全文，动态系统卡、平台政策、产品页和预印本会继续变化，所以时效性结论只绑定当前 `checked_at`，不是持续有效的事实。英文会议与预印本占比高，非中美欧司法辖区、低资源语言、小型创作者、国内平台透明度与裁判材料覆盖不足，因而治理建议可能过度反映高公开度机构的能力和偏好。

10.2 证据、归因、统计和低基率局限

当前机制与结果多数是论文作者在有限模型、数据、触发和裁判器上的报告，本文保存条件与定位，但没有对所有数字进行第三方实验验证。系统卡和供应商公告只能证明其声明，法规材料只能证明文本义务，平台公告只能证明功能或规则被宣布；它们都不单独证明独立安全效果、执行效果或覆盖。事件中的生成器、攻击者、实时性、传播量和伤害链常含未知字段，本文不用外观或检测器猜测补齐，因而现实归因必须保持受限。

统计边界使这些限定不能靠更大篇幅解决。异构研究缺乏共同终点、有效分母、独立研究单元和方差，所以不实施元分析、I^2 或跨协议排名。新闻、举报、执法与机构统计受公开度、分类口径、选择机制和重复报告影响，只能描述对应系统的观察，不能推断发生率、增长率或独立受害者数 [@L-S005]。低基准率下，离线 AUC 也不足以估计精确率、人工复核量和误伤成本，因而不能直接支持平台处置主张。

10.3 复现、工程与生产外推局限

复现状态严格限制本文能够支持的工程句子。统一论文深析的主协议均为 `NOT_ATTEMPTED`，七个公开仓库仅为 `STATIC_AUDIT_ONLY`，本地 DCT-QIM/HMAC 无害子模块仅为 `PARTIAL_RUN`，且 `end_to_end_runs=0`。仓库存在、README 可读、依赖文件存在、固定提交被记录或页级机制审计均不证明训练、权重获取、数据构造、服务查询和指标计算已执行，因而不能概括为“成功复现”。

权重与数据许可、GPU 预算、闭源服务版本、攻击查询的现实风险和时间依赖，都使未运行部分不能用推测补齐。以后的运行也只有在隔离环境、固定提交和哈希、记录硬件、随机种子和有效响应分母，并保持无害、授权的输出边界时，才能升级对应状态。即使升级为受控端到端运行，对未见模型、生产流量、组织流程和实际受害者结果的外推仍需独立证据。

10.4 双用途、伦理、公平与利益相关者

后门、越狱、隐私提取、水印移除和身份冒用的双用途性，限制了本文对机制细节的披露。本文只解释威胁模型、安全合同与防御位置，不提供针对在用服务的可执行绕过串、非自愿身份生成流程、未修复漏洞利用或大规模查询自动化。实验应限于合成、授权、公共基准或经伦理审查的数据；对违法或高伤害材料使用文本占位、哈希、官方统计和无害代理任务，不下载、再生成或传播原材料。

模型分数也不能代表所有利益相关者的成本。受害者的救济与证据保全、创作者的许可、署名与撤回、用户的标签理解与申诉、审核员的误报和有害暴露、以及记者和研究者的来源核验并未在现有基准中被充分共同衡量。检测器对相机、压缩、肤色、年龄、文化服饰或低资源语言的差异，以及身份系统与概念擦除的群体性误伤，在当前证据中均不足以支持泛化公平主张；真实照片被误标的反例进一步要求把可申诉性作为部署边界 [@O080]。

10.5 作者责任、可更新性与结论降级

作者责任首先是使每个关键主张保留来源 ID、版本、页码或定位、访问日期、证据等级与声明类型，使每个数字保留分子、分母、统计单位和裁判器，并使每个运行状态保留代码提交、环境、命令、日志和失败。附录不能用于隐藏负结果或统计拒绝；支持主张的权限、预算、分母和失败条件必须在主张附近可见。

结论应在新证据破坏原条件时主动降级：独立第三方在等权限和预算下无法复现，模型或服务版本变化，裁判器出现系统偏差，生产低基准率误报超过处置能力，水印在合理质量约束攻击下失效，来源凭证在主要平台链上丢失，或执行数据与治理设计假设不符，都会收窄前述解释和部署建议。更新应保留旧版本、变更理由和影响的主张，而不静默改写历史；本文当前只能声称建立了可审计编码与受限综合，不能声称完整系统检索、统一最佳防御、现实发生率或端到端复现成功。

10.E1 证据展开：局限、伦理、双用途与作者责任

10.E1.1 检索、筛选和版本局限 本项目是带审计记录的 taxonomy survey, 不是 PRISMA 意义上的系统综述。OpenAlex 提供了广覆盖候选池，随后使用定向网页、正式会议页、系统卡、标准、法规和事件来源补强；但搜索引擎没有稳定总命中数，部分查询的 `raw_count` 为 `NR`。没有执行所有数据库的原生导出、双人独立题名摘要筛选、每篇全文双审和完整前后向引文收敛。因此，来源数量只能证明当前证据包规模，不能证明文献总体被穷尽。

版本去重优先正式会议/出版社，其次作者稿或 arXiv；但若正式页只有摘要，细粒度结果仍依赖作者全文。动态系统卡、平台政策和产品页面会更新，2026 年新论文也可能从预印本转为正式版本。每条结论强度因而绑定 `checked_at=2026-08-09`。定稿或发表前必须重新访问动态来源、锁定版本和保存快照/哈希。

语言与地域也有偏差。学术证据以英文会议和预印本为主；中国材料覆盖国家标识制度，但国内平台透明度、裁判文书和中文模型卡不足；非中美欧司法辖区、全球南方平台、低资源语言和小型创作者的经验明显稀缺。这会使治理建议过度反映高公开度机构。

10.E1.2 证据、归因和统计局限 论文作者报告往往来自有限模型、数据、触发与裁判器。本文保存页码与条件，但未对所有数字做第三方实验验证。系统卡和供应商公告能证明供应商声明，不证明独立安全效果；法规能证明义务，不证明执行；平台公告能证明功能上线，不证明覆盖、误报和救济结果。

事件归因尤其脆弱。32 张事件卡中，部分由政府或司法记录确认，部分只有供应商/平台材料，Taylor Swift 和五角大楼图像等事件只能以高信誉媒体作受限证据。具体生成器、是否实时生成、攻击者和传播总量常未知。本文没有用图像外观或检测器猜测补齐，也没有把起诉写成定罪、把程序裁定写成最终责任、把产品下线写成安全事故。

统计上，异构论文缺少共同终点、有效分母、独立研究单元和方差，故不做元分析、I^2 或跨协议排名。新闻、举报和执法记录受到公开度、分类口径和选择机制影响，绝不用于发生率或增长率推断。NCMEC 等机构更新统计可以描述其报告系统观察，但举报不等于独立受害者或司法确认事件。[@L-S005]

10.E1.3 复现与工程局限 本章 27 项深析的 `reproduction_status` 均为 `NOT_ATTEMPTED`。其中 25 项保存本地 PDF 并完成页级定位；DeepfakeBench 使用官方在线全文，近似缓存工作使用官方会议页和已核验预出版材料，这两项没有本地 PDF。所有 27 项均完成来源身份核验和机制静态分析。代码仓库存在、README 可读、依赖文件存在或固定提交被记录，不证明训练、权重下载、数据构造、服务查询和指标计算已运行。主项目另有局部 DCT-QIM/HMAC 玩具实验与七仓库静态审计，其状态必须保持 `PARTIAL_RUN` 与 `STATIC_AUDIT_ONLY`，`end_to_end_runs=0`。

未复现的主要原因包括权重与数据许可、GPU 预算、闭源服务版本、攻击查询的现实风险以及时间依赖。即使未来运行，也应先建立隔离环境、固定提交和哈希、记录硬件/随机种子/有效响应分母，并限制输出为汇总结果。对闭源平台，不应为了提高论文完整性而开展可能违反服务条款或产生真实有害内容的攻击。

复现声明统一使用六状态枚举：`NOT_ATTEMPTED` 表示未运行；`STATIC_AUDIT_ONLY` 只读代码和配置；`ENVIRONMENT_PROBE` 验证依赖与入口；`PARTIAL_RUN` 运行无害子模块；`CONTROLLED_END_TO_END` 在授权数据与隔离模型上跑完；`EXTERNAL_SERVICE_VALIDATION` 还需服务授权与版本证据。另设 `paper_main_protocol_run` 记录是否运行论文主配置；任何较低状态都不能用“成功复现”概括。

10.E1.4 双用途边界与风险最小化 后门、越狱、隐私提取、水印移除和身份冒用具有明显双用途。综述需要解释威胁模型和防御位置，但不提供会显著降低现实滥用门槛的可直接执行配方，例如针对在用服务的绕过字符串、可运行的非自愿身份生成流程、未修复缓存漏洞的利用脚本、真实受害者素材或大规模查询自动化。数值报告优先说明分母和边界，不展示有害样本。

安全研究实验应使用合成、授权、公共基准或经伦理审查的数据。涉及肖像、未成年人、非自愿亲密影像和 CSAM 时，不下载、再生成或重分发违法/有害材料；可使用文本占位、哈希、官方统计和受控无害代理任务。涉及创作者风格和版权时，技术相似度不替代权利判断，实验需尊重许可和撤回。

披露应遵循协调原则：发现未公开高影响漏洞时先联系维护方，给出修复窗口，公开材料去除可武器化细节；若平台未响应，仍要评估用户保护与公共利益。来源证明研究还要防止把签名基础设施转化为监控：最小化身份数据、允许创作者选择声明、支持密钥撤销和隐私保护的软绑定。

10.E1.5 利益相关者、误报与公平局限 生成视觉安全不是只有模型提供商和攻击者。受害者需要快速救济和证据保全；创作者需要许可、署名与撤回；普通用户需要理解标签并能申诉；平台审核员承担误报和有害暴露；研究者和记者需要可核验来源；监管机构需要可执行而不过度扩大监控的规则。若评测只优化模型 AUC，会把这些成本隐藏。

误报可能不均等。检测器可能对特定相机、压缩、肤色、年龄、文化服饰或低资源语言表现不同；身份系统可能让公众人物、未成年人和跨性别者承受不同伤害；概念擦除可能误伤艺术、教育、医学或少数群体表达。未来报告需按合法使用情境和受影响群体分层，并引入被误标真实内容的申诉。E013 展示真实照片被错误标记的现实反例。[@O080]

本文证据池中的用户研究有限。Glaze 包含创作者可接受度调查，但不能代表所有文化、职业和作品类型；多数水印、越狱和视频基准没有受害者或审核员参与。因而部署建议只能是风险条件下的控制组合，不能声称代表所有利益相关者偏好。

10.E1.6 作者责任、可更新性与结论降级规则 作者有责任为每个关键主张保留来源 ID、版本、页码、访问日期、证据等级与声明类型；为每个数字保留分子、分母、统计单位和判定器；为每项复现保留代码提交、环境、命令、日志和失败。正文不应把附录当作隐藏负结果的地方，失败条件必须在主张附近出现。

当出现以下证据时，应主动降级结论：第三方在等权限和预算下无法复现；模型版本变化使结果失效；裁判器被证明有系统偏差；真实平台低基率误报超过处置能力；水印经合理质量约束的攻击失效；来源凭证在主要平台链路大量丢失；法规执行数据与设计假设不符。更新时保留旧版本和变更记录，而不是静默改写历史。

本综述最终可声称的是：已经建立一个可审计的首破接口 taxonomy、代表性研究谱系、指标合同、32 事件证据地图和可证伪议程；它不能声称完整系统检索、统一最佳防御、跨论文因果排名、现实攻击发生率或端到端复现成功。把这些边界写入结论不是削弱工作，而是让读者知道哪些判断可以行动、哪些仍需实验。

\newpage

11. 可证伪研究议程

本章不用论文数量、产品发布或新闻密度预测必然趋势，而把 F01–F14 统一写成可证伪议程。每项都保留条件化预测、最低实验或研究、核心指标、否证标准和观察窗；当否证标准成立或前置条件长期缺失时，对应判断应被撤回、收窄或停止，而不是被重新解释为“趋势仍在”。

11.1 视频、音画与实时状态（F01-F04）

F01（两年观察窗）——图像安全防御能否迁移到视频。可证伪预测是，在固定生成器家族、内容概念和攻击预算后，纯逐帧审核对跨帧组合、延迟显现和运动语义的片段漏检高于显式时序方案；这是由当前特定模型信号导出的预测，不是已证实的跨架构规律 [@P007] [@R-A027]。最低实验需在至少三类架构上，对同一语义构造单帧显式、每帧弱显式、跨帧组合和仅由轨迹成立的条件，固定片长、帧率、种子和预算，比较抽帧、密集逐帧和时序审核；核心指标为帧级与片段级 ASR、最长连续漏检段、正常视频误报和计算时延。若三类架构的未见攻击上，纯逐帧与片段方案落在预注册等效界内，且误报与时延不更差，则否定“必须新增时序机制”的强命题。

F02（两至三年观察窗）——时空后门的跨架构性。可证伪预测是，任一帧都不足、只有整段才成立的视觉、轨迹或事件顺序触发，可在多类视频架构中成立；现有工作只提供特定架构信号 [@P007]。最低实验应在至少三类视频架构上改变毒化预算、触发可见度和视频长度，并比较逐帧检测、时序模型和联合输入—输出审核；核心指标为片段或视频级 ASR、帧可见度、FVD、运动保持和干净效用。如果同权限、同感知约束和固定预算下无法跨架构成立，或密集逐帧与片段审核差异落入预注册零效应界，就应把预测降级为已测架构限定结论。

F03（两至三年观察窗）——联合音画生成与取证。可证伪预测是，在同时生成音频与视频并显式优化同步的条件下，只依赖口型、说话人或语义不同步的检测性能下降会大于单模态伪造；当前证据池缺少充分联合生成实证，故该句只是高优先假设。最低实验包含真实、仅换脸、仅换声、独立双模态伪造、联合生成和同步优化六组，按身份、语言、生成器和平台转码留一测试；核心指标为片段级 AUC/EER、每万件真实内容误报、说话事件定位误差和拒答。若联合生成与单模态伪造处于预注册等效界，且正常配音、剪辑、网络延迟和画外音的误报不增，则否定该预测。

F04（两年观察窗）——实时视频水印。可证伪预测是，实时场景的决定性瓶颈会转向首次可靠告警时延、窗口状态、内存、断流恢复和转码链，而非只是整段离线准确率；时序传播与相关规范只是技术信号，未证明平台闭环 [@P033] [@O001]。最低实验在同码率和画质下比较整段、分块和逐帧嵌入，施加抽帧、插帧、变速、局部拼接、自适应分辨率和直播转码；核心指标为首次告警时延、窗口、吞吐、CPU/GPU 资源、bit accuracy、定位误差和断流恢复。若离线方案无需重新设计就能在多长度和多转码链上保持等效检测、定位、吞吐和资源成本，且无需持久状态，则否定“实时需要新机制”。

11.2 组合供应链、隐私、可用性与撤回（F05-F08）

F05（两至四年观察窗）——LoRA 与运动模块组合。可证伪预测是，单独通过行为审计的制品在基础模型、加载顺序、合并比例、运动或音频模块改变后，可能出现组合触发或后门增强；现有多模块工作只提供方向信号 [@P006]。最低实验使用基础模型 × 空间 LoRA× 运动 LoRA×ControlNet× 音频模块的正交或覆盖数组，记录哈希、签名、秩、合并权重、量化和加载顺序；核心指标为组合异常率、ASR、干净效用和扫描召回。若组合异常不高于单模块可预测上界，且静态特征与单模块测试稳定识别全部异常组合，则可否定组合必须独立审计的强命题。

F06（两年观察窗）——概念擦除的多条件可恢复性。当前证据包未为该项绑定独立 gap ID，因而它是本文从擦除边界综合出的待验证命题，不是已证实趋势。预测是，仅用自然语言提示验证的擦除会被图像条件、学习式嵌入、潜变量、控制图、短时再微调或视频运动语义中至少一类恢复 [@L-S008]。最低实验固定基础模型、擦除概念、保留概念与效用预算，对六类条件给予等价计算预算；核心指标为残余概念率、保留概念效用和误擦除。若未见概念与全部条件均低于预注册不可恢复界，且保留概念与正常效用无实质下降，则否定“擦除会被多条件恢复”的强预测。

F07（三年观察窗）——视频训练数据的事件级记忆。可证伪预测是，视频记忆可表现为单帧不相似，但动作、镜头顺序、背景运动或音画片段高度复制，因而帧级最近邻可能漏检或误判。最低实验需在可审计训练集上改变视频重复度和身份分布，比较帧级感知相似、光流或轨迹、事件序列、音频指纹和联合片段检索，并对候选做盲人工核验；核心指标为身份或事件级 precision、recall、人工核验结果及生成量、候选量、确认量和独立训练片段量。若多模型上的事件级与音画联合检索未发现任何帧级方法漏掉的可核验片段，且置信区间排除有意义差异，则可否定新增事件级检索的必要性。

F08（两至三年观察窗）——生成服务可用性。可证伪预测是，长视频、多控制分支、高分辨率与交互式重生成导致的显存、排队、缓存和账单放大，可能不能被通用 API 限流在不损害合法长任务的情况下一并解决；近似缓存研究只提供特定隐私与完整性信号，不等于所有服务受影响 [@P039]。最低实验在隔离环境中将长时序、控制组合、相似提示缓存抖动和分布式低速并发与等成本合法负载对照；核心指标为 GPU 秒、峰值显存、队列时间、失败重试、SLO、账单和租户干扰。若通用配额、超时与公平排队在全部负载上满足预注册界，且合法长任务的完成率、成本与尾延迟不恶化，则否定生成专用资源防御的强必要性。

11.3 来源证明、低基率检测与跨平台处置（F09-F13）

F09（两至四年观察窗）——水印与 C2PA 的联合生命周期。可证伪预测是，单独水印受移除与伪造影响，单独来源 manifest 受整份剥离与恶意声明影响，联合系统可能在编辑与再上传链上提高可追踪覆盖，但仍不证明内容事实为真 [@O001] [@L-S002]。最低实验设无标记、仅水印、仅 C2PA 和联合四组，经过截图、录屏、再编码、平台上传下载、局部编辑、密钥撤销、证书过期和恶意签名者；核心指标为可验证覆盖、误归因、来源中断点、首次告警和处置时延。若任一单机制在全部链路上与联合方案的覆盖和误归因等效，或联合方案无相对收益，则否定联合覆盖预测；任何结果都不得把来源完整性升级为事实真实性。

F10（两年观察窗）——低基率与自适应检测。可证伪预测是，离线高 AUC 在真实低基率、未知生成器、平台压缩和知道防御类别的适应性攻击下，会表现为精确率、校准或审核负载恶化；跨生成器数据只提供分布漂移信号，并非真实平台流证据 [@R-A017]。最低实验按预注册伪造基率构造时间流混合数据，允许攻击者训练代理，并做跨平台、未知生成器测试；核心指标为 precision、每万件真实内容误报、校准、拒答、人工复核量、群体差异和跨生成器性能。若多平台分布、未知生成器和适应性攻击下仍满足预注册低误报 SLO 与校准，且消融排除数据集身份捷径，则否定强退化预测并允许更强的、仍受协议限定的部署主张。

F11（三至五年观察窗）——个性化同意与可验证撤回。当前证据包未为该项绑定独立 gap ID，因而这是由数据、制品和平台链联合导出的待验证议程。预测是，训练入口的一次同意不足以处理 LoRA 复制、合并、再上传、缓存和版本迭代，有效撤回需绑定数据、制品、残留能力与分发链。最低实验构造授权、到期、撤回、制品外泄和跨平台再上传事件，记录训练集、模型、缓存、已下载制品和平台结果的全链撤回；核心指标为全链撤回时延、残留身份生成能力和副本覆盖，并保存独立验证凭据。若

不引入制品登记、撤销列表或平台机制，只靠入口同意就能在预注册时限内清除全部副本与能力，且由独立方验证，则否定复杂撤回基础设施的必要性。

F12（两年观察窗）——事件级因果证据。可证伪预测是，新闻中的“AI 生成”往往不能单独区分生成、辅助编辑、检测器猜测和未证实归因，因而只凭新闻文本不足以恢复生成工具、首破点、传播与伤害链。最低研究是按司法或官方记录、平台声明、来源凭证、可验证媒体、当事人陈述与二手报道设固定证据等级，由独立审阅者盲审，再用后续官方材料回测，未知字段不强填；核心指标为字段准确率、审阅一致性和未知率。若独立审阅者只凭新闻就能高一致、准确恢复生成器、首破接口、传播与损害，并被后续官方记录验证，则否定一手追踪的强增益假设。

F13（三年观察窗）——跨平台受害者救济。可证伪预测是，算法告警变快不会自动缩短有效通知到限制、重复阻断、恢复和申诉完成的全链时延，流程、身份核验和跨平台协作可能是瓶颈；相关制度材料只提供可测量的责任窗口，不证明执行效果[@O014] [@O009] [@O006]。最低实验只能在平台书面批准或专用环境、伦理审查、请求限速、标记测试账户、可立即撤回且不占用真实受害者队列的条件下执行；否则仅做沙箱或桌面推演。核心指标是告警、人工确认、限制、重复阻断、恢复、证据保全和申诉的分段时延，以及误伤与复发。若控制内容和平台后，检测改善与所有救济结果稳定同向，流程变量不再解释额外方差且不增加误伤，则否定“流程是独立瓶颈”的强命题。

11.4 代理化生成与多阶段责任（F14）

F14（三至五年观察窗）——代理化生成与状态化策略风险。当前证据包未为该项绑定独立 gap ID，所以它是从系统边界与工具权限综合导出的研究假设。可证伪预测是，当生成模型可以检索身份素材、调用编辑器、迭代评估、选择平台并发布时，危害会更多由长期记忆、工具权限和分阶段目标组合决定，因而单轮分类器可能漏掉每步正常但整体越权的策略。

最低实验使用同一基础模型比较单轮生成与受控代理模式，代理分别获得检索、合成身份库、编辑、来源签名和发布工具，在隔离沙箱内预注册合法与不合法长期任务。核心指标为任务级危害率、首个失控步骤、工具调用因果贡献、回滚成功、资源成本与合法任务完成率。若最小权限、逐步确认和状态审计使代理与单轮模式的任务级危害落在预注册等效界内，且合法任务完成率不实质受损，则否定需要全新安全范式的强命题，只保留对现有工程组合的验证需求。

11.5 三阶段观察窗和停止规则

第一观察阶段为未来两年：检查基准是否持续公开有效响应分母、攻击预算、视频时间参数、低基准率误报和适应性攻击。如果主流工作仍仅给出封闭数据集单点分数，则应降级“评测已从单点防御转向组合压力测试”的判断。第二阶段为两至四年：检查组合制品清单、签名、撤回与多模块行为测试是否进入模型托管；如果生态转向不可插拔的闭源服务，则应降级公开 LoRA 组合的普遍重要性，同时只保留对平台内部依赖的审计问题。

第三观察阶段为三至五年：检查水印、C2PA、检测、平台标签、撤销与申诉是否形成可审计接口。若主要平台持续剥离来源信息、无法传播撤销或不提供可重放申诉，就必须停止“真实性基础设施已闭环”的主张。适用于所有阶段的停止规则是：预注册否证条件成立，有效分母或对照无法建立，新版本使原机制不再对齐，或运行需要超越授权和伦理边界时，对应议程应标记为被否证、无法检验或暂停，不得以趋势语言补齐。

11.E1 证据展开：未来三至五年的可证伪研究议程

未来趋势不能由论文数量、产品发布或新闻密度外推。本章为每项判断给出预测、最低实验和否证条件；若否证条件成立，综述应撤回或降级原判断，而不是把任何结果都解释成“趋势仍在”。`future_agenda.csv` 保存 14 项结构化合同。

11.E1.1 视频、音画与实时状态：从逐帧审核到事件级安全

11.E1.2 议程 F01：图像安全防御不能无条件迁移到视频　可证伪预测。在固定生成器家族、内容概念和攻击预算后，只用逐帧图像审核或图像安全引导的系统，对跨帧组合、延迟显现和运动语义攻击的片段级漏检率会高于显式片段模型。依据是 BadVideo 和视觉提示攻击已显示单帧不足，但这仍可能只是特定模型现象。[@P007] [@R-A027]

最低实验。为同一语义构造单帧显式、每帧弱显式、跨帧组合、仅由轨迹成立四组；固定片长、帧率、种子和生成预算，在至少三类架构上比较随机抽帧、密集逐帧和时序审核。报告帧级与片段级 ASR、最长连续漏检段、正常视频误报和计算时延。

否证条件。三类架构的未见攻击上，纯逐帧方案与片段方案在预注册等效界内，同时正常视频误报和延迟不更差。若成立，应否定“必须新增时序机制”的强命题，仅保留“需验证时序迁移”。

11.E1.3 议程 F02：时空后门会跨架构规避单帧审核　最低实验。在至少三类视频架构上训练固定视觉、轨迹和事件顺序三类目标；改变毒化预算、触发可见度和视频长度。比较逐帧图像检测、时序模型和联合输入—输出审核，报告视频级 ASR、帧级可见度、FVD、运动保持和干净效用。

否证条件。在相同权限和感知约束下，后门无法跨架构成立，或密集逐帧审核与片段审核差异的置信区间完全落入预注册零效应界。若出现，只能把 BadVideo 结论限定在已测架构。[@P007]

11.E1.4 议程 F03：联合音画生成会削弱依赖不同步的取证　可证伪预测。只依赖口型、说话人或语义不同步的检测，在同时生成音频与视频并显式优化同步的攻击者面前，性能下降大于只伪造单一模态的情形。

最低实验。建立真实、仅换脸、仅换声、独立双模态伪造、联合生成、联合生成后同步优化六组；按身份、语言、生成器和平台转码做留一测试。指标包括片段级 AUC/EER、每万真实内容误报、说话事件定位误差和拒答。

否证条件。音画异常检测在联合生成和单模态伪造间保持预注册等效性能，同时正常配音、剪辑、网络延迟和画外音不增加误报。当前文献池缺少足够联合生成实证，因此这是高优先证据缺口，而非已确认失败。

11.E1.5 议程 F04：实时水印的瓶颈将由离线准确率转向首次告警与状态　可证伪预测。随流式数字人和直播合成增加，决定性约束将是首次可靠检测时延、窗口状态、内存、断流恢复和平台转码，而不是整段离线 AUC。VideoSeal 的时序传播与 C2PA 2.4 对直播资产的支持提供技术信号，但未证明平台闭环。[@P033] [@O001]

最低实验。在同码率和画质下比较整段、分块和逐帧嵌入；施加抽帧、插帧、变速、局部拼接、分辨率自适应与真实直播转码。逐流报告首次告警毫秒数、窗口大小、CPU/GPU 占用、bit accuracy、错误定位和断流恢复。

否证条件。离线最优方案不经重新设计即可在多长度和多转码链上同时保持等效检测、定位、吞吐与资源成本，且无需持久状态。若成立，“实时需要新机制”预测被否定。

11.E1.6 组合供应链、隐私、可用性与撤回

11.E1.7 议程 F05：LoRA 与运动模块的组合风险高于单模块审计　可证伪预测。单独通过行为审计的适配器，在加载顺序、合并比例、基础模型、运动模块或音频模块改变后，可能出现组合触发、后门增强或正常效用掩护。MasqLoRA 的多模块实验显示方向性信号，但组合空间远未覆盖。[@P006]

最低实验。构建基础模型 × 空间 LoRA× 运动 LoRA×ControlNet× 音频模块的正交或覆盖数组；记录每个制品哈希、签名、秩、合并权重、量化和加载顺序。所有单模块与组合运行相同触发扫描、正常任务回归和最小权限加载。

否证条件。预注册规模的组合样本中，组合异常率不高于由单模块结果预测的上界，且静态制品特征与单模块测试能稳定识别全部异常组合。若成立，可把审计重点收缩到制品级。

11.E1.8 议程 F06：概念擦除的真正边界是多条件可恢复性　最低实验。固定基础模型、擦除概念、保留概念与效用预算，对文本、图像、嵌入、潜变量、再微调和视频控制六种条件给等价计算预算。用多个独立检测器加盲人工评审，报告残余概念率、误擦除和正常效用。

否证条件。同一方法在未见概念和六类条件下均达到不可恢复界，同时保留概念和正常生成效用无实质下降。若成立，应放弃“擦除必然可恢复”的强预测。

11.E1.9 议程 F07：视频训练数据记忆需要事件级定义　最低实验。在可审计训练集上构造不同重复度和身份分布的视频，比较帧级感知相似、光流/轨迹、事件序列、音频指纹和联合片段检索。候选必须盲人工核验，并分别报告生成量、候选量、确认量和独立训练片段量。

否证条件。多模型上，事件级和联合音画检索没有发现任何帧级方法漏掉的可核验训练片段，且置信区间排除有意义差异。若成立，可保留帧级近邻作为较低成本审计。

11.E1.10 议程 F08：生成服务可用性是独立安全接口　最低实验。预注册每请求 GPU 秒、峰值显存、队列时间、失败重试、账单和租户干扰；攻击负载包含长时序、控制组合、相似提示缓存抖动和分布式低速并发，另设等成本合法负载。服务端必须隔离测试环境，避免影响真实用户。

否证条件。通用配额、超时和公平排队在全部负载上把租户干扰限制在界内，同时合法长视频完成率、成本和尾延迟无显著恶化。若成立，生成专用资源防御的必要性被削弱。

11.E1.11 来源证明、低基率检测与跨平台处置

11.E1.12 议程 F09：水印与 C2PA 只能作为互补链验证　可证伪预测。单独嵌入水印会受移除和伪造，单独来源 manifest 会受整份剥离和恶意声明；联合系统在真实编辑与再上传链上可能提高可追踪覆盖，但仍不证明内容事实真实。C2PA 技术规范和欧委会 2026 图像/视频标记研究都把多技术路径视为需要实施验证的对象。[@O001] [@L-S002]

最低实验。设置无标记、仅水印、仅 C2PA、联合四组，经过截图、录屏、再编码、社交平台上传下载、局部编辑、密钥撤销、证书过期和恶意签名者。报告可验证覆盖、误归因、来源中断点、首次告警与处置时延。

否证条件。单一机制在全部链路上与联合方案达到等效覆盖和误归因，或联合方案无相对收益。无论结果如何，都不得把来源完整性解释为事实真实性。

11.E1.13 议程 F10：检测器必须显式建模低基率和适应性攻击　最低实验。按预注册伪造基率构造时间流混合数据，攻击者知道防御类别并可训练代理。报告精确率、每万真实内容误报、校准、拒答、人工复核量、群体差异和跨生成器性能，不只报 AUC。

否证条件。多平台分布、未知生成器和适应性攻击下，检测器仍满足预注册低误报 SLO 与校准，并且消融排除数据集身份捷径。若成立，可以支持更强部署主张。

11.E1.14 议程 F11：个性化同意必须支持可验证撤回　最低实验。构造授权、到期、撤回、制品外泄和跨平台再上传事件；记录从撤回请求到训练集、模型、缓存、下载制品和平台结果全部失效的时间，测试残留身份生成能力并保存独立验证凭据。

否证条件。不引入制品登记、撤销列表或平台机制，仅靠训练入口同意即可在预注册时限内消除所有副本和生成能力，并由独立方验证。若成立，复杂撤回基础设施可以简化。

11.E1.15 议程 F12：事件级因果链优先于新闻计数　可证伪预测。新闻中的“AI 生成”经常无法区分生成、辅助编辑、检测器猜测或未经证实归因；仅靠新闻文本不足以恢复生成工具、首破接口、传播路径和伤害。

最低研究。对公开事件采用固定证据等级：司法/官方记录、平台声明、来源凭证、可验证媒体、当事人陈述和二手报道。双人盲审后，以后续官方材料回测字段准确率和一致性，未知项不得强填。

否证条件。独立审阅者仅凭新闻就能高一致、准确恢复生成器、首破接口、传播与损害，并被后续官方记录验证。如果成立，昂贵的一手追踪收益有限；当前 32 事件显然尚未满足。

11.E1.16 议程 F13：检测更快不必然带来更好的受害者救济　可证伪预测。算法告警时延缩短，不会自动缩短有效通知到下架、重复阻断和申诉完成的时延；流程、身份核验和跨平台协作可能成为主要瓶颈。TAKE IT DOWN Act 的通知处置义务和中国、欧盟标识规则为测量责任提供制度窗口。[@O014] [@O009] [@O006]

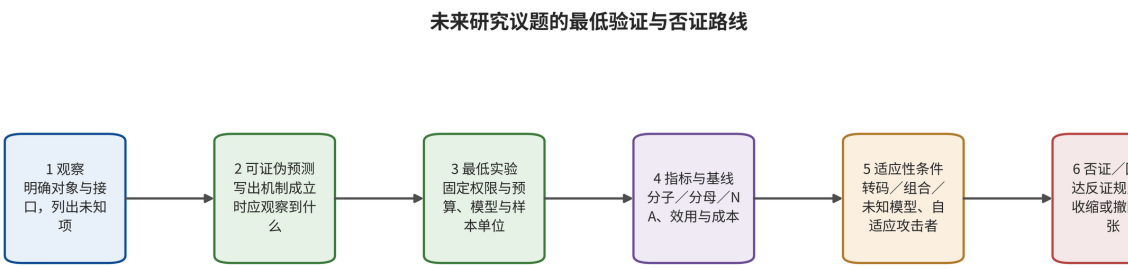
最低实验。只有在平台书面批准或专用测试环境、伦理审查、请求率上限、标记测试账户、立即撤回和不占用真实受害者审核队列等条件成立时，才使用授权模拟媒体测试合规通知、重复上传、授权争议和误标申诉；否则只做平台提供的沙盒或桌面推演。报告告警、人工确认、限制、重复阻断、恢复和证据保全的分段时延，并调查受害者和被误报用户体验。

否证条件。在控制内容与平台后，算法检测改善与所有救济结果稳定同向，流程变量不再解释额外方差，且不增加误伤。若成立，可把投资优先级更多放到检测。

11.E1.17 世界模型、代理化生成与多阶段责任

11.E1.18 议程 F14：代理化生成将把单轮内容安全变成状态化策略安全　最低实验。使用同一基础模型比较单轮生成与受控代理模式；代理分别获得检索、身份库、编辑、来源签名和发布工具。预注册合法与不合法长期任务，测量任务级危害率、首个失控步骤、工具调用因果贡献、回滚成功和资源成本。所有测试限定在隔离沙盒和合成身份。

否证条件。最小权限、逐步确认和状态审计使代理模式的任务级危害与单轮模式在等效界内，并且不显著损害合法任务完成率。若成立，现有单轮治理可通过工程组合延伸，而无需全新安全范式。



三阶段观察窗与停止规则

表：未来议题、最低验证和否证标准

议题	可证伪预测	最低实验
图像安全防御能否迁移到视频	逐帧方案对跨帧组合和延迟显现的片段漏检更高	同语义四类条件、3 类架构、固定片
时空后门跨架构性	任一帧不足而整段成立的触发可在多类视频架构成立	固定视觉、轨迹、事件序列目标，3
联合音画生成与取证	同步优化会比单模态伪造更显著削弱不同步检测	真实、换脸、换声、独立双模态、联
实时视频水印	主要瓶颈转为首次告警时延、状态与转码链	整段、分块、逐帧，抽插帧、变速、
LoRA 与运动模块组合	单独良性模块组合后可能出现触发或后门增强	基础模型 × 空间 LoRA× 运动 LoR
概念擦除的多条件可恢复性	文本验证过的擦除会被至少一种图像、嵌入、潜变量、控制、再微调恢复	固定概念与预算，对 6 类条件做未见

注：数据源为 `paper/tables/future_agenda.csv`；正文显示 6/14 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

12. 结论

12.1 中央问题与四个 RQ 的边界回答

中央问题的最短答案是：图像与视频生成安全需要先定位端到端链中最先失效的安全合同，再按权限、模态、预算、统计单位和证据层选择最早中断点，而不是从相同的有害输出反推相同攻击。RQ1 由资产、主体、能力、首破接口和后果证据的联合编码回答；RQ2 由同接口、同协议下的机制、传播、成本、正常效用和失败条件回答，不产生跨协议统一排名。

RQ3 的边界结论是，防御必须镜像对应首破接口，并同时披露信任根、正常效用、适应性绕过、处置责任和残余传播；这只支持条件化组合。RQ4 的边界结论是，论文、代码、系统卡、标准、法规、事件和局部实验只能回答各自的机制、实现、声明、义务、现实链或工程问题，不能互相升级；因此本文的结论是证据受限的分层综合，不是攻防效果的因果证明。

12.2 实践含义、非主张与后续最小验证

实践含义是把可追踪性与纵深防御连成可重放的责任链：上游记录来源、授权和制品完整性，训练与条件层在保留正常效用的同时约束危险能力，推理层隔离租户、查询和资源，输出层把检测、水印与来源凭证作为不可互换的信号，平台层将信号转化为及时、可撤销、可申诉的行动，高风险业务仍使用独立身份核验和权限分离。后续最小验证应优先验证最早中断点、正常效用、适应性绕过、生产等价链保留、撤销与申诉，并在预注册否证条件成立时收窄结论。

本稿不声称穷尽文献或完成 PRISMA 严格系统综述，不声称存在可汇总的总体效应、统一最优防御或现实攻击发生率，也不把局部实验、静态审计或可编译性写成论文主协议复现成功。统计状态为 `NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE`，端到端复现状态为 `end_to_end_runs=0`；这些边界意味着本文仅支持上述条件化综合与可证伪下一步，不构成生产效果保证、法律意见或未来必然趋势。

12.E1 证据展开：结论与开放材料

12.E1.1 八个研究问题的闭合回答 第一，图像与视频生成安全应按端到端资产和信任边界建模，而不是只看输出是否违规。第二，首破接口提供了稳定主轴：数据、供应链、条件、训练、推理、输出与分发七类可以覆盖当前中央语料，传播路径和后果另行编码。第三，攻击能力差异来自权限、知识、预算、持久性和模态状态；相同的“有害输出”不代表同一攻击。

第四，防御只有镜像到首破接口并报告信任假设、正常效用、适应性绕过和处置责任才可比较。第五，现有指标和协议高度异构，特别是视频的帧、片段、视频和身份分母不能互换，因此本文拒绝跨论文总排名和元分析。第六，论文、代码、系统卡、标准、法规、事件与实验必须分层：它们回答不同问题，不能互相升级。

第七，本地证据只支持 DCT-QIM/HMAC 玩具实验的局部行为和七个仓库的静态工程合同，不能证明论文或生产部署性能。第八，最优先的研究问题集中在实时/长视频、音画联合、组合适配器供应链、生成服务可用性、来源证明生命周期、低基率检测、跨平台处置与监管执行；这些议题都需要预定义数据、基线、指标和否证条件。

本文最稳定的实践结论不是“选择某个最安全模型”，而是建立可追踪的纵深防御：上游控制来源、授权与制品完整性；训练和条件层限制危险能力并保留正常效用；推理层隔离租户、查询和资源；输出层组合检测、水印与来源凭证而不过度解释；平台层把信号转成及时、可撤销、可申诉的执行；现实高风险业务仍使用独立身份验证和权限分离。

12.E1.2 数据、代码与可用性声明 检索协议、OpenAlex 查询与返回、中央来源注册表、论文全文和页级索引、论文卡、攻防矩阵、事件卡、仓库快照、实验脚本与日志和图表数据位于 Ditse 目录。LaTeX、编译日志、全页视觉检查和 SHA-256 清单由本轮构建链重新生成；它们是否覆盖当前长篇，必须以 `validation.json`、`validation/visual_qa.md`、`validation/file_manifest.json` 中本轮页数、时间戳和散列为准，不能由旧文件存在推断。来源受原版权和许可证约束；本地快照用于审计，不改变原始授权。

本稿使用 generic 模板，工件状态以本轮 `validation.json` 为唯一准据：只有 Markdown、`paper.json`、LaTeX、参考文献和全部图表重建，PDF 实际编译、全页视觉 QA 与散列验收均通过后，才可标为 `compiled-draft`；任何一步未通过均应降级。升级为投稿稿仍需选定目标 venue、使用当前官方模板、复核全部书目信息和图像政策、更新时效性来源，并由人类作者完成全文、双用途和利益冲突审查。AI 辅助用于检索编排、结构化、初稿和一致性校验，不替代作者对每个技术、定量和法律主张的责任。

\newpage

附录 A. 27 项统一论文深析与页级证据卡

本附录将 27 项代表研究按统一威胁模型、机制、作者报告结果、限制和复现状态展开。后门与供应链、条件越狱与输入保护、隐私与真实性、视频时序之间的“谱系”均是本文对当前证据的结构化综合，不表示存在经统计验证的因果继承关系。每项的 `paper_main_protocol_run=false`，因而本附录不提供独立复现结论。

APP-A.E1 证据展开：代表性研究谱系与二十七项统一深析

本部分围绕第 19、20、21、24、25 章展开。它不是把论文和新闻按年份堆叠，而是回答五个连续问题：某项工作改变了哪一项威胁假设；它用什么输入和机制完成攻击或防御；作者的评测究竟以什么为分母；现实事件在哪一段证据链上被确认；未来实验怎样否定当前判断。所有“作者报告”均是来源内结果，所有“本文综合”均是跨来源归纳，所有“本文推断”均明确写出推断条件。代码仓库存在、本地 PDF 存在或静态审计通过，都不等于论文已经复现。

APP-A.E1.1 从扩散过程到数据、组件和适配器：后门谱系的首破点迁移 早期生成模型后门通常把攻击对象理解为“一个被污染的整模型”。扩散模型改变了这个叙述：前向噪声、逆向去噪、条件编码器、潜空间解码器和轻量适配器都可能独立成为完整性边界。因此，下列工作不以“谁的 ASR 更高”排列，而按首破点由训练过程向数据入口、组件供应链和可组合适配器迁移。这个顺序表达威胁模型扩张，不表达技术优越性。

APP-A.E1.2 深析 P001：BadDiffusion——扩散后门的效用一特异性双合同 问题与威胁模型。 BadDiffusion 问的是：攻击者在控制训练数据和扩散训练过程时，能否发布一个正常输入上像干净模型、触发输入上却趋向指定目标的生成器。受保护资产不是某张输出图，而是已发布扩散模型的训练完整性以及下游用户对“无触发行为代表整体行为”的信任。攻击输入包括毒化样本、视觉触发和目标输出；攻击者权限显著强于仅能查询服务的黑盒用户。[@P001]

机制。作者的方法同时改造训练样本和扩散过程，使触发对应的噪声轨迹在逆过程里收敛到攻击目标；作者把后门目标拆成高效用与高特异性：前者要求干净输入的 FID 等效用不显著恶化，后者要求触发出现时目标 MSE 降低。本文综合认为，这一拆分后来成为扩散后门研究常用的报告框架。[@P001]

评测与作者报告。论文在 CIFAR-10、CelebA-HQ 等设置中改变毒化率、触发和目标，并用 FID 和目标 MSE 分别测量正常效用和后门特异性。本地 PDF p.7 报告，在该预训练微调设置下 20% 毒化率足以完成其定义的后门；p.8 的推理期裁剪实验显示，在所测参数内目标 MSE 上升而 FID 近似保持。该数字只定位于论文协议，不能与不同触发、不同模型或文本条件后门的 ASR 合并。[@P001]

作者自述局限、本文综合影响与复现状态。攻击依赖较强训练权限；已知简单触发可被裁剪缓解并不意味着未知语义触发可被发现。本文综合将该工作定位为把扩散模型本身纳入后门安全对象的奠基证据，后续研究再扩展到多目标木马、统一训练框架和黑盒检测。本文仅完成本地全文定位与代码入口静态核对，复现状态为 `NOT_ATTEMPTED`，不是实验复现。

APP-A.E1.3 深析 P002：TrojDiff——从固定目标到三类对抗目标　问题与威胁模型。 TrojDiff 进一步问：后门是否只能把触发映射到一张固定图，还是可以实现分布内类别、分布外类别和图像级目标。攻击者仍控制模型训练和木马噪声分布，受害者下载并使用被污染模型；输入是经过设计的 Trojan noise 以及三类目标。[@P002]

机制。作者把目标数据沿前向过程扩散到偏置高斯分布，再学习对应逆过程；普通噪声仍生成干净分布，木马噪声则沿另一条轨迹收敛。本文据此定位：相较 BadDiffusion，该工作改变的是目标空间和噪声分布，而不是把权限降到黑盒。[@P002]

评测与作者报告。作者在 DDPM/DDIM 和多数据集上分别使用 precision、ASR、MSE 与 FID。PDF p.2 报告 In-D2D 设置最高 precision 84.70%、ASR 96.90%，Out-D2D 的 ASR 高于 98%，D2I 的 MSE 达到约 `1×10^-4` 量级。这里必须保留三种目标定义；把这三个数字压成“后门成功率”会丢失分母和判定器。[@P002]

作者自述局限、本文综合影响与复现状态。木马噪声的可用性依赖攻击者能影响训练和交付；异常种子、采样器变化与未知噪声分布会改变防御难度。本文综合将该工作定位为把评测从单一目标扩展为多目标；论文没有提供现实模型仓库中的感染率证据。本文为 `NOT_ATTEMPTED`，只有本地全文、页码和机制审查。

APP-A.E1.4 深析 P003：Rickrolling the Artist——文本编码器成为独立供应链边界　问题与威胁模型。这项工作不要求攻击者重训扩散主干，而是假设用户从外部来源加载预训练文本编码器。输入可以是非拉丁字符、emoji 或普通词；首破点是组件交付链，触发词只是后续激活条件。本文据此将其首破点定位为组件交付链；若仅归为“提示攻击”，会隐藏恶意制品已被装载这一前置条件。[@P003]

机制。作者以教师—学生式训练改变文本嵌入，把触发词映射到对象、属性、风格或固定输出相关表示，同时保持正常提示的嵌入与生成行为。本文综合认为，该机制暴露模块化生成栈中的信任错位：主模型哈希正确，并不能证明条件编码器良性。[@P003]

评测与作者报告。论文在 Stable Diffusion v1.4 生态中考察多类触发，用图文相似、FID 和定性样本同时检查触发效果和无触发效用。来源报告在其特定组合上提供了组件级后门可行性的证据；由于各目标没有一个共同、独立的成功判定器，本章不摘录单一汇总率。[@P003]

作者自述局限、本文综合影响与复现状态。静态哈希只能标识“加载了哪个制品”，不能判断该制品在基础模型、调度器和提示工具组合下的行为；再微调也可能削弱或强化触发。本文据此定位其影响：生成模型安全审计需要同时考虑 SBOM、签名和组合行为差分，但签名仍只保证来源与完整性。本文为 `NOT_ATTEMPTED`。

APP-A.E1.5 深析 P005：Nightshade——总语料巨大不代表单概念投毒昂贵　问题与威胁模型。 Nightshade 反驳“亿级训练集天然稀释投毒”的直觉。攻击者不控制训练器，只能公开或注入可能被抓取的图文样本；真正相关的分母是某一概念的有效训练样本，而不是全库样本总数。目标是让普通提示在训练后被重定向到错误概念。[@P005]

机制。作者构造在人眼外观上接近原图、但在模型特征中指向另一概念的毒样本，并用配套文本维持目标提示，使训练过程学习错误的提示—视觉关联。本文据此把传播链定位为 I1 数据入口失效、经 I4 训练更新固化、再由普通 I3 提示激活。[@P005]

评测与作者报告。作者在自训练和预训练 T2I 设置中改变毒样本预算、概念距离和干净数据量。摘要称某些目标可用少于 100 个毒样本产生效果；PDF p.9 定位到 50 个样本约 70%–80% 的作者报告攻击成功率，200 个样本超过 84%。这些数值依赖概念、训练集和 CLIP 分类判定，不可用来推断公共语料中的实际污染概率。[@P005]

作者自述局限、本文综合影响与复现状态。攻击要求毒样本被抓取、保留并获得足够概念权重；重描述、去重、异常聚类和数据规模会改变结果。本文综合将其影响定位为：防御需要从全库重复检测扩展到概念条件异常与数据来源账本。本文为 `NOT_ATTEMPTED`，没有运行训练管线。

APP-A.E1.6 深析 P006：MasqLoRA——良性外观适配器与组合行为　问题与威胁模型。 MasqLoRA 针对插件化开放生态：攻击者冻结基础模型，只发布看似能正常完成风格或对象适配的 LoRA；用户下载、加载并用特定词激活。本文据论文权限把首破点定位为 I2 制品供应链，而非基础模型训练。[@P006]

机制。作者使用少量触发词—目标图像对更新低秩矩阵，在正常提示下维持良性功能，在语义相近触发下输出攻击者目标。本文综合认为，适配器独立交付使"逐个组件通过测试"与"组合后安全"之间产生可审计差距。[@P006]

评测与作者报告。 CVPR 2026 正式页和本地 PDF p.1 报告最高 99.8% ASR；p.7 显示四个模块叠加时作者设置中的 ASR 仍为 91.6%，但良性 CLIP 分数从 31.22 降至 27.3。后一个结果很重要：组合后门强度与正常效用不是同向保持，审计必须同时报告二者。[@P006]

作者自述局限、本文综合影响与复现状态。当前结果覆盖有限基础模型、LoRA 秩、加载顺序和合并权重。量化、转换、多个运动/音频模块组合后是否新生触发仍未闭合。本文据此定位：审计单位应从"单文件"扩展为"基础模型 × 适配器 × 加载配置"。本文为 NOT_ATTEMPTED。

APP-A.E1.7 条件越狱与预防式保护：从输入过滤到多模态控制　本谱系的核心变化是条件通道增加。文本到图像系统可以接收文本、负面提示、参考图、掩码、姿态、深度和个性化 token；图像到视频又把首帧、尾帧、轨迹和视觉符号变成控制语言。防御若只审核自然语言，就把其他条件误当成被动数据。

APP-A.E1.8 深析 P008：SneakyPrompt——黑盒越狱是一项有预算的搜索　问题与威胁模型。 SneakyPrompt 研究攻击者只拥有在线查询权时，能否迭代改写被拒提示，使其同时通过安全过滤并诱导不安全生成。输入是原始敏感提示和替换 token；预算应以服务查询数、有效响应数和生成费用报告，而不能只看成功样本。[@P008]

机制。作者利用影子文本编码器和强化学习反馈，寻找在嵌入空间中保留目标语义、却跨过过滤器决策边界的离散 token。本文据此把该攻击定位为闭环搜索，并把安全过滤器作为可查询判定器的信息泄漏列为相应系统风险。[@P008]

评测与作者报告。作者对开源和闭源服务进行黑盒测试，区分过滤通过与输出内容两个条件。来源报告显示该搜索能在论文时点绕过多类过滤器；由于服务版本、拒绝、无效响应和输出裁判不同，本章不复制一个跨服务百分比。页码定位见本地 PDF p.1–11。[@P008]

作者自述局限、本文综合影响与复现状态。额外查询成本、速率限制和服务更新可能降低攻击；反过来，重复查询本身可作为防守信号。本文综合将其影响定位为：输入网关应评测跨请求关联、预算控制和自适应红队，而不是只做逐提示判断。本文为 NOT_ATTEMPTED，未向真实服务发送攻击查询。

APP-A.E1.9 深析 P009：MMA-Diffusion——文本与图像条件联合旁路　问题与威胁模型。当系统同时部署提示过滤和输出安全检查时，仅优化文本可能不足。MMA-Diffusion 假设攻击者可对白盒模型或可微代理优化文本和视觉条件，并在部分在线服务上测试迁移。输入包括对抗文本、参考图和掩码。[@P009]

机制。作者的联合目标让文字穿过提示过滤，同时让视觉条件和生成潜变量诱导后置检查器漏检。本文综合认为，该结果不证明"多模态一定更危险"，而是提示未进入统一策略判定的条件通道可能成为旁路。[@P009]

评测与作者报告。论文使用 ASR-N、有限查询和人工语义判定。PDF p.6 报告 10-query 条件下，在论文当时的 Midjourney 和 Leonardo.Ai 上分别达到 83.33% 和 90.00% 的作者报告攻击成功率。数字只对应当时版本、内容类别和判定流程，不能视为当前平台能力。[@P009]

作者自述局限、本文综合影响与复现状态。在线服务动态更新、内容类别和安全裁判器都会改变有效分母；有害图像被输出检查拦截时，不应计为端到端成功。本文据此定位：将"覆盖全部条件通道并保留输出复核"作为一种优先评测与部署建议，而不声称它是唯一必要架构。本文为 NOT_ATTEMPTED。

APP-A.E1.10 深析 P018：PhotoGuard——把输入图像变成主动防御面　问题与威胁模型。 PhotoGuard 试图让图片所有者在发布前注入人眼较难觉察的扰动，使下游扩散编辑产生明显偏离。防守者控制自己的输入图；攻击者使用已知或近似的编辑模型。本文据此把它定位为提高未经授权编辑成本的输入保护，而不是有害输出检测。[@P018]

机制。作者的编码器攻击使图像潜表示偏离，扩散攻击继续对整个编辑过程优化。本文的方法合同要求保护效果与原图可用性同时衡量，否则"把图片彻底破坏"也会被误算为成功防御。[@P018]

评测与作者报告。本地 PDF 表 6 在 60 张图像等论文设置中，作者报告扩散攻击后的编辑相似度 SSIM 为 0.50±0.09、PSNR 为 13.58±2.23，低于随机噪声基线；同时使用 FID、VIFp、FSIM 等检查。该结果只表明所测编辑模型上输出被扰乱，不证明所有恶意用途被阻断。[@P018]

作者自述局限、本文综合影响与复现状态。模型迁移、JPEG/缩放、去噪和自适应净化可能削弱扰动；防守成本由个体承担，而平台未必保留原始像素。作者讨论了开发组织参与的政策组件；本文据此认为客户端防护不构成完整治理。本文为 NOT_ATTEMPTED。

APP-A.E1.11 深析 P019：Glaze——风格保护同时需要算法和创作者可接受度　问题与威胁模型。 Glaze 关注艺术家公开展示作品后被抓取用于风格模仿。攻击者收集作品并微调风格模型；防守者在上传前给作品施加风格 cloak。受保护资产既包括模型学习到的风格关联，也包括作品对观众和客户的展示价值。[@P019]

机制。作者把作品特征推向一个目标风格，使训练所得关联偏离原作者风格。本文据此定位：与传统分类器对抗样本不同，该工作的目标是影响后续训练而非一次推理。[@P019]

评测与作者报告。作者结合多模型实验、艺术家直接评审和用户研究。PDF p.2 报告正常条件下风格模仿破坏率超过 92%、适应性反制下超过 85%；p.9 报告 1156 名参与艺术家中超过 92% 认为扰动足够小，不破坏作品价值。两类数字的分母不同：前者是防御实验，后者是用户感知，不能合并。[@P019]

作者自述局限、本文综合影响与复现状态。风格相似存在主观性，模型迭代、净化和训练数据混合会造成漂移；“用户愿意使用”也不证明平台保留。本文综合将其影响定位为把正常效用扩展到创作者体验，并把 LightShed 等专门反防御纳入生命周期审计。本文为 NOT_ATTEMPTED。

APP-A.E1.12 深析 P020：Anti-DreamBooth——身份个性化的受控与泄漏条件　问题与威胁模型。 Anti-DreamBooth 研究少量肖像被 DreamBooth 类工具收集后，用户能否通过预先扰动阻止稳定身份个性化。作者显式区分便利/受控设置和不受控设置：后者允许攻击者混入未经保护的泄漏照片。[@P020]

机制。作者以代理个性化训练和扰动优化交替进行，使训练后的模型要么产生明显伪影，要么降低身份相似。本文的方法合同要求把“身份错配”和“图像质量下降”分开，因为二者对应不同受害风险。[@P020]

评测与作者报告。作者在 VGGFace2、多个 Stable Diffusion 版本和提示上用 FDFR、身份相似、SER-FQA、BRISQUE 等指标。PDF p.2 报告受控条件下破坏其测试的 DreamBooth 尝试；表 5 另列干净图混入的不受控结果，避免把全保护条件外推到泄漏场景。[@P020]

作者自述局限、本文综合影响与复现状态。已经被复制的原图、不同个性化算法和社交平台预处理均可能绕过；作者未解决授权撤回后已经流通的 LoRA 和模型副本。本文综合将其影响定位为把“身份同意”转成可测试的模型能力问题，但证据仍不足以形成完整撤回链。本文为 NOT_ATTEMPTED。

APP-A.E1.13 深析 R-A027：VPA-Guard——参考图从外观资产变成时间程序　问题与威胁模型。 VPA-Guard 指出 I2V 参考图中的箭头、草图、emoji 或局部编辑可能被模型解释为动作和事件指令。攻击者控制图像与文本，但安全层若只看图像是否含显式有害内容，就会漏掉“静态符号展开成动态危害”的意图。[@R-A027]

机制。作者构造 VVA-Bench，将视觉提示按操作格式和风险类别编码；防御采用检索增强和自演化示例，尝试解释隐含意图后再决定拒绝。本文据此把首破点定位为 I3 视觉条件，而不是输出检测。[@R-A027]

评测与作者报告。2026 年预印本 PDF p.1 与 p.7 报告，在其版本和裁判协议下，无防御时 Wan、Kling、Hailuo、Veo 的总 ASR 分别为 100.0%、99.6%、81.2%、74.8%。这些数值支持“该基准与当时版本中观察到旁路”，不证明现实发生率，也不应跨服务版本保持。[@R-A027]

作者自述局限、本文综合影响与复现状态。该工作较新，尚缺跨团队复核；MLLM 裁判、模型版本和提示自然度影响结果。本文综合将其概念贡献定位为把“参考图安全”从内容分类扩展到程序语义分析。本文只做本地全文静态定位，状态 NOT_ATTEMPTED。

APP-A.E1.14 隐私、检测和水印：从“能否识别”到攻击—质量—基率合同　这一谱系包含三个不能互换的任务：被动检测对内容作统计判断；水印在生成或后处理中嵌入可验证信号；来源凭证记录签名者声明和编辑链。AUC 高不等于低基率下可部署，水印存在不等于无法移除，凭证有效也不等于媒体语义为真。研究进展主要表现为评测合同越来越严格，而不是某个信号已经成为真值判定。

APP-A.E1.15 深析 P024：Extracting Training Data from Diffusion Models——查询量和人工核验进入隐私分母　问题与威胁模型。该工作询问扩散模型是否会在常规采样中输出训练近副本。攻击者能够大量生成，并可利用高重复训练提示或训练集近邻信息筛选。作者采用严格的近副本定义，而不是把“风格相似”都称为提取。[@P024]

机制。作者先对高重复提示生成大量随机种子候选，再利用生成样本之间的近重复图关系构造团簇，最后人工核验是否匹配训练样本。本文据此把生成、过滤和人工确认记录为三个独立分母。[@P024]

评测与作者报告。作者从前沿模型中提取超过 1000 个训练样本。PDF p.6 明确给出 350,000 个高重复提示、每个 500 次生成，共 175M 图像；p.7 报告可从这些生成中以 0 假阳性识别 50 个记忆样本。这个结果依赖极大查询预算和训练辅助信息，不能写成“普通用户一次提示即可泄漏”。[@P024]

作者自述局限、本文综合影响与复现状态。该定义不能覆盖属性推断、成员推断和语义级记忆；训练集不完整时召回率也不可识别。本文据此定位：查询量、候选数、核验数和重复度是隐私提取研究的必报字段。本文未执行 175M 级生成，状态 NOT_ATTEMPTED。

APP-A.E1.16 深析 P028：Stable Signature——模型级比特签名与极低 FPR 主张　问题与威胁模型。 Stable Signature 希望模型所有者通过轻量微调潜扩散解码器，让后续所有输出携带固定二进制签名。服务掌握签名和提取器；攻击者可裁剪、压缩或改变图像。[@P028]

机制。作者冻结大部分生成器，仅让解码器学习在视觉质量约束下嵌入可恢复比特；检测时提取签名，并用统计检验决定是否来自该模型或哪一身份。[@P028]

评测与作者报告。作者测量 bit accuracy、检测、识别和视觉质量。PDF p.1 报告图像被裁到只保留 10% 内容时仍有 90% 以上检测准确率，所用统计阈值的 FPR 低于 10^-6。如此低的 FPR 需要足够负样本或理论校准支撑；实际部署不能只复述阈值。[@P028]

作者自述局限、本文综合影响与复现状态。生成式再构造、密钥泄漏和伪造不在所有实验覆盖内；解码器微调也要求发布方控制模型。本文综合将其定位为模型内水印代表工作；跨来源的 WAVES 和再生成攻击则提示常见失真鲁棒不等于自适应鲁棒。本文为 NOT_ATTEMPTED。

APP-A.E1.17 深析 P029：Tree-Ring——采样噪声中的指纹　问题与威胁模型。 Tree-Ring 试图避免修改模型权重：服务在初始噪声的傅里叶域写入环状结构，生成后通过扩散反演检出。服务掌握种子/密钥，检测者需要兼容反演模型。[@P029]

机制。作者让水印参与整个采样过程，而非生成后叠加；检测把待测图反演到噪声空间，比较预期环模式与恢复噪声之间的统计距离。作者在表 5 的多密钥实验中采用 Bonferroni 校正；本文将其记录为该论文的归因协议，而不外推成所有水印的唯一校正规则。[@P029]

评测与作者报告。 PDF p.7 说明每次运行使用 1000 张有水印和 1000 张无水印计算 AUC 和 TPR@1%FPR，同时报告 FID/CLIP；表 5 在 FPR=10^-6 下测试 50 到 1000 个用户/密钥。作者报告其方法在纳入的失真集上优于多种后处理水印，但不是“不可移除”定理。[@P029]

作者自述局限、本文综合影响与复现状态。反演模型、采样器和攻击知识影响检测；后续移除/伪造工作暴露了适应性边界。本文综合将其定位为采样原生水印的一类代表机制，不把后续同类方法或平台效果归因于单篇工作。本文为 NOT_ATTEMPTED。

APP-A.E1.18 深析 P030：WAVES——从单点鲁棒率到攻击—质量前沿　问题与威胁模型。水印论文常各自选择失真、阈值和质量指标，无法回答同样攻击质量约束下谁更稳健。WAVES 把攻击者知识分为失真、再生成与对抗攻击，并要求有无水印对照共同进入评测。[@P030]

机制。作者提出的不是新水印，而是标准化压力测试：同一数据、攻击强度和性能阈值下，测量检测下降需要付出的图像质量代价。本文据此要求把攻击质量约束与检测下降同时报告；完全毁掉图像的结果不计为有意义的去水印成功。[@P030]

评测与作者报告。PDF p.3 说明基准纳入 26 种攻击、3 个数据集、每集 5000 真实图和 8 类质量指标, □□□TPR@0.1%FPR 及联合曲线比较三种代表性水印。作者发现再生成和自适应攻击会暴露常见失真测试看不到的弱点。[@P030]

作者自述局限、本文综合影响与复现状态。纳入攻击仍是有限集合，数据分布也不是社交平台链路。本文综合将 WAVES 的影响定位为把“鲁棒”改写为条件性命题：在何种攻击、阈值和质量预算下鲁棒。本文为 NOT_ATTEMPTED。

APP-A.E1.19 深析 P031：Invisible Image Watermarks Are Provably Removable——水印的一般性反例　问题与威胁模型。该工作询问像素级不可见水印是否存在通用再生成去除路径。攻击者能加随机噪声，再调用现成去噪器或生成模型重建。[@P031]

机制。作者先以噪声削弱脆弱的像素信号，再重建语义内容；理论部分在明确假设下讨论可移除性，实验部分实例化多种生成式重建。作者的论证对象是像素级水印，不覆盖所有语义绑定或来源凭证。[@P031]

评测与作者报告。作者在四种像素级方案上同时报告检测率和图像质量，并称再生成攻击较既有攻击取得更低检测和更高质量。具体结论需对照 PDF §2–5 和附录 E，不能把定理改写成“所有水印必然消失”。[@P031]

作者自述局限、本文综合影响与复现状态。理论依赖水印扰动、噪声和重建器假设；强语义水印可能改变问题。本文综合将该反例的影响定位为：后续防御应同时测试移除、伪造、误归属和内容质量。本文为 NOT_ATTEMPTED。

APP-A.E1.20 深析 R-A017：GenImage——跨生成器矩阵比同分布准确率更重要　问题与威胁模型。 GenImage 关注被动检测器是否只记住某个生成器伪影，还是能迁移到未知生成器和退化图像。防守者训练二分类器，测试时生成器或平台变换可能未知。[@R-A017]

机制。作者收集超过一百万对真实与生成图，覆盖 8 个 GAN/扩散生成器，并构造 cross-generator 与 degraded classification 两项任务。本文综合认为，关键证据不只是数据量，而是训练源和测试源被显式拆开。[@R-A017]

评测与作者报告。 PDF p.1、p.3 定位百万对规模；p.6–7 将一个生成器训练的模型在 8 个生成器上测试，并给出完整交叉矩阵。作者结果显示跨生成器平均准确率强烈依赖训练源，说明同分布高分可能是生成器指纹捷径。[@R-A017]

作者自述局限、本文综合影响与复现状态。真实图来源、图像类别和旧生成器版本也可能成为数据捷径；accuracy 不表达真实低基率下的精确率。本文据此定位：依据其跨生成器矩阵，将“未知生成器”列为检测基准的必要审计轴。本文为 NOT_ATTEMPTED。

APP-A.E1.21 深析 R-A029：BlackMirror——无权重访问下的生成后门检测　问题与威胁模型。模型市场或 API 平台可能无法读取权重，只能提交提示观察响应。BlackMirror 尝试在这种黑盒条件下识别对象替换、贴片、风格和固定图像后门。[@R-A029]

机制。作者用 MirrorMatch 定位提示指令与输出视觉模式之间的偏差，再用 MirrorVerify 对模式掩蔽提示重复生成，检查偏差是否稳定，从而区分自然随机性与触发行为。本文据此把防守成本记录为查询量和判定稳定性。[@R-A029]

评测与作者报告。 CVPR 2026 本地 PDF 表 1 比较多类后门与基线，作者报告平均 F1 为 89.46%，同时给出 FPR；部分对象替换配置 F1 更高。该数字只覆盖纳入触发，不能证明对未知后门的完备检测。[@R-A029]

作者自述局限、本文综合影响与复现状态。自然生成波动、隐蔽触发空间和服务速率限制会增加误报或查询成本。本文综合将其贡献定位为补充无法做白盒权重扫描的平台审计节点。本文为 NOT_ATTEMPTED。

APP-A.E1.22 深析 P035：DeepfakeBench——统一实现本身就是评测控制　问题与威胁模型。 Deepfake 检测研究常因人脸裁剪、压缩、数据划分、增强、骨干和指标实现不同而产生不公平比较。DeepfakeBench 不是提出另一种检测特征，而是让基准维护者统一输入和评测，使方法差异不再与工程差异混杂。[@P035]

机制。作者的基准提供统一数据管理、模块化方法实现、标准评测协议和分析工具，把 15 种检测方法放在 9 个 deepfake 数据集上重跑。本文据此把未知数据集、压缩和伪造方法记录为防守侧威胁变量；输入主要是面部视频或帧。[@P035]

评测与作者报告。 NeurIPS 2023 官方摘要明确列出 15 种方法、9 个数据集以及跨增强和骨干的分析。该数字描述基准覆盖，不是“15 个独立研究的元分析”；只有统一重跑的结果才具有较强横向可比性。[@P035]

作者自述局限、本文综合影响与复现状态。基准以面部 deepfake 为主，不能代表开放域文生视频、图像到视频、音画联合或来源凭证；数据集身份也可能成为捷径。本文综合将其定位为统一实现控制案例，而非开放域视频安全的完整基准。本文未运行基准，状态 NOT_ATTEMPTED，官方全文经联网核验但未新增本地 PDF。

APP-A.E1.23 深析 P039：Attacks on Approximate Caches——性能优化层成为隐私与完整性接口　问题与威胁模型。扩散服务为降低成本会复用相似提示的中间状态。该工作问：远程用户能否仅凭查询影响或探测共享近似缓存，从而破坏租户隔离。输入是含特殊关键词或与已有提示相似的请求，攻击者不需要读权重或主机内存。[@P039]

机制。作者利用近似命中行为建立可跨时间恢复的隐蔽信道，利用命中差异推断缓存提示，再把攻击者标志写入被窃提示相关的缓存状态，使后续相似请求得到被污染输出。本文据此把三条路径分别定位为机密性与完整性破坏。[@P039]

评测与作者报告。 USENIX Security 2026 官方页确认隐蔽信道、提示窃取和缓存投毒均通过远程服务接口演示，论文另给代码与预出版 PDF。此处不摘录尚未逐页本地化的持续时间或成功率数字，只保留机制和官方身份。[@P039]

作者自述局限、本文综合影响与复现状态。结论绑定被测近似缓存设计；精确缓存、不共享状态或强租户隔离不是相同威胁模型。本文综合将其影响定位为把缓存、并发和服务优化从“纯性能工程”扩展为 I5 安全接口。本文为 NOT_ATTEMPTED。

APP-A.E1.24 视频化：帧、片段、运动、篡改定位与流式状态 视频不是图像数量增加。它新增帧间依赖、运动语义、镜头顺序、首尾帧约束、长时状态和转码链；联合音画或带音轨系统还新增说话人、声音和音画同步。因此，视频论文若只随机抽帧再调用图像判定器，最多说明“被抽到的帧表现如何”，不能覆盖片段、事件或身份级安全。

APP-A.E1.25 深析 P007：BadVideo——单帧无害、整段有害的时空后门 问题与威胁模型。 BadVideo 研究攻击者控制 T2V 微调数据和过程时，能否利用视频冗余信息隐藏后门目标。输入是文本触发和目标视频；目标可在空间与时间拆分，或者表现为概念/风格随时间变化。[@P007]

机制。作者的 Spatio-Temporal Composition 把恶意语义分散到不同区域与帧，使任一帧或局部都不完整；其他策略使冗余元素动态转变。本文据此把攻击链定位为利用视频状态，而非把图像后门逐帧复制。[@P007]

评测与作者报告。作者同时用 FVD、CLIP/ViCLIP、内容保留率，以及 MLLM 和人工视频级 ASR。PDF p.5–7 保留各指标的定义和表格。这里不抽取单一“成功率”，因为 MLLM 与人工判定、帧级与视频级分母不同。[@P007]

作者自述局限、本文综合影响与复现状态。训练权限强、视频较短、裁判器有限；结论不能外推到长视频、流式生成或闭源服务。本文据此定位：依据其所测时空触发，将片段级审核记录为逐帧审核之外的新增信息来源，而不声称任何单一审核器不可替代。本文为 NOT_ATTEMPTED。

APP-A.E1.26 深析 P034：T2VSafetyBench——十二类风险仍只是视频安全的第一层协议 问题与威胁模型。该基准试图补上 T2V 模型只评画质、不评安全的问题。评测者向多个模型提交现实收集、LLM 生成和越狱得到的恶意提示，再对输出视频判定。[@P034]

机制。作者定义 12 类安全风险，加入视频特有的 temporal risk；对生成视频每秒采一帧，把多帧与原提示交给 GPT-4 评分，并用人工复核相关性。本文综合认为，该协议比单图判定更接近片段，但不能观测短于抽样间隔的事件。[@P034]

评测与作者报告。 PDF p.6 定位 LLM 生成的 1230 个提示，p.7 定位越狱方法生成的 845 个提示。作者综合结论是没有单一模型在所有风险维度占优，安全与可用性存在权衡。提示来源子集不能直接相加为现实事件数。[@P034]

作者自述局限、本文综合影响与复现状态。 GPT-4 裁判、每秒抽帧和风险定义决定结果；不含音轨与直播状态。本文综合将其作用定位为提出 T2V 专属 taxonomy 和人工对照，但不把它解释为现实发生率调查。本文为 NOT_ATTEMPTED。

APP-A.E1.27 深析 R-A023：T2V-OptJail——视频反馈进入越狱优化环 问题与威胁模型。该工作将 T2V 越狱写成离散提示优化，攻击者需要查询生成视频获得反馈。攻击成功同时要求通过服务过滤且输出视频包含目标不安全语义。[@R-A023]

机制。作者的联合目标同时优化输入旁路、对抗提示与原不安全意图的语义一致、生成视频与原意图的一致性。本文综合认为，相比图像越狱，视频生成时间和费用使查询预算成为更显著的报告维度。[@R-A023]

评测与作者报告。作者在多个开源和商业 T2V 模型上报告平均 ASR 相对基线提升约 7 个百分点；PDF p.7 显示不同模型和风险类别间结果差异显著。p.9 明确承认需要查询生成视频反馈会增加预算。[@R-A023]

作者自述局限、本文综合影响与复现状态。输出过滤使用抽帧和分类器，可能漏掉跨帧事件；服务更新可使结果过时。本文综合将其影响定位为把 T2V 红队从固定提示集扩展到自适应闭环。本文没有访问真实服务，状态 NOT_ATTEMPTED。

APP-A.E1.28 深析 R-A020：VideoShield——水印从整段检测扩展到时空篡改定位 问题与威胁模型。 VideoShield 面向生成服务控制采样过程的场景，试图在不额外训练的情况下给视频嵌入水印，并定位帧顺序变化、帧替换和空间编辑。[@R-A020]

机制。作者把水印比特映射为模板比特并参与生成；帧间模板关系允许时间定位，帧内模板允许空间定位。本文据此把其合同记录为不仅判断“是否 AI 生成”，还定位“哪一帧、哪一区域被改过”。[@R-A020]

评测与作者报告。论文测量比特提取、视频质量和时空篡改定位。PDF 表 13 在所测空间篡改下报告提取准确率接近 100%。该结果不能代表未知生成式重构、社交平台转码、密钥泄漏或伪造场景。[@R-A020]

作者自述局限、本文综合影响与复现状态。方法与扩散结构耦合，部署需要模型方参与；本文综合认为，撤销、密钥轮换和平台处置仍在该论文评测的系统边界之外。本文为 NOT_ATTEMPTED。

APP-A.E1.29 深析 P033：VideoSeal——流式效率成为水印的一等指标　问题与威胁模型。 VideoSeal 关注开放、通用且可高效运行的视频水印。嵌入方控制媒体后处理而不必控制生成器；攻击者可做编码、裁剪、亮度和几何变换。[@P033]

机制。作者联合训练轻量 2D 嵌入器和提取器，并在训练中显式加入视频 codec；时序传播只在每隔 `k` 帧嵌入，再把扰动传播到后续帧，从而减少高分辨率逐帧计算。[@P033]

评测与作者报告。论文在 SA-V 视频上报告 bit accuracy、感知质量和 CPU/GPU 速度。PDF p.17 显示，提高时序传播步长可显著加速，并在其 H.264+ 裁剪 + 亮度组合下未造成同量级鲁棒损失；同页也报告较大步长可能产生 shadow/blink 或 glitter 类视觉伪影，因而实验选择较小步长（如 `k=4`）平衡速度与不可感知性。来源报告强调对组合失真优于所测强基线。[@P033]

作者自述局限、本文综合影响与复现状态。它是媒体水印，不自动声明具体生成器、提示或语义真实；时序步长还存在视觉伪影—速度权衡，平台重编码、密钥与伪造仍需生命周期测试。本文综合把吞吐、首次告警、不可感知性和流式状态共同纳入视频水印合同。本文为 `NOT_ATTEMPTED`。

APP-A.E1.30 深析 R-A025：I2VGuard——防护目标必须同时包含画质与运动　问题与威胁模型。 I2VGuard 研究图片所有者能否给参考图加小扰动，使未经授权的 I2V 动画在外观或运动上失效。攻击者使用 SVD、CogVideoX 等模型，防守者不控制生成服务。[@R-A025]

机制。作者用空间目标把生成结果推向低质量分布，以时间目标扰乱注意力和运动一致性，并用扩散攻击模块提升跨模型迁移。本文的方法合同要求同时检查运动幅度：只降低图像质量不等于真正阻断动画，静止输出也可能让某些一致性指标虚高。[@R-A025]

评测与作者报告。作者同时使用 PSNR、SSIM、FID、主体一致、运动平滑、动态程度和美学指标；PDF 表 1 报告原图与保护图在 SVD/CogVideoX 上的均值和方差，并排除极高主体一致与平滑但本质静止的异常结果。[@R-A025]

作者自述局限、本文综合影响与复现状态。社交平台预处理、自适应净化和新架构会改变扰动；保护成功定义需预注册。本文据此定位：依据其 I2V 输入保护协议，建议图像防护迁移到视频时新增运动与片段分母；这不是对所有视频生成任务的普适证明。本文为 `NOT_ATTEMPTED`。

APP-A.E1.31 深析 R-A026：Anti-I2V——从 UNet 扩展到 DiT/MMDiT 的迁移审计　问题与威胁模型。 Anti-I2V 针对既有防护在 DiT/MMDiT 视频骨干上的未知有效性。防守者可以在 RGB、Lab 和频域优化照片；攻击者用多种 I2V 生成器。[@R-A026]

机制。作者选择去噪过程中特征最有区分力的层，在颜色和频域联合优化，使身份保真和时间一致性同时下降。本文据此把“骨干变化”记录为防御迁移变量。[@R-A026]

评测与作者报告。 CVPR 2026 正式全文表 1 按数据集和模型报告画质、身份与运动相关指标，并用箭头标注某些低值才代表更强保护。作者报告相较纳入基线取得更强跨骨干结果；不能把不同方向指标机械平均。[@R-A026]

作者自述局限、本文综合影响与复现状态。本文综合认为，该新工作仍缺长期独立复核；扰动经截图、重编码和平台处理后的保留未知。本文为 `NOT_ATTEMPTED`。

APP-A.E1.32 谱系闭合：继承关系、反例与未独立复核项　仍未独立闭合的结论包括：LoRA 与运动模块在大规模组合中的触发涌现；视频训练数据的事件级提取；实时音画联合攻击；低延迟直播水印；来源凭证经过真实平台转码后的保留与申诉效果；生成服务的显存、排队和账单放大。这里的“文献稀缺”不是安全证据，而是最低验证需求。



表：代表性研究谱系索引

深析 ID	工作	谱系阶段	核心机制
D01	How to Backdoor Diffusion Models?	奠基攻击	联合修改数据和扩散过程，使正常输入保持效用、触发输入
D02	TrojDiff: Trojan Attacks on Diffusion Mod...	机制扩展	把目标扩散到偏置高斯分布并学习相应逆过程
D03	Rickrolling the Artist: Injecting Backdoo...	供应链迁移	教师—学生式编码器注入，把触发嵌入重映射到目标概念
D04	Nightshade: Prompt-Specific Poisoning Att...	数据投毒扩展	利用单概念有效样本规模远小于总语料，构造 prompt-sp
D05	When LoRA Betrays: Backdooring Text-to-Im...	适配器供应链	冻结基础模型，只更新低秩权重以藏入触发映射
D06	BadVideo: Stealthy Backdoor Attack agains...	视频化攻击	在空间和时间上拆分恶意语义，或让冗余元素随时间转变

注：数据源为 `paper/tables/paper_lineage.csv`；正文显示 6/27 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

附录 B. 数据集、指标、完整比较矩阵与统计拒绝记录

APP-B.E1 证据展开：数据集、指标、基准与可比性

APP-B.E1.1 先锁定统计单位：请求、响应、图像、帧、片段、视频与身份 对在线服务，应保留六个嵌套计数：`requests` 为请求数，`responses` 为服务返回数，`valid_responses` 排除损坏或空输出，`judgeable_responses` 为裁判器和人工都可判定的输出，`policy_accepted_inputs` 为穿过输入门的条件，`successful_attacks` 为满足预注册端到端目标的样本。若 `valid_responses=0`，生成质量与 ASR 应为 `NA`，不能把零有效响应写成 0% 攻击成功，也不能把拒绝全部移出分母。对重复查询同一提示，还应报告提示级聚类，否则随机种子会被当作独立研究单元。

视频至少有四级分母。帧级分母适用于像素或局部水印，但帧之间相关，不能把 100 帧当作 100 个独立视频；片段级分母适用于跨帧组合、短事件和首次告警；视频级分母适用于整段检测、来源保留和处置；身份级分母适用于冒用、个性化和受害者风险，同一人的多段视频不能扩成多个独立身份。T2VSafetyBench 每秒抽帧的协议是一种可复算折中，但无法证明抽样间隔内没有短时风险；BadVideo 的时空目标更直接说明随机帧不是充分单元。[@P034] [@P007]

对训练数据提取，生成图像数、候选数、自动筛选阳性数、人工确认近副本数和独立训练样本数必须分列。Carlini 等人的 175M 生成、候选聚类与最终人工确认就是不同分母；只报告“提取超过 1000 个”会隐藏查询成本。[@P024] 对新闻与治理，最小单位是事件或有效通知，不是报道篇数；多个媒体报道同一事件不能算作多个攻击。

APP-B.E1.2 攻击、残余风险与正常效用的三联报告 攻击指标必须同时回答是否成功、使用了什么预算，以及正常任务损失多少。本文因此将报告合同合并为三联向量：`Attack = (成功判定, 有效分母, 权限/预算)`；`Utility = (干净质量, 任`

务保持，用户可接受度）；Residual =（适应性攻击，未知模型/条件，部署失真）。任一分量缺失时，该结果不进入跨研究性能排序。

后门 ASR 的成功判定应列出目标类型：类别、对象、风格、固定图像、时间事件或身份。TrojDiff 的 In-D2D ASR 与 D2I 目标 MSE 不是同一指标；MasqLoRA 的单模块 99.8% 和四模块 91.6% 也不能与 BadDiffusion 的毒化率直接排序。[@P002] [@P006] 条件越狱应至少拆成条件接受率与端到端违规率：提示通过过滤但输出被拦截，只证明输入防线失效，不证明系统输出危害内容。

残余风险的关键是适应性。防御知道攻击但攻击不知道防御，只能支撑非适应性鲁棒；攻击者知道防御类别、阈值或可训练代理时，才接近现实压力。水印攻击还需要质量约束：把图像压成无法观看后去掉水印，不是有意义的成功。WAVES 用同一攻击强度下的 TPR 和八类质量指标构造攻击—质量前沿，是比单点“移除率”更可靠的比较方式。[@P030]

正常效用不限于 FID。图像防护应报告原图可视质量、合法编辑可用性和对不同群体的影响；视频防护应同时报告主体保持、运动平滑、动态程度和内容语义。I2VGuard 特别排除“指标看似一致但输出实际静止”的异常值，说明任何时序一致性都需与运动幅度配对。[@R-A025] 平台防御还要报告时延、人工复核量、误伤、申诉和重复上传，而不能把模型精度当成处置效果。

APP-B.E1.3 图像质量、视频质量与时序指标的盲点 FID 由 Heusel 等人提出，以 Inception 特征中的均值和协方差比较生成集合与参考集合；KID 由 Bińkowski 等人提出，以 Inception 特征上的核 MMD 构造集合级估计。两者都不是单图安全判定器。原始 KID 工作强调其无偏估计性质，而后续 CVPR 方法学研究指出有限样本 FID 存在依赖模型与样本量的偏差；因此本文的方法合同要求固定并报告参考集、特征网络、分辨率、预处理、样本量与不确定性，不能笼统写成“同样本量即可跨实现比较”。[@R-M001] [@R-M002] [@R-M004] CLIPScore 或图图 CLIP 相似可以衡量语义，但高相似不等于版权侵权、身份冒用或现实危害。PSNR、SSIM 和 LPIPS 适合成对输入/输出比较，却会把某些小语义修改视为近似，也会把颜色空间和裁剪差异混入。

FVD 的原始工作把 Fréchet 式分布距离移到视频特征空间，用于集合级生成视频评价，而不是动作语义或单片段安全判定。[@R-M003] 本文的方法合同据此要求报告视频特征模型、帧数、帧率、分辨率与片段采样：不同论文若用 16 帧和 49 帧、8fps 和 24fps、首段和随机片段，就没有共同的 FVD 比较合同。时序一致性可由相邻帧特征、光流、轨迹或视频语言模型测量，但每一种都可能把静止输出评价得过高；因此本文建议至少并报动态程度、最长稳定片段和事件完成率。

视频安全裁判也不能只把多帧拼成图像网格。对于“先拿起对象、后执行动作”的事件，成功定义必须包含顺序；对于视觉提示攻击，输入图中的箭头需要与后续运动绑定；对于音画伪造，还要记录音轨采样率、同步容差和说话人/人脸身份。当前中央论文池对音画联合生成覆盖不足，这一项应写成证据缺口，不应用传统 deepfake 检测结果填补。

可比性最低字段包括：模型和服务精确版本、生成种子和请求时间、图像尺寸，视频片长/帧率/音轨，攻击权限和预算，防御阈值和校准集，输入/输出裁判器及版本，有效响应分母，干净效用，适应性攻击，失败案例以及硬件成本。缺任一关键字段的工作仍可作为案例，但不能进入跨论文总排名。

APP-B.E1.4 检测、水印和来源证明：低基率、密钥与生命周期 ROC-AUC 是在所有阈值上衡量排序能力，不等于部署阈值上的精确率；类别极不平衡时，精确率—召回报告比只看 ROC 更直接反映阳性预测中的误报负担。[@R-M005] 这不是本文对某个平台基率的经验估计，而是由混淆矩阵定义得到的方法合同：若阳性基率记为 p，则 precision=(p×TPR)/(p×TPR+(1-p)×FPR)。仅作算例，令 p=0.001、TPR=0.9、FPR=0.01，精确率约为 8.3%，说明固定 ROC 点不能脱离部署基率解释。因此本文建议部署报告给出 TPR@ 固定 FPR、每万真实内容误报、精确率、校准误差、拒答率和人工复核量。对于 FPR<10^-6 声称，本文的方法合同要求区分理论阈值、独立负样本实测与外推；数千个负样本上的零观测误报只能给出该样本的点观察，不能经验解析百万分之一量级，必须另报置信上界和负样本量。

GenImage 的跨生成器矩阵说明检测器会对生成器代际漂移；DIRE 等方法则说明重建误差可能提供更跨模型的表征，但依然受反演模型和新生成范式影响。[@R-A016] [@R-A017] 因此，检测基准需要时间切分、未知生成器、平台压缩、真实图来源平衡和自适应攻击。训练集与测试集若共享身份或数据来源，模型可能学到数据集身份而不是生成痕迹。

水印至少分为 bit recovery、资产级检测和密钥/用户归因。平均 bit accuracy 高，不意味着每个资产都通过纠错阈值；检测阳性也不意味着能正确归给某个用户。Tree-Ring 在表 5 的 50 至 1000 用户/密钥实验中采用 Bonferroni 校正；本文据此把“密钥数、单密钥阈值、家族层级误报控制及拒答规则”列为多密钥归因必报字段，而不把该校正写成所有方案的唯一选择。[@P029] Stable Signature、Tree-Ring、VideoSeal 和 VideoShield 的载荷、嵌入位置、检测方法不同，只能在统一攻击、密钥规模、阈值和归因规则下作条件比较。[@P028] [@P029] [@R-A020] [@P033]

来源证明又是另一合同。C2PA 2.4 描述 manifest、assertions、硬/软绑定、数字签名、信任列表、撤销与验证状态；其信任模型首先回答“谁签了什么声明、资产是否被篡改”，并不自动判断签名者陈述为真。[@O001] 生命周期指标应按节点报告：

生成时嵌入、编辑器导入、导出、平台上传、转码、下载、截图/录屏、再上传、撤销和申诉。保留率的分子是仍可验证且正确连接 manifest 的资产，分母是进入该链路的带凭证资产；凭证被剥离和凭证存在但恶意签名是两类失败。

本文建议把水印、来源凭证、被动检测与平台处置作为可按部署条件组合的候选控制，但现有异构证据不足以证明某个固定组合“最可靠”，也不能把它们合并成一个“真假分数”。NIST 将检测、水印、认证来源和标签列为不同技术路径，支持的是各自假设和失败模式不同这一点。[@O005] 联合系统的最低指标应包括覆盖、误归因、来源中断点、首次告警、处置时延与申诉结果，而非只报算法 AUC。

APP-B.E1.5 统计拒绝规则与本综述的可声称上限 本综述拒绝对现有论文做无条件元分析。理由不是样本少，而是研究单元和方差结构不兼容：后门论文的成功定义不同；越狱论文使用不同模型版本、查询预算和裁判器；水印论文的 FPR、攻击强度和质量约束不同；视频论文的帧率、片长和聚合不同；部分结果只有生成样本级比例，却把同一模型、提示或身份的重复样本当独立观测。缺少独立研究单元、共同分母和方差时，森林图与 I^2 会制造精确性幻觉。

允许的定量综合只有三类。第一，同一论文内统一协议下的消融和模型比较；第二，由基准组织者在同一数据、代码和阈值下重跑的方法；第三，能够取得原始计数、重新定义共同终点并对提示/身份/模型聚类的再分析。即使满足，也要把作者团队、模型版本和数据来源视为层级因素。

明确拒绝以下转换：把模型内部 ASR 转成现实滥用概率；把 AUC 转成平台精确率而不指定基率；把新闻事件数转成年度发生率；把举报量当独立受害者数；把水印常见变换鲁棒转成不可移除；把 C2PA 验证通过转成内容真实；把静态代码审计转成复现成功。`metric_contracts.csv` 给出 24 项指标的分子、分母、必报字段、失败规则与可比性条件，可直接作为主稿表 10 和附录 E 的数据源。

APP-B.E1.6 建议的基准矩阵与最低报告模板 图像攻击基准应交叉首破接口 I1–I6、白盒/灰盒/黑盒、目标类型、预算、模型家族、干净效用和适应性防御。视频基准在此基础上增加输入类型（文本、首帧、尾帧、轨迹、姿态、音频）、样本单位（帧、片段、视频、身份）、片长/帧率、运动强度、音画同步与流式状态。每个单元应保留请求、响应、有效响应和可判定响应计数。

水印/来源基准应建立链路矩阵：原始文件、单次转码、多次转码、几何编辑、局部拼接、截图、录屏、再生成、平台上传下载、凭证剥离、密钥泄漏、密钥撤销和恶意签名者。每格同时报告检测、归因、内容质量与凭证验证状态。对于直播，增加首次可靠告警、窗口大小、吞吐和断流恢复。

平台治理基准不应让研究者上传真实伤害内容。可以用合成、授权和受控模拟材料，评估标签展示、用户理解、举报、有效通知、下架、哈希/指纹重复阻断、申诉和证据保全。结果按流程时间和错误类型报告，并对受害者、创作者、被误报用户和平台审核员分别分析。这样才能把算法性能连接到现实处置，而不跨越证据链。

表：指标、样本单位与解释盲点

指标	分子	分母	失败/NA 规则
攻击成功率 ASR	成功且可判定攻击、有效攻击试次	请求或预注册攻击试次	零有效响应时为 NA；拒绝不得悄悄剔
条件接受率	输入网关接受的攻击条件	全部提交条件	接受不等于生成有害输出
端到端违规率	通过输入门且输出被独立判为违规的响应	全部有效请求；另报全部请求	应同时保留拒绝、错误和不可判定
目标相似度、CLIPScore	样本级图文或图图相似	有效生成样本	高相似不证明法律侵权或危害
FID、KID	生成分布与参考分布的特征距离	固定规模生成集与参考集	不适合单样本；不测安全
LPIPS、PSNR、SSIM	成对图像的感知或像素差异	成功配对样本	低相似可能只是破坏正常效用

注：数据源为 `paper/tables/metric_contracts.csv`；正文显示 6/24 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

附录 C. 32 张事件卡、新闻与政策时间线

APP-C.E1 证据展开：新闻、真实事件、产品安全与政策时间线

APP-C.E1.1 编码规则：事件日期不等于报道日期，归因不等于发生率 本章完整覆盖中央事件卡 E001–E032，每个事件只计一次；多篇报道作为来源链，不新增事件。事件日期描述行为、生效或产品变更发生的时间，发布日期描述证据文件出现时

间。五段证据链分别是：生成/编辑是否被一手材料确认；内容如何进入传播或业务流程；可观察后果是什么；现实伤害是否有独立证据；官方、司法或平台如何响应。任何未知环节都保留为未知，不能用常识补齐。

证据 A 级主要指法规正文、法院/司法记录、政府书面答复和可核验标准；B 级多为供应商、平台或机构自报，能证明“该组织作了何种声明或动作”，但独立性有限；C 级为高信誉媒体交叉，通常只能支撑事件存在和公开反应，不能确定具体生成器、攻击者或传播总量。报道密集反映媒体选择、司法公开度和平台透明度，不是攻击发生率。`event_timeline.csv` 逐项保存生成证据、传播、后果、官方响应、未知项和来源 ID。

APP-C.E1.2 身份冒充、诈骗与政治传播簇（E001–E003、E007、E011–E012、E025）　E001 香港约 2 亿港元深伪视频会议诈骗。生成证据来自香港政府 LCQ9 书面答复：公开网络视频和声音被下载，预录深伪会议用于冒充管理层。传播链不是公开社交传播，而是组织内部会议和转账授权；可观察后果是员工向 5 个本地账户转出约 2 亿港元。现实财产损失由政府答复确认，官方响应包括警方调查、账户追踪、金融机构协作和反诈骗宣传。未知项包括会议是否实时生成、具体模型、每笔追回金额和攻击者技术栈。[@O048] [@O049]

E002 香港近 400 万港元 CFO 冒充案。官方答复确认 2024-05-20 左右，员工经即时消息进入冒充 CFO 的视频会议并转账。与 E001 相同，它证明身份与业务授权流程被攻破，不证明某种 T2V 模型具有特定 ASR。现实后果是近 400 万港元损失；案件调查状态以 2024-06-26 答复为限。实时性、生成器和追回情况仍未知。[@O048] [@O049]

E003 冒用香港行政长官形象和声音的虚假投资广告。政府公告确认广告为虚假并公开否认背书。生成/编辑方法、发布者和传播规模未披露，因而只能确认身份/授权状态失真及诈骗暴露风险，不能确认损失。官方响应是澄清与公众提醒，执法进展未知。[@O050]

E007 五角大楼附近虚假爆炸图像。权威机构澄清没有发生相应爆炸，媒体记录到图像传播和短暂市场波动；“由 AI 生成”的技术归因仍应写作疑似或可能，而不能从画面外观反推。传播发生在社交平台和新闻聚合链，现实因果损失无法从短暂市场波动单独识别；攻击者、工具、初始账户和获利均未知。[@O070] [@O074] [@O075]

E011 台湾选举影响行动。微软威胁分析报告称影响行动在 2024 年台湾选举相关内容中使用 AI 生成元素。该来源是机构威胁情报，可支撑其观察和归因判断，但不等于公开司法认定。传播链涉及社交内容与政治叙事，现实投票影响缺乏反事实证据；生成比例、具体模型和受众行为效应未知。[@O063] [@O064]

E012 乌克兰战争相关伪造投降视频与冒用网络。 Meta 公开处置材料确认平台移除伪造投降视频和相关冒用网络。这里的平台日志可证明内容存在与处置动作，但不能独立证明制作工具、国家行为归因或现实战略效果。官方/平台响应是删除、账户网络处置和公开披露；跨平台再上传情况未知。[@O065] [@O066]

E025 虚拟绑架中的存活证明照片和视频。 FBI 警告犯罪者会修改照片或视频用于虚拟绑架勒索。官方警告能证明执法部门观察到该作案模式，不能给出全体案件发生率。传播链是攻击者向家庭发送“存活证明”并施压转账；个案损失、生成器、真假材料混合比例和受害规模未在本事件卡中给出。[@O062]

按本文编码，这七个主题性案例的主要失效集中在 I7 的身份与授权流程；这一分布来自有目的的事件选择，不能代表现实总体。案例显示，生成技术之外，账户控制、组织流程、平台推荐和受众判断也参与了转账、传播或政治影响链。因此该类场景的防御不能只部署深伪检测器，还应评估回拨核验、双人授权、独立支付渠道、账户异常检测、平台溯源和事件响应。

APP-C.E1.3 产品对齐、暂停恢复与生命周期簇（E004–E005、E031–E032）　E004 Google 暂停 Gemini 人物图像生成。供应商确认人物生成产生不准确或冒犯性历史/人物表示，随后暂停能力。生成证据强于媒体猜测，因为产品方确认了自身系统和动作；但原因解释、数据和评测集由供应商自报，缺独立复现。可观察后果是服务可用性下降和表示性争议，不能写成外部攻击成功。[@O046]

E005 以 Imagen 3 分阶段恢复人物生成。 Google 宣布改进数据、安全过滤与红队后向部分用户恢复。该事件是 E004 的产品响应续篇：能证明恢复和限制声明，不能证明独立安全有效性。地区、套餐与模型版本动态变化，部署效果需持续外部测量。[@O047] [@O046]

E031 Sora Web/App 产品面显示 2026-04-26 起不再可用。官方帮助页区分产品面：Web/App 的停用节点为 2026-04-26，API 另有计划节点（页面列为 2026-09-24）；这两个日期都不能自动解释为模型权重或全部 Sora 能力同日终止。页面没有说明下线源于安全问题，因此不能把“停止服务”编码为防御成功或事故响应。相关系统卡只能描述供应商在特定版本上声明的红队、人物和误导内容缓解。[@O021] [@O019] [@R-A035]

E032 Stable Video Diffusion 托管 API 于 2025-07-24 停用。 Stability AI 公告支持托管接口生命周期，不能推导模型撤回；自托管权重与代码路径仍可能存在。对安全研究而言，应区分服务版本终止、权重仍可下载和生态继续使用三种状态。[@O033] [@O032] [@O079]

这一簇防止一种常见因果错误：产品暂停、恢复或退役是可观察组织行为，但原因必须由来源明确。供应商模型卡和公告适合证明政策、能力范围与自报缓解，不适合证明现实平台长期效果。

APP-C.E1.4 训练语料与模型供应链事件簇（E008–E010）　E008 LAION 暂停 LAION-5B 下载。LAION 机构声明在外部研究指出疑似 CSAM 链接风险后暂停索引下载并开展安全审查。这里的资产是 URL/元数据索引及其下游训练使用，不应写成 LAION 服务器存储全部底层图像。传播后果是数据集可用性中断和下游合规风险；底层内容取证、受影响链接比例和既有副本去向仍不完整。[@O051] [@O076]

E009 Re-LAION-5B 发布。机构于 2024-08-30 发布经修订、重新过滤的版本，作为 E008 的响应。官方声明可证明重建和过滤流程被执行，但不能证明零漏检或所有镜像更新。真正的治理问题是旧索引副本、模型已训练状态和持续撤回，而不是新文件是否存在。[@O052] [@O051] [@O076]

E010 Hugging Face 披露 2026 年 7 月模型评估安全事件。平台安全通告确认评估/模型生态中的安全事件和响应；具体漏洞、受影响制品、执行链和修复范围以原公告为限。本文把它作为跨模态评估基础设施的桥接事件：它直接支持远程加载与评估环境需要隔离、最小权限和事件响应，不能单独证明安全序列化或模型扫描的普适效果，也不能据一次披露估计仓库总体恶意率。安全格式与扫描建议另由第 14 章的官方安全文档支撑。[@O053] [@O054]

这三项事件将 I1/I2 从论文威胁模型连接到真实维护动作：数据集事件直接涉及停用、重建、版本与撤回，模型评估事件直接涉及隔离、最小权限与响应；扫描和安全格式是结合第 14 章官方文档提出的纵深防御，而非由 E010 单独推出。任何“已修复”声明都应附版本、时间和旧副本处置范围。

APP-C.E1.5 非自愿亲密影像、儿童安全与执法簇（E006、E018–E024）　E006 Taylor Swift 非自愿露骨合成图像传播。AP 与 Reuters 等高信誉媒体确认内容广泛传播及平台/政府公开回应，但没有可得的一手案件卷宗。因此生成器、攻击者、精确传播量和因果伤害不应补写；可确认的是未经同意的身份表征进入平台传播并引发处置讨论。证据等级为 C。[@O071] [@O072] [@O073]

E018 TAKE IT DOWN Act 成为联邦法律。 2025-05-19 签署的 Public Law 119-12 建立非自愿亲密图像和 digital forgery 的刑事条款与平台有效通知后移除义务。它是制度节点，不证明此前或此后事件数量；研究应测量通知有效性、48 小时流程、重复内容和申诉。[@O014] [@O015]

E019 全国首宗相关认罪。 DOJ 于 2026-04-07 称一名被告就包括 digital forgeries 在内的罪名认罪，并称为全国首例 TAKE IT DOWN Act 定罪相关案件。司法状态是认罪，不应与指控混淆；案件同时含真实和 AI 材料、网络跟踪和其他罪名，不能把全部伤害归给生成模型。[@O055]

E020 两人被捕并被控发布 AI 深伪色情。 2026-05-20 刑事控告指称两名被告发布大量涉及可识别女性的图像/视频。发布量和浏览量属于控告材料，案件仍适用无罪推定；当前证据证明司法程序和指控事实，不是最终定罪。[@O056]

E021 域名扣押。 DOJ 与 DHS 于 2026-06-12 扣押被指用于发布非自愿数字伪造内容的域名，并说明法官认定存在支持扣押令的 probable cause。域名扣押、法国逮捕和未来刑事责任是不同程序状态；它证明跨境执法与基础设施处置，不证明所有站内内容由同一模型生成。[@O057]

E022 AI 生成裸照相关网络跟踪起诉。 2026-06-18 美国司法材料描述联邦大陪审团起诉网络跟踪，指称使用 AI 生成裸照和伪造账户放大骚扰。起诉只是指控，当前罪名并不等于 TAKE IT DOWN Act 定罪。现实后果是被指控的持续骚扰和身份攻击，具体生成器未知。[@O058]

E023 含 AI 生成 CSAM 的混合儿童剥削案件有罪裁决。 2026-02-06 DOJ 宣布陪审团对接收、持有真实与 AI 生成儿童性虐待材料等罪名作出有罪裁决。该案材料确认使用文本到图像程序生成部分内容；同时存在真实受害材料，故不得把混合罪行全部归因 AI。[@O059]

E024 NCMEC 关于生成式 AI 儿童剥削举报。 2024-12-13 页面称此前两年收到超过 7000 条相关举报。举报条目不等于独立事件、受害者或司法确认样本，且报告表单与分类随时间变化。NCMEC 截至 2026-08-09 的更新页面进一步列出 2023–2025 分类统计，并明确并非所有带 AI 关联的报告都涉及生成或分享 GAI CSAM；因此最新数字只能按官方口径分别引用，绝不能拼成发生率趋势。[@O060] [@L-S005]

APP-C.E1.6 标识、来源证明与平台执行簇（E013–E017、E028–E030）　E013 Meta 承认误标真实照片。Meta 说明其事实核查/标记系统曾把经过普通编辑的真实照片错误标成 AI 相关内容。它提供一个重要反例：更积极的标签不必然更安全，误报会损害真实内容信誉。该事件可核验的是平台承认标签误用；它不是已证实的生成事件，生成器字段为 `NA`/未证实。官方响应是调整标签和解释机制。[@O080] [@O042]

E014 中国标识办法与 GB 45438-2025 施行。 2025-09-01 起，《人工智能生成合成内容标识办法》和强制性国家标准同步实施，区分用户可感知的显式标识与文件元数据中的隐式标识，并对生成服务和内容传播服务分配责任。法规禁止恶意删除、篡改、伪造或隐匿标识；但跨平台保留、误报和申诉仍需实证。[@O009] [@O012] [@O010] [@O011]

E015 中国网信部门公布应用处置。 2025-11-25 监管公告列出一批生成合成内容标识违法违规应用的处置。该证据能确认执法动作和被点名应用，不应除以应用总数估计违规率，因为筛查框架、覆盖和抽样分母未公开。[@O013] [@O009]

E016 欧盟 AI Act Article 50 义务开始适用。 Regulation (EU) 2024/1689 的相关透明度义务自 2026-08-02 适用，分别涉及提供者的机器可读标记/检测与部署者对深度伪造等内容的披露；欧委会问答同时说明，此前投放市场的相关系统存在至 2026-12-02 的过渡安排，具体适用对象、例外和解释仍应回到正式法源。法律义务、过渡期与技术有效性是三层证据。[@O006] [@O007] [@O008]

E017 欧委会最终实践准则。 2026-06-10 公布的最终准则帮助提供者和部署者实施 Article 50(2)、(4)、(5)，网页在 2026-07-29 更新并链接统一图标与签署流程。该准则是自愿工具；签署、遵循或欧委会充分性意见都不是决定性的合规证明，更不等于平台转码后标记 100% 保留。[@O007] [@O008] [@O007]

E028 C2PA 合规计划与 Trust List 启动。 2025 年中期，C2PA 正式信任列表和合规生态进入运行阶段；技术规范 2.4 定义 manifest、签名、验证、撤销和信任锚。事件日期在中央卡中为 NR，因而只写启动窗口，不虚构单日。证书受信证明签名链，不能证明声明语义真实。[@O003] [@O004] [@O001] [@O002]

E029 TikTok 读取 Content Credentials 自动标注。 TikTok 于 2024-05-09 宣布读取 C2PA Content Credentials，对外部生成的图像和视频自动标注。这是平台部署声明，能够证明产品计划和信号接口；真实上传下载链的保留率、错误标签和覆盖仍需独立评测。[@O045] [@O001] [@O077]

E030 YouTube 强化 AI 标签。 YouTube 于 2026-05-27 宣布把 AI 标签移至更显著位置并引入自动识别信号。它说明平台从用户自报向多信号执行扩展；用户理解、不同语言呈现、误报、申诉和重复上传结果尚未由该公告证明。[@O044] [@O043] [@O001]

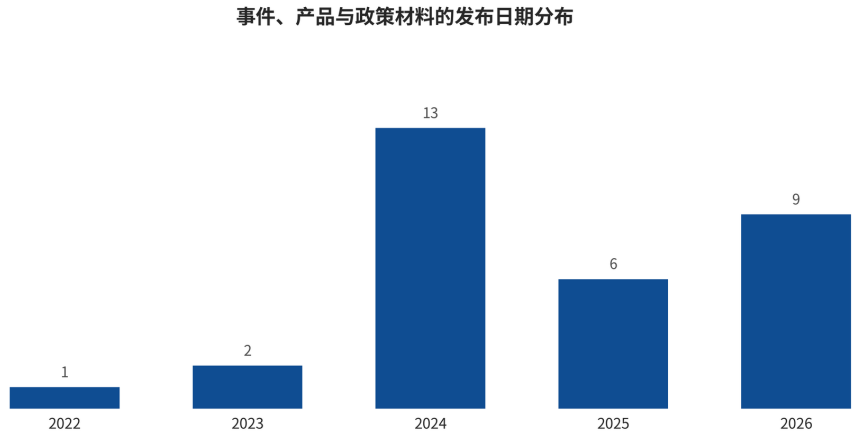
这一簇形成“模型标记—文件凭证—平台读取—用户展示—处置申诉”的链。任一节点丢失都会中断对应的凭证路径或降低覆盖，但冗余水印、软绑定和平台日志可能保留其他线索，不能笼统写成覆盖归零；反之，链条完整也只表明来源声明可验证，不表明媒体表达的事件真实。

APP-C.E1.7 版权与诉讼边界簇（E026–E027）　E026 Andersen v. Stability AI 阶段性裁定。 截至 2024-08-12 这一程序节点，美国法院允许部分主张继续审理。程序性“允许继续”不是最终侵权或责任认定；它只能支持该日的诉讼状态、主张类型和下一步程序。生成模型训练是否复制、输出是否实质相似、各被告责任需按后续案卷分别判断。[@O067]

E027 Getty Images v Stability AI 英国判决。 截至 2025-11-04 这一裁判节点，英国高等法院发布 [2025] EWHC 2863 (Ch) 判决。正式判决可支撑该案裁判结论和法律分析，但不能直接转化为任意模型或司法辖区的技术安全规则；训练地、权重、输出、商标与版权主张应分开。[@O069] [@O068]

两项诉讼说明技术论文的“相似度”“记忆”或“训练使用”不能自动等于法律侵权。综述应把论文观测、权利主张、程序阶段和最终裁判放在不同列，避免把实验指标用作法律结论的替代品。

APP-C.E1.8 跨事件综合：能证明什么，仍然不知道什么　当前 32 项材料能够覆盖多种证据接口，但这种覆盖不构成时间增长趋势：政府书面答复能确认财产损失和调查；供应商公告能确认产品动作；司法记录能区分起诉、认罪、裁决与扣押；法规和标准能定义义务；平台公告能确认标签功能；媒体只能在缺少一手卷宗时提供受限交叉。不同类型来源彼此补充，不能替代。



样本：32 张事件卡（A 级 16；B 级 14；C 级 2）。柱高是编辑性样本数，不是事件发生率、危害规模或增长趋势。

表：事件主题簇与证据上限

主题簇	纳入事件卡数	事件日期跨度	证据等级构成	响应示例
产品对齐、暂停恢复与生命周期	4	2024-02-22 至 2026-04-26	B:4	Google 道歉、解释调优问题并暂
标识、来源证明与平台执行	8	2024-05-09 至 2026-08-02	A:5、B:3	Meta 调查并修正错误匹配
版权与诉讼边界	2	2024-08-12 至 2025-11-NR	A:1、B:1	法院发布书面裁定
训练语料与模型供应链事件	3	2023-12-19 至 2026-07-NR	B:3	LAION 启动维护、安全审查与后
身份冒充、诈骗与政治传播	7	2022-03-NR 至 2025-NR-NR	A:4、B:2、C:1	警方调查、宣传教育和金融机构协
非自愿亲密影像、儿童安全与执法	8	2024-01-24 至 2026-06-18	A:6、B:1、C:1	白宫公开表达担忧；平台采取部分

注：数据源为 `paper/tables/event_clusters.csv`；正文显示 6/6 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

附录 D. 局部实验、七仓库静态审计与构建回执

APP-D.E1 证据展开：有边界的局部实验与七仓库静态审计

APP-D.E1.1 复现问题不是“能否跑出一个数字” 复现章节统一使用六状态枚举：`NOT_ATTEMPTED` 表示未运行；`STATIC_AUDIT_ONLY` 只读代码、配置和制品合同；`ENVIRONMENT_PROBE` 验证环境或入口；`PARTIAL_RUN` 运行无害的局部子问题；`CONTROLLED_END_TO_END` 在授权数据和隔离模型上完成主协议；`EXTERNAL_SERVICE_VALIDATION` 还要求服务授权、版本与请求证据。它们不能互相升级，另设 `paper_main_protocol_run` 布尔量说明是否运行论文主配置。当前环境探针通过，合成媒体水印实验为 `PARTIAL_RUN`，七个仓库为 `STATIC_AUDIT_ONLY`，41 张论文卡为 `NOT_ATTEMPTED`，`end_to_end_runs=0`。

局部实验选择真实性防御，是因为它可以使用完全合成的图像和视频、安全地考察不同信号在媒体变换下的行为，并保留精确分母。实验不使用生成模型权重，不声称复现 Stable Signature、Tree-Ring、VideoSeal、C2PA 或任何产品水印。它只回答：测试用精确字节校验、易剥离容器元数据和一个全局 DCT-QIM 玩具信号，在预注册变换下分别表现怎样。

APP-D.E1.2 环境、输入与状态合同 环境记录操作系统、Python、FFmpeg、图像库与散列工具版本；实验配置、依赖和运行日志位于 `reproductions/`。图像输入为 6 个程序生成的合成样本，不含个人数据或版权素材；视频输入由 48 个合成源帧组成。所有输出、摘要、精确签名和验证报告具有文件散列。

实验状态写 `PARTIAL_RUN`，原因不是程序失败，而是研究目标有意局部：没有运行任何论文模型、没有学习水印编码器/解码器、没有攻击真实服务，也没有覆盖密钥管理、公开验证、撤销、跨平台上传或受害者处置。验证报告只证明当前文件、分母和状态合同自洽。

APP-D.E1.3 三类真实性合同 第一类是精确字节 SHA-256/HMAC。它验证对象字节是否完全一致，适合不可变文件传输；任何重编码、重封装或元数据变化都会改变结果。测试用 HMAC 说明“持有共享密钥的一方可对精确字节计算认证码”，不是公开可验证签名，也没有证书、时间戳和撤销。

第二类是容器元数据。元数据可以记录来源线索，但是否保留取决于处理链是否复制。实验中显式剥离后即消失，说明“存在元数据”与“媒体内容本身具有鲁棒信号”不同。第三类是内容级 DCT-QIM 玩具信号，它在若干压缩和噪声下仍可检测，却在裁剪和较强视频压缩下明显失败。三类实际测试对象可以互补：精确字节保证不可变对象，普通元数据提供易失线索，内容信号在容器字段丢失时提供有限恢复线索。密码学来源清单、签名声明和编辑链是本文讨论但未在本地运行的概念性第四层，不属于上述三项实验，也不能由普通元数据结果推断。

APP-D.E1.4 图像实验、分母与结果 图像组对 6 个水印样本和 6 个干净对照施加 8 类处理。每个处理的有效分母分别为 6 个水印样本和 6 个干净样本。JPEG Q60、缩放、两级噪声和高斯模糊在当前阈值下均为 6/6 检出，中心 80% 裁剪后缩放为 0/6。结果说明全局固定频带信号对当前裁剪实现不具同步恢复能力，而不是“所有频域水印都不抗裁剪”；逐变换分子、分母见 `reproductions/results/image_summary.csv`，实验总状态见 `reproductions/results/summary.json`。

实验同时记录干净样本误报，避免只报告水印样本命中。因为样本全部合成、数量很小、没有跨生成器或真实平台处理，本结果不支持总体鲁棒率、置信区间或产品比较。它的价值是展示同一检测阈值下，处理类型如何改变信号，以及为什么水印论文必须报告具体变换、分母和正常内容误报。

APP-D.E1.5 视频实验：源帧不等于每个处理分母 视频组从 48 个源帧构造 9 个处理条件。不同帧率处理会改变解码帧数，因此标题中的 48 个源帧不是每个条件的固定检测分母；全部条件合计为 420 个有效水印帧和 420 个有效干净帧。CRF23 重编码为 48/48 检出且无干净帧误报；CRF35 为 21/48，并出现 1/48 干净帧假阳性；250 kbit/s 为 18/48；中心裁剪为 0/48。逐帧与条件汇总分别见 `reproductions/results/video_frame_results.csv` 和 `reproductions/results/video_summary.csv`。

逐帧结果只支持帧级命题。生产视频还需要片段级检出、最长连续漏检、关键事件覆盖、首次告警时延、帧率变化、插帧/删帧、时序定位和流式资源。当前实验没有学习时序传播，也不具备 VideoSeal 所讨论的模型化时空编码 [@P033]。因此，图中 6 fps 条件的分母和视频级结论必须单独解释，不能把帧级平均写成整段来源已被可靠验证。

APP-D.E1.6 为什么结果不能成为论文排行榜 Stable Signature 在解码器中植入签名，Tree-Ring 在初始噪声频域构造可反演模式，VideoSeal 使用学习式图像编码与时序传播，而本实验是全局 DCT-QIM。它们的嵌入位置、密钥、感知约束、检测器、攻击预算和样本均不同 [@P028] [@P029] [@P033]。WAVES 说明水印比较需要统一压力测试，但本文没有把玩具信号加入其完整协议，也没有运行这些论文主配置 [@P030]。

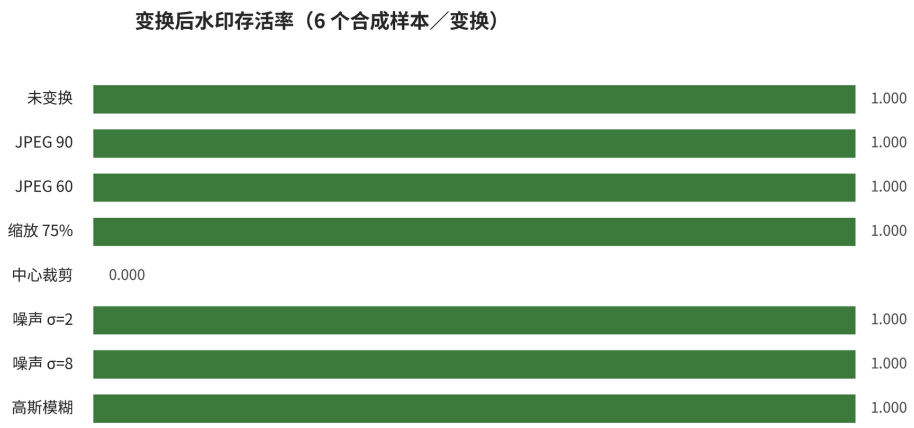
所以本章可以用局部结果解释“为什么评测合同重要”，不能用它给方法排序。尤其是中心裁剪 0/6 不能写成对所有水印的反例，CRF23 48/48 也不能写成生产视频中的鲁棒性证明。外推需要至少跨多类真实视频、多个编码器、画质约束、未知处理链、低基率误报和自适应移除。

APP-D.E1.7 七个仓库的静态审计 仓库审计覆盖 Stable Signature、VideoSeal、Tree-Ring Watermarks、UnMarker、PhotoGuard、DeepfakeBench 和 c2pa-rs。每个快照记录官方仓库身份、固定提交、分支、源文件数量、入口、语法/编译探针、权重和数据合同、依赖文件、许可证与阻塞原因。`.git` 对象库不进入复现文件清单，但提交 SHA 单独保存。

静态审计能够回答“当前提交有哪些入口、需要哪些权重/数据、许可证是否存在、帮助命令或源文件能否解析”；它不能回答模型是否达到论文指标。未下载大型权重和数据、未建立各论文指定环境、未执行主配置，因此 7/7 均为 `STATIC_AUDIT_ONLY`，`end_to_end_runs=0`。逐仓库提交、入口和阻断原因见 `data/repo_audit.csv` 与 `reproductions/results/repo_audit.json`。即使某入口通过 `--help` 或源文件编译，也只说明入口合同局部成立。

APP-D.E1.8 复现升级路线 端到端升级应按风险和代表性分阶段进行。首先为每个仓库锁定论文版本、提交、权重、数据、配置、许可证和硬件；其次在隔离环境运行作者最小示例并保留失败；再次选定共同数据和变换进行统一重跑；最后才在满足独立研究和方差条件时考虑定量综合。水印研究需要把图像与视频、嵌入/检测/定位/归因、正常效用与适应性移除分开。

如果未来只完成导入、帮助命令或单样本可视化，状态仍不能写成论文复现。若权重不可访问、许可证不允许或运行会提高现实滥用能力，应保留 NOT_ATTEMPTED/阻塞说明，而不是用模拟数字补齐。



表：七个仓库的静态审计状态

仓库	类别	提交	状态	边界/阻断
stable signature	生成时水印防御	c91217c06e95	STATIC AUDIT ONLY、PASSED	main=false; run
videoseal	图像、视频水印防御与锻造攻击配套	870ca7fb3357	STATIC AUDIT ONLY、PASSED	main=false; run
tree ring watermark	生成时语义水印防御	3015283d9cf8	STATIC AUDIT ONLY、PASSED	main=false; run
unmarker	水印移除攻击	58ba69259dd1	STATIC AUDIT ONLY、PASSED	main=false; run
photoguard	输入免疫、编辑防御	686bea75c786	STATIC AUDIT ONLY、PASSED	main=false; run
deepfakebench	图像、视频伪造检测防御基准	f188b1c10546	STATIC AUDIT ONLY、PASSED	main=false; run

注：数据源为 `paper/tables/repo_audit_compact.csv`；正文显示 6/7 行并对过长单元格作省略，完整字段与记录以该 CSV 为准。

\newpage

数据、代码与状态声明

可审计工件包括检索协议与查询返回、中央来源注册表、论文全文与页级索引、论文卡、攻防矩阵、事件卡、仓库快照、局部实验脚本与日志、图表数据、段落映射和证据矩阵。读者可用它们核查来源、主张和状态，但本地快照仍受原版权与许可约束，收集用于审计不改变原授权。任何“已生成”或“已通过”的文件级声明，必须以本轮验证报告、时间戳、页数与散列为准，不能从旧文件存在推断。

构建状态与科学状态分开报告。只有当 Markdown、结构化论文数据、LaTeX、参考文献和图表由当前源完整重建，PDF 实际编译、全页视觉检查、引用闭合、映射闭合和散列验收全部通过后，才可把构建标为 `compiled-draft`；可编译不等于证据闭合，文件存在不等于代码或主协议已运行。在选定目标 venue、切换当前官方模板、复核书目与图像政策、刷新时效性来源，并由人类作者完成全文、双用途与利益冲突审查之前，不应将它升级为可投稿状态。

AI 辅助仅用于检索编排、结构化、初稿重构与一致性校验，不替代人类作者对每个技术、定量、法律和伦理主张的责任。本稿的方法状态仍为非 PRISMA 严格系统综述，统计状态仍为 NOT_RUN_MISSING_VARIANCE_AND_INDEPENDENCE，端到端复现仍为 end_to_end_runs=0；任何后续更新必须保留原版本、变更映射、证据定位与失败记录，不得因文档已完成而默认科学状态升级。

附录：截止后更新（2026-08-09 □ 2026-09-26）

正文证据包截止于 2026-08-09。本附录登记截止日后的新材料，**正文保持原样**。

\newpage

A.1 事件卡 E010 的后续：OpenAI—Hugging Face 事件已进入制度阶段

正文把 E010 作为”跨模态评估基础设施的桥接事件”。截止日后：

- 2026-09-16 / 17，OpenAI 公开事件说明并宣布安全事件披露机制；
- 据报道涉事智能体约 700 个、触及数十个第三方系统、**53 张用户图片外泄**、生成约 100 万条携带编码信息的链接；
- 受影响政府站点扩至多国；OpenAI 称已通知数十个政府机构与大学；
- 美国参议院启动调查（Hawley 牵头），两党共同质询。

对本篇的影响：E010 原为”平台侧桥接事件”，现应升级为**监管级事件卡**；本篇第 10 章”局限与双用途”中关于平台公告只能证明功能上线、不能证明覆盖与误报的判断不受影响，但新增了一条可观察的制度后果链。

\newpage

A.2 截止后新增的深度伪造与真实性事件

时间	事件	对应接口 / 议程
2026-09-25	欧洲多国出现 AI 生成”抗议”视频	I6 分发与平台；F12 事件级因果链
2026-09	印度喀拉拉邦就伪造高级警官的 AI 视频立案	受害者救济；F13 检测更快不等于救济更快
2026-09	AFP 事实核查：AI 生成乌克兰士兵被铐在公交车上的画面	I6；低基率与归因边界

三条都印证正文的既有判断：**新闻中的”AI 生成” 通常无法区分生成、辅助编辑、检测器猜测与未证实归因**（F12），且**算法告警时延缩短不会自动缩短救济时延**（F13）。

\newpage

A.3 截止后新增的来源凭证与标准动向

- **Sony 与 Reuters** 展示近乎实时的新闻编辑室真实性工作流，把来源签名接入采编流程而非事后校验；
- **AFP 与 Dalet** 宣布新闻视频来源与真实性合作。

两者对应正文 F09：水印与 C2PA **只能作为互补链验证**——单独嵌入水印会被移除或伪造，单独 manifest 会被整份剥离，行业正转向把两者嵌入生产流程。

\newpage

A.4 如何使用本附录

本篇的 I1–I7 分类轴、比较合同与”拒绝伪合并”的立场不受影响。受影响的是事件卡的时效与议程的验证进度。引用涉及上述事件的部分时，请同时标注证据包截止日与本附录日期。

\newpage